

Aula 03

CBM-PE (Oficial) Informática

Autor:

**Diego Carvalho, Renato da Costa,
Equipe Informática e TI**

15 de Junho de 2026

Índice

1) Malwares - Teoria	3
2) Malwares - Mapa Mental	82
3) Malwares - Resumo	86
4) Malwares - Questões Comentadas - AOCP	92
5) Malwares - Questões Comentadas - MULTIBANCAS	98
6) Malwares - Lista de Questões - AOCP	120
7) Malwares - Lista de Questões - MULTIBANCAS	124



TÓPICOS DA AULA

Tópicos da Aula	3
Malwares	5
Conceitos Básicos	5
Infecção	5
Prevenção	5
Terminologia	7
Principais Malwares	9
Vírus	9
Worm	20
Bot e Botnet	24
Trojan Horse	26
Spyware	29
Backdoor	31
Rootkit	33
Tabela Comparativa	36
Outros Malwares	37
Ransomware	37
Keyloggers	39
Screenloggers	41
Adwares	42
Sniffer	44
Bombas Lógicas	46
Exploits	47
Hijacker	48



Ataques e Golpes	50
Engenharia Social	50
Força Bruta	53
Denial of Service (DoS).....	55
IP Spoofing	57
E-mail Spoofing.....	59
Phishing Scam	61
Hoax	73
Man in the Middle	75
Defacement	76
SQL Injection	77
Furto de Identidade.....	79
Fraude de Antecipação de Recursos.....	80



MALWARES

Conceitos Básicos

INCIDÊNCIA EM PROVA: BAIXA

Malwares (Malicious Softwares) – também chamados de Softwares Maliciosos ou Pragas Virtuais – são programas ou códigos maliciosos desenvolvidos com o objetivo de invadir, danificar, espionar ou obter acesso não autorizado a sistemas, dispositivos ou redes. Eles podem se disfarçar de softwares legítimos ou agir silenciosamente em segundo plano, comprometendo a segurança, a privacidade e o desempenho do sistema afetado. Algumas das formas como eles podem infectar/comprometer um computador são:

FORMAS COMUNS DE INFECÇÃO DE MALWARES

Pela exploração de vulnerabilidades existentes nos programas instalados ou pela auto-execução de mídias removíveis infectadas, como pen-drives;

Pelo acesso a páginas maliciosas, utilizando navegadores vulneráveis ou pela ação direta de atacantes que, após invadirem o computador, incluem arquivos contendo códigos maliciosos;

Pela execução de arquivos previamente infectados, obtidos em anexos de mensagens eletrônicas, via mídias removíveis, em páginas web ou de outros computadores.

Uma vez que esses códigos maliciosos conseguem se instalar no sistema, eles podem acessar dados armazenados, espionar suas atividades e até executar ações em seu nome, dependendo das permissões que o seu usuário tem. É como se o invasor tomasse o controle silencioso do seu computador – e, em muitos casos, você nem percebe de imediato. Mas por que alguém criaria esse tipo de software? Os motivos variam bastante, mas os mais comuns são: ganhar dinheiro, roubar informações confidenciais (como senhas e dados bancários), buscar notoriedade ou simplesmente por vandalismo digital.

Além disso, os malwares são muitas vezes usados como pontes para outros crimes virtuais. Eles ajudam na aplicação de golpes, no lançamento de ataques a outros sistemas ou na disseminação de spam – aquelas mensagens indesejadas que lotam e-mails e redes. As principais categorias de malware são: Vírus, Worm, Bot, Trojan, Spyware, Backdoor e Rootkit. Vejamos:



Infecção

A principal porta de entrada para os malwares hoje é a Internet! Ela pode ocorrer por meio da execução de arquivos infectados obtidos de anexos de mensagens eletrônicas, de mídias removíveis ou dispositivos de memória *flash* (Ex: PenDrive), de páginas web comprometidas, de redes sociais ou diretamente de outros equipamentos. É interessante também tomar muito cuidado ao fazer o download de arquivos com alguns formatos específicos.

Prevenção



É muito provável que a maioria dos seus dados está gravado em seu computador pessoal e, é por meio dele, que você acessa seus e-mails e redes sociais, e realiza transações bancárias e comerciais. **Por conta disso, mantê-lo seguro é essencial para se proteger dos riscos envolvidos no uso da Internet.** Além disso, ao manter seu computador seguro, você diminui as chances de ele ser indevidamente utilizado para atividades maliciosas.

Por diversas vezes, os atacantes estão interessados em conseguir o acesso a grande quantidade de computadores, independentemente de quais são e das configurações que possuem. **Dessa forma, acreditar que seu computador está protegido, por não apresentar atrativos para um atacante, pode ser um erro gigantesco.** Logo, para manter seu computador pessoal seguro, é importante seguir os seguintes procedimentos:

PROCEDIMENTOS DE SEGURANÇA

- Manter os programas instalados com as versões mais recentes.
- Ser cuidadoso ao instalar aplicativos desenvolvidos por terceiros.
- Utilizar apenas softwares originais (sem pirataria).
- Manter os programas instalados com todas as atualizações aplicadas.
- Utilizar mecanismos de proteção (antivírus, firewall, etc).
- Ser cuidadoso ao enviar seu computador para serviços de manutenção.
- Utilizar configurações de segurança disponíveis.
- Ser cuidadoso ao manipular arquivos.
- Proteger seus dados (utilizando backup, por exemplo).
- Manter seu computador com data e hora corretas.
- Criar um disco de recuperação de sistema.
- Ser cuidadoso ao utilizar o computador em locais públicos.



PARA MAIS INFORMAÇÕES, EU RECOMENDO QUE VOCÊS ACESSEM O SITE DO CERT.BR. ESSA AULA TEÓRICA FOI COMPLETAMENTE BASEADA EM SEUS DOCUMENTOS. ACESSEM: [HTTP://WWW.CERT.BR](http://www.cert.br).



Terminologia

INCIDÊNCIA EM PROVA: BAIXÍSSIMA



TERMINOLOGIA	DESCRIÇÃO
HACKER	Trata-se de um usuário experiente – exímio programador – que invade sistemas computacionais para provar suas habilidades, ampliar seus conhecimentos, descobrir novas técnicas e demonstrar vulnerabilidades, mas não para causar danos.
CRACKER	Trata-se de um usuário que invade sistemas para roubar informações, violar a integridade de sistemas, além de outras atividades maliciosas – podem também ser associados a indivíduos que decifram códigos indevidamente e destroem proteções de software para pirataria.
SCRIPT KIDDIES	Também chamado de Newbies, essa terminologia é utilizada para o hacker iniciante, que utiliza de ferramentas prontas na internet para realizar ataques a sistemas computacionais.
INSIDERS	Ameaças internas a uma instituição, funcionários descontentes ou insatisfeitos, corruptos ou subornados ou até mesmo enganados.
PHREAKING	É um especialista em telefonia, sua principal atividade é a realização de ligações gratuitas, clonagem e instalação de escutas em telefones fixos ou celulares.
WAREZ	Software pirata distribuído ilegalmente pela internet.
SPAM	Termo usado para se referir aos e-mails não solicitados geralmente enviados para um grande número de pessoas com finalidade comercial.

(FGV / SEAD-AP - 2010) Quando se trata da Gestão da Segurança da Informação, a terminologia empregada no mundo dos hackers assume papel de importância. A esse respeito, dois termos são a seguir descritos.



I. É o hacking de sistemas telefônicos, geralmente com o objetivo de fazer ligações gratuitas ou para espionar ligações alheias;

II. É o software pirata distribuído ilegalmente pela Internet. Esses dois termos são denominados, respectivamente como:

- a) phishing e worm.
- b) phreaking e warez.
- c) war dialer e worm.
- d) phreaking e phishing.
- e) phishing e warez.

Comentários: (a) Errado. Phishing é uma técnica de fraude para obter dados sensíveis, e worm é um tipo de malware autorreplicante, não relacionado aos conceitos descritos; (b) Correto. "Phreaking" refere-se ao hacking de sistemas telefônicos para obter vantagens como ligações gratuitas, e "warez" são softwares piratas distribuídos ilegalmente; (c) Errado. War dialer é um programa que discar números aleatórios para encontrar modems, e worm é malware – ambos não correspondem corretamente às descrições dadas; (d) Errado. Embora "phreaking" esteja correto, "phishing" é técnica de engano para roubo de dados e não se refere a software pirata; (e) Errado. "Phishing" está incorreto para a primeira definição, embora "warez" esteja certo para a segunda (Letra B).

(CEBRASPE / PCDF - 2012) No mundo cibernético, qual é o termo utilizado para designar quem pratica quebra de proteções de softwares cedidos a título de demonstração usando-os por tempo indeterminado como se fossem cópias legítimas.

- a) worm
- b) hacker
- c) trojan
- d) malware
- e) cracker

Comentários: (a) Errado. "Worm" é um tipo de software malicioso autorreplicante que se espalha por redes, sem relação com a quebra de proteção de softwares; (b) Errado. "Hacker" é um termo genérico, podendo se referir a pessoas com grande conhecimento técnico, nem sempre associadas a atividades ilegais; (c) Errado. "Trojan" ou "Cavalo de Troia" é um tipo de malware disfarçado de software legítimo, usado para enganar usuários e permitir acesso não autorizado ao sistema; (d) Errado. "Malware" é um termo genérico para qualquer software malicioso, mas não define especificamente quem quebra proteções de software de demonstração; (e) Correto. "Cracker" é o termo usado para descrever quem quebra proteções de software, como as limitações de uso de versões demonstrativas, burlando mecanismos de licença (Letra E).

(IBFC / Câmara De Araraquara - 2016) O termo técnico, em inglês, que se refere a e-mails não solicitados, que geralmente são enviados para um grande número de pessoas com intuídos geralmente comerciais é denominado:

- a) zombie
- b) worm
- c) spam
- d) wiki

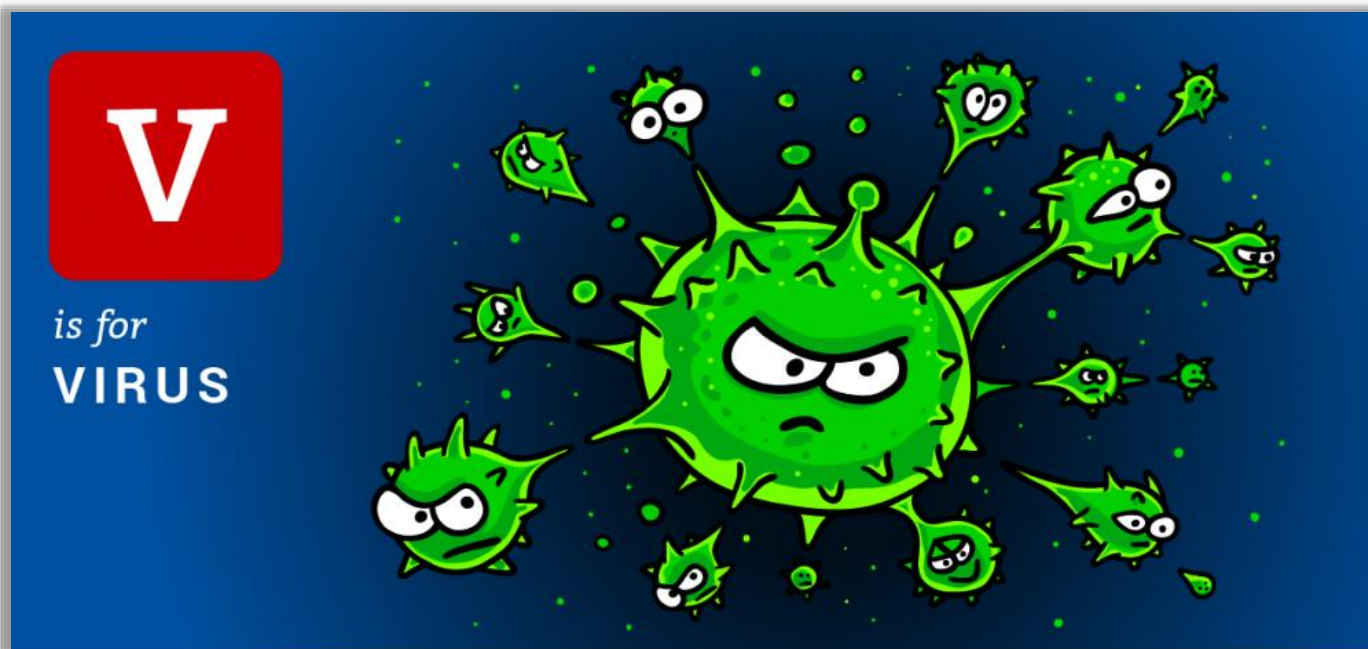
Comentários: (a) Errado. "Zombie" refere-se a um computador comprometido e controlado remotamente por um invasor, muitas vezes usado para ataques em massa, como DDoS, e não para e-mails não solicitados; (b) Errado. "Worm" é um tipo de malware autorreplicante que se espalha por redes, não está relacionado diretamente ao envio de e-mails não solicitados; (c) Correto. "Spam" é o termo usado para e-mails não solicitados enviados em massa, geralmente com conteúdo publicitário ou malicioso; (d) Errado. "Wiki" refere-se a um sistema colaborativo de edição de conteúdo na web, como o Wikipedia, sem relação com e-mails não solicitados (Letra C).



Principais Malwares

Vírus

INCIDÊNCIA EM PROVA: ALTÍSSIMA



Você sabia que os vírus de computador começaram a surgir lá pela década de 1980? Naquela época, eles tinham funções bem simples – alguns só mostravam mensagens na tela ou causavam pequenos incômodos. Mas os tempos mudaram, e hoje, esses códigos podem representar uma ameaça séria, com potencial de causar grandes danos. Empresas e instituições precisam investir cada vez mais para proteger seus sistemas contra esse tipo de invasor. Mas, afinal, o que é exatamente um vírus de computador?

De forma simples, um vírus é um programa (ou um trecho de código) malicioso¹ que se espalha infectando arquivos e programas existentes no computador. Ele se anexa a outros arquivos – como se fosse um parasita digital – e, quando o arquivo hospedeiro é executado, o vírus se ativa, se replica e tenta contaminar o máximo de programas possível normalmente de forma maliciosa².

Um detalhe importante: para ser considerado um vírus, o código precisa ter a capacidade de autorreplicação, ou seja, ele faz cópias de si mesmo e espalha essas cópias pelo sistema. Porém, diferente de outros tipos de malware, os vírus não são autônomos: eles precisam que o usuário execute o arquivo contaminado para começar a agir.

Então, dá para dizer que um vírus realiza duas tarefas principais: se replicar de forma discreta ou agressiva, se espalhando dentro do sistema e, em alguns casos, por redes inteiras; executar seu código malicioso, o que pode gerar uma série de consequências, desde mensagens engraçadinhas na tela até problemas

¹ Eles não precisam ser necessariamente destrutivos ou maliciosos para o sistema do usuário. Um vírus pode, por exemplo, simplesmente mostrar uma imagem na tela do computador.

² Para que um vírus recebido em um anexo de um e-mail seja ativado é necessário que anexo contaminado seja aberto ou executado. Logo, não é necessária a execução explícita do vírus em si, apenas do arquivo ou programa infectado.

sérios, como deixar o computador lento, reiniciá-lo sem aviso, apagar arquivos importantes ou, em casos extremos, causar a perda total dos dados da máquina. Por isso, é fundamental ficar atento a arquivos suspeitos, manter o antivírus atualizado e nunca executar programas de origem duvidosa. Afinal, um simples clique pode ser o ponto de partida para um problema muito maior.

(CEBRASPE / TJ-SE - 2014) Vírus são programas que podem apagar arquivos importantes armazenados no computador, podendo ocasionar, até mesmo, a total inutilização do sistema operacional.

Comentários: vírus são códigos maliciosos que se anexam a arquivos ou programas legítimos e podem causar diversos danos, como exclusão de arquivos e corrupção do sistema, podendo levar à falha total do sistema operacional (Correto).

Um vírus é composto basicamente de três partes: **um mecanismo de infecção**, **um mecanismo de ativação** e **uma carga útil**. Vejamos na tabela a seguir como essas partes são definidas:

COMPOSIÇÃO DE UM VÍRUS		
MECANISMO DE INFECÇÃO	MECANISMO DE ATIVAÇÃO	CARGA ÚTIL
Meios ou formas pelas quais um vírus se propaga, habilitando-o a se reproduzir – é também conhecido como Vetor de Infecção.	Evento ou condição que determina quando a carga útil é ativada ou entregue – às vezes, é conhecido como Bomba Lógica.	O que o vírus faz, além de se espalhar. A carga útil pode envolver algum dano ou atividade benigna, porém notável.

(CEBRASPE / Polícia Federal - 2018) Uma das partes de um vírus de computador é o mecanismo de infecção, que determina quando a carga útil do vírus será ativada no dispositivo infectado.

Comentários: o mecanismo descrito refere-se à *rotina de ativação*, não ao *mecanismo de infecção*. O mecanismo de infecção define como o vírus se propaga, enquanto a carga útil é ativada por uma condição definida pelo vírus (Errado).

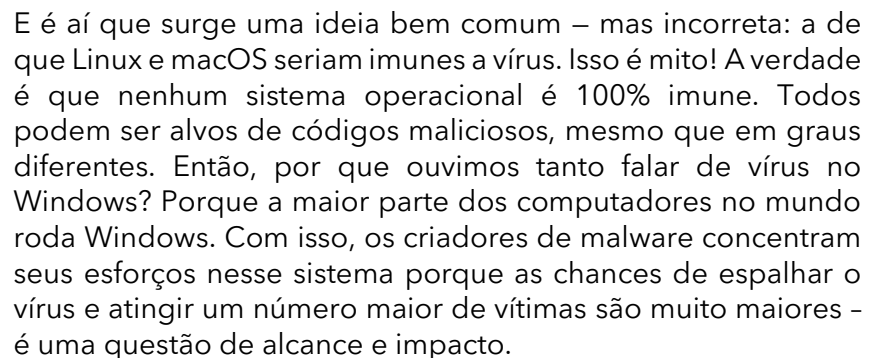
Quando se trata de vírus de computador, eles podem ser classificados em quatro fases de execução: **Dormência**, **Propagação**, **Ativação** e **Ação**. Vejamos:

FASES	DESCRIÇÃO
DORMÊNCIA	Nessa fase, o vírus está ocioso. A certa altura, ele será ativado por algum evento, como uma data, a presença de outro programa ou arquivo, ou a ultrapassagem de algum limite de capacidade de disco. Nem todos os vírus têm esse estágio.
PROPAGAÇÃO	Nessa fase, o vírus instala uma cópia de si mesmo em outros programas ou em certas áreas do sistema no disco. A cópia pode não ser idêntica à versão de propagação; muitas vezes, os vírus mudam de forma para escapar à detecção. Agora, cada programa infectado conterá um clone do vírus, que também entrará em uma fase de propagação.
ATIVAÇÃO	Nessa fase, o vírus é ativado para executar a função pretendida. Como ocorre com a fase de dormência, a fase de ativação pode ser causada por uma variedade de eventos de sistema, incluindo a contagem do número de vezes que essa cópia de vírus fez uma cópia de si mesma.
AÇÃO	Nessa fase, a função é executada. Ela pode ser inofensiva, como uma mensagem na tela, ou danosa, como a destruição de programas e arquivos de dados.



a) Dormente; Propagação; Ativação; e, Ação.
b) Ataque; Penetração; Replicação; e, Liberação.
c) Diversidade; Robustez; Autoexecução; e, Privilégio.
d) Anonimato; Garantia; Autenticidade; e, Disponibilidade.

Quando a gente fala sobre vírus que infectam arquivos executáveis, é importante entender que eles costumam ser desenvolvidos especificamente para um determinado sistema operacional – e, às vezes, até para um tipo específico de hardware. Isso acontece porque os vírus são escritos para explorar características, falhas ou vulnerabilidades específicas daquele sistema. Ou seja, um malware que foi feito para rodar no Windows, por exemplo, normalmente não vai funcionar no Linux ou no macOS.



Comentários: nenhum sistema operacional é totalmente imune a vírus. Embora o Linux seja menos visado por ter menor participação no mercado de desktops e adote uma arquitetura mais restritiva, ele pode sim ser afetado. As falhas em Windows não se limitam ao kernel (Errado).

Continuando... alguns tipos de vírus procuram permanecer ocultos, infectando arquivos do disco e executando uma série de atividades sem o conhecimento do usuário. Outros tipos de vírus permanecem inativos durante certos períodos, entrando em atividade apenas em datas específicas – quando sua carga útil é ativada. Nas próximas páginas, nós veremos diversos tipos de vírus:

Vírus de Script

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Vamos entender o que é um script? Imagina um ator se preparando para uma cena: ele precisa de um roteiro, certo? Esse roteiro diz exatamente o que ele deve falar e fazer. No mundo da tecnologia é bem parecido. Um script, nesse contexto, é um conjunto de instruções que dizem ao computador o que deve ser feito.

Quer ver um exemplo prático? As páginas da internet estão cheias de scripts, geralmente escritos numa linguagem chamada JavaScript. Esses scripts servem para deixar os sites mais interativos e dinâmicos. Sabe quando você clica num botão e aparece uma animação? Ou quando uma página atualiza o conteúdo automaticamente sem você precisar recarregar? Então, pode apostar que tem JavaScript ali. Se você desativar esses scripts no navegador, vai perceber: as páginas ficam estáticas, meio travadas, e vários recursos simplesmente somem.

Agora, não é só na internet que os scripts aparecem. Documentos do computador também podem conter scripts. Um exemplo clássico são as macros do MS-Excel. Já ouviu falar? São pequenas instruções programadas para fazer tarefas automaticamente. Tipo: você clica num botão dentro da planilha e ele calcula a média de vendas de um supermercado – isso é feito por um macro, que nada mais é do que um script. Nesse caso, escrito em VBScript.

Mas, atenção: nem todo script é do bem. Existem os chamados vírus de script – códigos maliciosos escritos em linguagens como JavaScript ou VBScript, que podem infectar seu computador. Como eles chegam até a gente? Muitas vezes por meio de páginas da web maliciosas, e-mails com arquivos anexos, ou até no próprio corpo do e-mail, quando ele vem em formato HTML.

E tem um detalhe importante: dependendo da configuração do seu navegador ou do seu programa de e-mail, esses scripts podem ser executados automaticamente – ou seja, sem você clicar em nada. Por isso, fica o alerta: não saia abrindo qualquer arquivo anexo de e-mail, mesmo que pareça vir de alguém conhecido. O computador da pessoa pode estar comprometido e você nem imagina.

(FCM / IFS-MS - 2016) Os vírus de scripts, que são os vírus que exploram as linguagens de script, são executados automaticamente pelos softwares de leitura de e-mails, por exemplo.

Comentários: vírus de script exploram linguagens como VBScript ou JavaScript e podem ser executados automaticamente por softwares vulneráveis, como leitores de e-mails mal configurados, especialmente em versões antigas (Correto).

(CEBRASPE / PRF - 2019) No acesso a uma página web que contenha o código de um vírus de script, pode ocorrer a execução automática desse vírus, conforme as configurações do navegador.

Comentários: vírus de script podem ser executados automaticamente ao acessar páginas web, dependendo das configurações e vulnerabilidades do navegador. Scripts maliciosos em JavaScript, por exemplo, podem ser ativados sem intervenção do usuário.

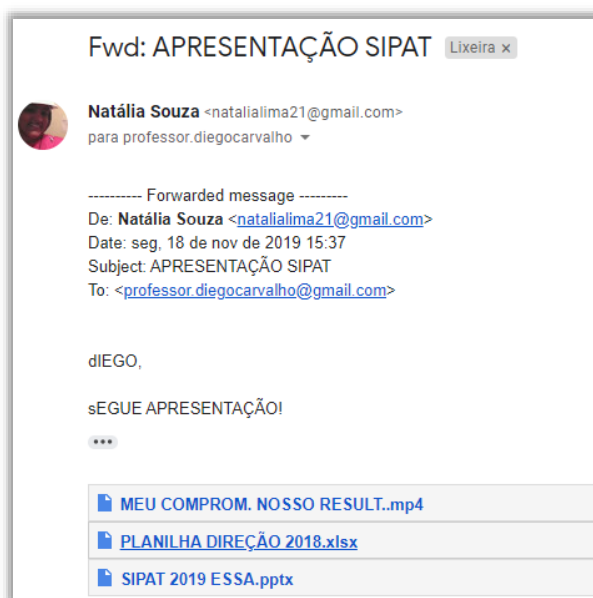
Vírus de Macro

INCIDÊNCIA EM PROVA: ALTÍSSIMA



Nós a-ca-ba-mos de ver o que é uma macro! Nós já sabemos que se trata de um tipo de script, logo os vírus de macro são um tipo específico de vírus de script – escrito em linguagem de macro – **que tenta infectar arquivos manipulados por aplicativos que utilizam essa linguagem como, por exemplo, os arquivos de dados que compõem o Microsoft Office (Excel, Word, PowerPoint, Access, entre outros)**. Esse tipo de vírus despeeeeeeeenca em prova!

Os vírus de macro utilizam técnicas de propagação baseadas em anexos de documentos que executam macros, uma vez que os usuários frequentemente compartilham documentos com recursos de macro habilitados. Quando um software carrega um arquivo com esse código malicioso, ele executa as instruções do vírus nele contidas, que geralmente são as primeiras instruções executadas.



Galera, vejam a imagem anterior! **Um dia desses eu recebi um e-mail de um remetente desconhecido falando comigo como se já nos conhecêssemos.** Havia três anexos com formato .mp4, .xlsx, .pptx. Era muito provável que os dois últimos tratassem de vírus de macro, apesar de haver outras possibilidades. *O que eu fiz?* Bloqueei o remetente e excluí a mensagem. Enfim, serviu pelo eu mostrar um caso real para vocês. Jamais abram anexos sem verificar antes!

VÍRUS DE MACRO

Ele infecta documentos e, não, programas – grande parte das informações em um sistema de computador se encontra na forma de documentos e, não, de programas;

Ele é fácil de se propagar, já que os documentos que eles exploram normalmente são compartilhados – um método muito comum de distribuição é por meio do envio de e-mails;

Como ele infecta documentos de usuário, os tradicionais controles de acesso a sistemas de arquivo são de efetividade limitada para impedir que eles se espalhem;

Eles geralmente infectam arquivos de dados produzidos por suítes de aplicativos de escritório como o Microsoft Office;

Vírus de Macro costumam alterar ou substituir um conjunto de comandos utilizados por programas para executar ações comuns;

É necessário que o arquivo que contém o vírus de macro seja aberto para que ele execute suas automaticamente instruções maliciosas e infecte outros arquivos no computador;

Eles podem ser bloqueados por meio de uma configuração específica dos programas do MS-Office. Para tal, deve-se bloquear a execução de macros em documentos;



A propagação ocorre quando documentos por ele infectados são remetidos por correio eletrônico para outros usuários;

A assinatura digital de um arquivo por meio da utilização de um certificado digital é possível evitar vírus de macro.

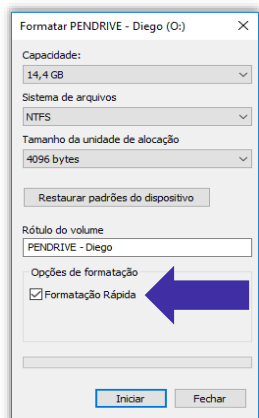
(FCC / CLDF - 2018) Um usuário de um computador relatou para o Administrador do sistema computacional que, ao abrir um arquivo do tipo .DOC recebido por e-mail, o computador utilizado começou a realizar ações erráticas e desordenadas. A partir desse relato, o Administrador concluiu que o computador foi infectado pelo malware do tipo:

- a) Spyware
- b) vírus de macro.
- c) Trojan Dropper.
- d) Backdoor.
- e) Worm.

Comentários: (a) Errado. Spyware coleta informações do usuário sem consentimento, mas não costuma causar comportamento errático imediato ao abrir arquivos; (b) Correto. Vírus de macro se espalham por documentos como arquivos .DOC, executando comandos automaticamente ao serem abertos, causando comportamentos anômalos; (c) Errado. Trojan Dropper serve para instalar outros malwares no sistema, mas geralmente atua de forma silenciosa e não está diretamente associado à abertura de arquivos .DOC; (d) Errado. Backdoors permitem acesso remoto ao sistema comprometido, mas não estão diretamente relacionados ao sintoma descrito; (e) Errado. Worms se propagam por redes automaticamente e não dependem da abertura de arquivos específicos para causar infecção local (Letra B).

Vírus de Boot

INCIDÊNCIA EM PROVA: BAIXÍSSIMA



Diego, o que é Boot? Galera, trata-se do procedimento de inicialização do computador durante o carregamento do sistema operacional, logo após a máquina ser ligada! **O Vírus de Boot - também chamado de Vírus de Setor ou Vírus de Setor de Inicialização - é um dos primeiros tipos de vírus conhecidos e infecta a parte de inicialização do sistema operacional, escondendo-se no primeiro setor da memória.**

Ele é ativado quando o computador é ligado e é carregado na memória antes mesmo do carregamento do sistema operacional. Os Vírus de Boot afetam o procedimento descrito anteriormente e podem impedir que o sistema operacional seja executado de forma adequada - aliás, eles podem afetar inclusive dispositivos móveis de armazenamento como pendrives!

A formatação rápida de um pendrive infectado não garante a remoção completa de vírus, uma vez que alguns malwares conseguem se alojar na MBR (Master Boot Record) - que é o setor de inicialização de dispositivos de armazenamento. Recomenda-se, portanto, não selecionar a opção de Formatação Rápida apresentada na imagem anterior.

(FCC / BB - 2011) Ativado quando o disco rígido é ligado e o sistema operacional é carregado; é um dos primeiros tipos de vírus conhecido e que infecta a partição de inicialização do sistema operacional. Trata-se de:

- a) vírus de boot.
- b) cavalo de Troia.
- c) verme.



- d) vírus de macro.
- e) spam.

Comentários: (a) Correto. Vírus de boot infectam a área de inicialização do disco (setor de boot) e são ativados logo no início da carga do sistema operacional, sendo um dos primeiros tipos de vírus conhecidos; (b) Errado. Cavalo de Troia (Trojan) disfarça-se como software legítimo, mas não infecta a partição de inicialização; (c) Errado. Vermes (worms) se replicam automaticamente por redes e não atuam no processo de boot do sistema; (d) Errado. Vírus de macro atuam em documentos de aplicativos de escritório, não na inicialização do sistema; (e) Errado. Spam refere-se a mensagens eletrônicas não solicitadas, não sendo um tipo de vírus. (Letra A).

(QUADRIX / CODHAB - 2018) O vírus de boot é um vírus que age diretamente na inicialização do sistema de computadores conectados à rede. Contudo, ele não é espalhado por meio de dispositivos, como, por exemplo, pen drives.

Comentários: vírus de boot afetam a área de inicialização de discos e podem sim ser espalhados por dispositivos como pen drives e mídias removíveis com capacidade de boot. A afirmação ignora esse vetor comum de infecção (Errado).

Vírus de Arquivo

INCIDÊNCIA EM PROVA: ALTÍSSIMA

Também chamado de Vírus de Programa ou Vírus Parasitário, trata-se do vírus mais tradicional no cotidiano das pessoas. **Ele infecta arquivos executáveis, sobrescrevendo o código original e causando danos quase sempre irreparáveis.** Em geral, replicam-se ao localizar outros arquivos executáveis, embora possam também infectar arquivos que sejam requisitados para a execução de alguns programas, como os arquivos com as seguintes extensões (principalmente .exe).



(IESES / SEPLAG-MG - 2013) Assinale a única alternativa correta, que corresponde a seguinte definição: "Estes tipos de vírus são os que mais causam danos, pois atacam arquivos executáveis (.exe, .com, .ovl, .dll) sobrescrevendo o código original e causando danos quase sempre irreparáveis. Para ser contaminado por este vírus se deve executar um arquivo já infectado.":

- a) Vírus invisível.
- b) Vírus de macro.
- c) Vírus de boot.
- d) Vírus de programa.

Comentários: (a) Errado. "Vírus invisível" não é uma classificação técnica precisa, sendo um termo genérico usado para vírus difíceis de detectar; (b) Errado. Vírus de macro infectam arquivos de aplicativos de escritório (como .doc, .xls), e não arquivos executáveis; (c) Errado. Vírus de boot afetam o setor de inicialização do disco, não arquivos executáveis como .exe ou .dll; (d) Correto. Vírus de programa (ou de arquivos) infectam arquivos executáveis, sobrescrevendo ou anexando código malicioso, sendo ativados com a execução do arquivo contaminado (Letra D).

(IBADE / Câmara de Jarú-RO - 2019) Dos tipos de arquivo abaixo, você evitaria abrir para se proteger da instalação de um vírus o arquivo:



- a) .AWS
- b) .JPEG
- c) .MP3
- d) .EXE
- e) .XLS

Comentários: (a) Errado. Arquivos .AWS são usados por softwares como o Ability Write e não são comumente vetores de vírus; (b) Errado. Arquivos .JPEG são imagens e, embora possam conter código malicioso em vulnerabilidades específicas, não são normalmente executáveis; (c) Errado. Arquivos .MP3 são arquivos de áudio e não executam código diretamente, sendo risco baixo para infecção por vírus; (d) Correto. Arquivos .EXE são executáveis e podem conter código malicioso. Abrir um .EXE desconhecido é uma das principais formas de infecção por vírus; (e) Errado. Embora arquivos .XLS possam conter macros maliciosas, o risco é menor que o de arquivos executáveis diretos como .EXE (Letra D).

Vírus Polimórfico

INCIDÊNCIA EM PROVA: MÉDIA



Também chamado de Vírus Mutante, é capaz de assumir múltiplas formas a cada infecção com o intuito de burlar o software de antivírus. Como ele faz isso, professor? Ele muda sua assinatura, mantendo suas funcionalidades e alterando apenas o seu padrão de bits. A assinatura é uma característica utilizada pelos antivírus para detectar a sua presença. Pode ser um nome, um comportamento ou o tamanho do vírus.

Os vírus polimórficos são capazes de criar uma nova variante a cada execução, alterando tanto a rotina de encriptação quanto a rotina de decriptação. Em geral, para realizar a detecção dessas ameaças, os antivírus fazem a decriptação do vírus usando um emulador ou realizam uma análise de padrão do corpo do vírus, uma vez que verificar a assinatura é pouco efetivo em um contexto em que o código muda, mas a semântica, não.

(IADES / CFA - 2010) Tem a capacidade de gerar réplicas de si mesmo utilizando-se de chaves de encriptação diversas, fazendo com que as cópias finais possuam formas diferentes. A polimorfia visa a dificultar a detecção de utilitários antivírus, já que as cópias não podem ser detectadas a partir de uma única referência do vírus. Tal referência normalmente é um pedaço



do código virótico, que no caso dos vírus polimórficos varia de cópia para cópia. O texto do enunciado da questão está se referindo aos vírus:

- a) de scripts.
- b) criptografados.
- c) mutantes.
- d) stealth ou furtivos.

Comentários: (a) Errado. Vírus de script exploram linguagens como JavaScript e VBScript, mas não possuem mecanismos de mutação de código como descrito no enunciado; (b) Errado. Vírus criptografados usam criptografia para ocultar seu conteúdo, mas não necessariamente mudam sua forma em cada replicação; (c) Correto. Vírus mutantes, também chamados de polimórficos, alteram seu código a cada replicação, dificultando a detecção por antivírus baseados em assinaturas; (d) Errado. Vírus stealth (furtivos) escondem sua presença no sistema, mascarando arquivos ou processos, mas não alteram seu código como os mutantes (Letra C).

Uma variação do vírus polimórfico é o vírus metamórfico que, diferentemente do vírus polimórfico - se reescreve completamente a cada infecção, podendo mudar seu tamanho e comportamento, aumentando a dificuldade de detecção. Aqui não tem muito o que falar: basta lembrar que o Vírus Polimórfico muda apenas a sua assinatura, mantendo sua funcionalidade, e o Vírus Metamórfico muda sua assinatura e sua funcionalidade.

(FCC / SUGEP - 2018 - Letra B) O vírus metamórfico muda a cada infecção, se reescrevendo completamente a cada iteração, aumentando a dificuldade de detecção.

Comentários: vírus metamórficos realmente se reescrevem completamente a cada infecção, modificando seu próprio código sem utilizar criptografia ou ofuscação simples, o que dificulta bastante sua detecção por antivírus tradicionais (Correto).

Vírus Stealth

INCIDÊNCIA EM PROVA: BAIXÍSSIMA



Vocês já ouviram falar no avião Lockheed Blackbird SR-71? Ele é conhecido por ser o avião mais incrível de toda a história da aviação. Por que ele era tão especial, Diego? **Galera, esse avião tinha uma característica muito peculiar: ele era praticamente invisível a radares, sendo capaz de refletir ou absorver ondas eletromagnéticas.** Por conta disso, ele ganhou a denominação de Avião Furtivo ou Stealth. Professor, o que isso tem a ver com a aula?

Pessoal, vocês acreditam que nós temos um tipo de vírus chamado de Vírus Stealth? **Também chamado de Vírus Furtivo, eles são projetados explicitamente para não serem detectados pelo antivírus,** possuindo a capacidade de se remover da memória do computador temporariamente para evitar que o antivírus o detecte. Da mesma forma que o avião stealth era capaz de se esconder de radares, o vírus stealth é capaz de se esconder de antivírus.

(CEBRASPE / TCU - 2015) O vírus do tipo stealth, o mais complexo da atualidade, cuja principal característica é a inteligência, foi criado para agir de forma oculta e infectar arquivos do Word e do Excel. Embora seja capaz de identificar conteúdos importantes nesses tipos de arquivos e, posteriormente, enviá-los ao seu criador, esse vírus não consegue empregar técnicas para evitar sua detecção durante a varredura de programas antivírus.

Comentários: vírus do tipo *stealth* são projetados justamente para evitar detecção, usando técnicas como interceptação de chamadas do sistema para ocultar sua presença. Além disso, não são especificamente ligados a arquivos do Word e Excel – isso seria típico de vírus de macro (Errado).

Vírus Time Bomb

INCIDÊNCIA EM PROVA: MÉDIA

Também conhecido como Vírus Bomba Relógio, trata-se de um vírus que – após infectar a máquina – permanece latente (oculto), apenas se replicando. **Além disso, seu código malicioso é programado para ser ativado em um determinado momento específico, executando sua carga útil.** É comumente distribuído como anexo de e-mails e se instalam em computadores pela ação do usuário, ao executar o arquivo.

Os Time Bombs se instalam silenciosamente e agem apenas em datas ou momentos determinados, que são definidos pelo seu criador. Alguns vírus conhecidos foram:

- Sexta-feira 13 (ações danosas apenas nas sextas-feiras 13);
- I Love you (ação danosa apenas no dia dos namorados – 12 de junho)
- Chernobyl (ação danosa apenas no dia do acidente nuclear – 25 de abril)

(CESBRASPE / MTE - 2014) Quando ativado na máquina, a principal característica do vírus time bomb é a sua capacidade de remover o conteúdo do disco rígido em menos de uma hora.

Comentários: a principal característica do Vírus Time Bomb é sua capacidade de ser ativado em momentos específicos – definidos pelo criador. Não há necessariamente nenhuma relação com a remoção do conteúdo do disco rígido em menos de uma hora (Errado).

Vírus de E-Mail

INCIDÊNCIA EM PROVA: MÉDIA



Os vírus propagados por e-mail são recebidos como um arquivo anexo a um e-mail cujo conteúdo tenta induzir o usuário a clicar sobre este arquivo, fazendo com que seja executado. Quando entra em ação, infecta arquivos e programas e envia cópias de si mesmo para os e-mails encontrados nas listas de contatos gravadas no computador. Por essa razão, é importante desabilitar a autoexecução de arquivos anexos em e-mails e verificar a sua extensão.

(FCC / TJ/SE - 2009) Quanto às medidas sensatas e objetivas de precaução contra a propagação de vírus por e-mail, considere:

- I. Nunca abrir arquivos anexados às mensagens.
- II. Desabilitar, no programa leitor de e-mails, a auto-execução de arquivos anexados às mensagens.
- III. Não anexar arquivos às mensagens.
- IV. Excluir todos os e-mails que forem recebidos com arquivos anexados.

Está correto o que se afirma APENAS em:

- a) I.
- b) I e II.
- c) II.
- d) II e III.
- e) III e IV.

Comentários: (I) Errado, pode-se abrir arquivos anexados às mensagens, mas é importante passar previamente por algum antivírus; (II) Correto, isso é importante para que o leitor de e-mails não faça o download automático sem verificação do arquivo; (III) Errado, isso não é necessário; (IV) Errado, isso não é necessário (Letra C).

Vírus Multipartite

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

Um vírus multipartite é um tipo de malware que possui a capacidade de infectar múltiplas áreas de um sistema ao mesmo tempo, como arquivos executáveis e setores de inicialização do disco, especificamente o boot sector ou a Master Boot Record (MBR). Diferente de vírus comuns que atuam em apenas uma parte do sistema, os multipartites combinam características de vírus de arquivos e vírus de boot, tornando-se mais versáteis e perigosos. Eles conseguem se espalhar rapidamente, pois têm mais de um método de infecção e podem ativar diferentes partes do seu código em momentos distintos da operação do computador.

O processo de infecção de um vírus multipartite geralmente começa no carregamento inicial do sistema operacional, caso tenha contaminado o setor de boot, ou quando um arquivo infectado é executado. A partir daí, ele se replica comprometendo outras áreas, o que aumenta sua persistência no sistema. Isso significa que, mesmo que o usuário apague os arquivos contaminados, se o setor de boot ainda estiver infectado, o vírus pode se reinstalar – e o contrário também é verdadeiro. Essa característica torna sua remoção muito mais complexa.

Outro ponto importante é que esse tipo de vírus frequentemente se vale de técnicas de ocultação, como polimorfismo ou stealth, para dificultar a detecção por antivírus. Alguns multipartites podem modificar seu próprio código (criptografando-se, por exemplo) ou agir apenas em situações específicas para evitar serem identificados. Eles também podem causar diferentes tipos de danos, como corrupção de dados, lentidão do sistema ou falhas no processo de inicialização.



Por causa de sua atuação híbrida e persistente, o vírus multipartite representa uma ameaça significativa à segurança dos sistemas. A melhor forma de prevenção envolve manter o sistema operacional atualizado, utilizar um antivírus com proteção em tempo real, evitar mídias removíveis ou arquivos de origem desconhecida e realizar rotinas de backup. Em caso de infecção, a remoção completa pode exigir tanto limpeza de arquivos quanto reparo do setor de boot ou, em casos extremos, a reinstalação do sistema.

Alguns alunos confundem o vírus de boot com o vírus multipartite. Ora, todo vírus de boot ataca apenas o setor de inicialização. Um vírus multipartite pode atacar o setor de boot e também arquivos do sistema. Isso significa que todo vírus multipartite pode conter um componente de boot, mas nem todo vírus de boot é multipartite.

Vírus de Substituição

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

O vírus de substituição, também classificado como um tipo de vírus de arquivo, é uma forma de malware particularmente destrutiva. Ele infecta arquivos executáveis substituindo completamente o conteúdo original por uma cópia de si mesmo. Diferentemente de outros vírus que apenas inserem trechos de código malicioso dentro do arquivo, o vírus de substituição apaga parcial ou totalmente o código legítimo e o substitui de forma permanente. Por isso, é considerado uma das formas mais agressivas de infecção digital.

É crucial entender que, ao realizar essa substituição, o vírus não mantém cópias de segurança dos dados ou do arquivo original. Isso significa que o dano causado é, na maioria das vezes, irreversível, já que o código legítimo do arquivo contaminado deixa de existir. Assim, mesmo que um antivírus consiga detectar e remover a ameaça, o arquivo infectado não pode ser restaurado a menos que exista um backup ou uma versão original armazenada em outro local. Essa característica torna o vírus de substituição especialmente perigoso para ambientes sem rotinas de backup.

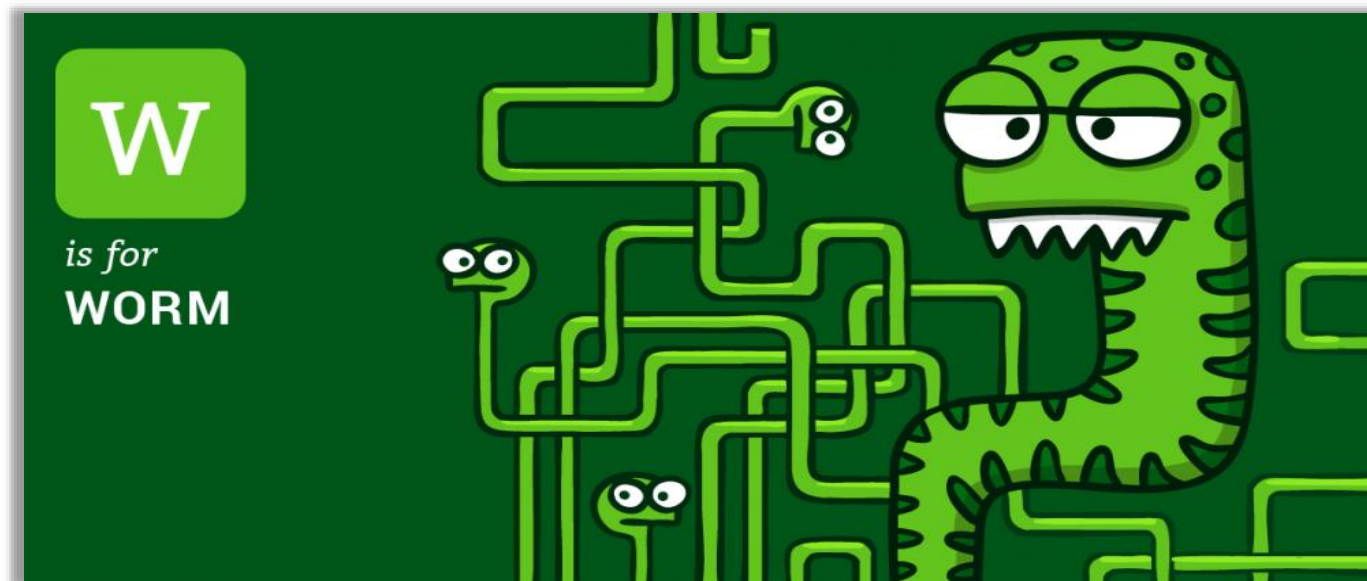
Quando um arquivo infectado é executado, o vírus inicia sua propagação procurando outros executáveis para sobrescrever. Esse comportamento pode comprometer programas essenciais, corromper dados importantes e até impedir o funcionamento de sistemas operacionais ou aplicativos críticos. Como o conteúdo original do arquivo deixa de existir, alguns antivírus podem ter dificuldade inicial na identificação, já que não há mais um padrão íntegro para comparação.

A proteção contra esse tipo de vírus depende de um conjunto de boas práticas: uso de antivírus com monitoramento em tempo real, atualização constante do sistema operacional, desconfiança de anexos e programas desconhecidos, além de rotinas de backup frequentes e automatizadas. Isso porque, diante de uma infecção por vírus de substituição, a única forma segura de recuperar arquivos perdidos é restaurá-los de uma cópia limpa. Assim, mais do que uma ameaça técnica, esse tipo de vírus evidencia a importância da prevenção e da gestão correta de dados.



Worm

INCIDÊNCIA EM PROVA: ALTÍSSIMA



Worm (ou Verme) é um programa capaz de se replicar automaticamente, enviando cópias de si mesmo de computador para computador. **Diferente dos vírus, ele não se propaga por meio da inclusão de cópias de si mesmo em outros programas ou arquivos através da rede**, mas – sim – pela exploração automática de vulnerabilidades existentes em programas instalados em computadores ou pela execução direta de suas cópias.

Pois é! Nesse primeiro parágrafo, nós temos dois pontos que necessitam de mais atenção: primeiro, worms podem – sim – ser executados diretamente, apesar de não ser a regra; segundo, worms não infectam outros arquivos, eles mesmos são os arquivos. Eles identificam computadores ativos na rede e exploram as conexões ou através da Internet por meio de correio eletrônico, redes sociais, bate papo, entre outros.

Worms são notadamente responsáveis por consumir muitos recursos, devido à grande quantidade de cópias de si mesmo que costumam propagar e, como consequência, degradam sensivelmente o desempenho de redes e podem lotar o disco rígido de computadores. **O processo de infecção e propagação ocorre em quatro fases: identificação dos computadores alvos; envio das cópias; ativação das cópias; e reinício do processo.**

- **Identificação de computadores-alvo:** também conhecido como *scanning*, após infectar um computador, ele tenta se propagar e continuar o processo de infecção. Para tal, ele necessita identificar os computadores alvos para os quais tentará se copiar;
- **Envio de cópias:** após identificar os alvos, ele efetua cópias de si mesmo e tenta enviá-las para estes computadores anexadas a e-mails, via canais de IRC, via programas de troca de mensagens instantâneas, incluídas em pastas compartilhadas em redes locais, etc;
- **Ativação de cópias:** após realizado o envio da cópia, ele necessita ser executado para que a infecção ocorra, o que pode acontecer imediatamente após ter sido transmitido, diretamente pelo usuário ou condicionado a algum evento específico (como a inserção de uma mídia):



- Imediatamente após a transmissão, pela exploração de vulnerabilidades em programas sendo executados no equipamento alvo no momento do recebimento da cópia;
- Diretamente pelo usuário, pela execução de uma das cópias enviadas ao seu equipamento;
- Pela realização de uma ação específica do usuário, a qual o worm está condicionado como, por exemplo, a inserção de uma mídia removível.

Os worms são capazes de entrar em uma máquina sem qualquer interação do usuário. Em geral, podem ser obtidos automaticamente pela rede, recebidos por e-mail, baixados de páginas na web, pelo compartilhamento de arquivos, pelo uso de mídias removíveis infectadas, por meio de redes sociais, por meio de mensagens instantâneas, por conta de uma invasão de um hacker ou pela ação de outro código malicioso.

E quais são as ações maliciosas mais comuns de um worm? Sua ação maliciosa mais comum consiste em consumir muitos recursos, devido à grande quantidade de cópias de si mesmo que costumam propagar e, como consequência, podem afetar o desempenho de redes e do computador. Além disso, eles podem instalar outros códigos maliciosos no computador, desferir ataques na internet e enviar e-mails sem autorização.

Sobre ações maliciosas, é importante destacar novamente que worms não infectam arquivos. Em resumo, os worms são programas autorreplicantes completos e autônomos que não necessitam de um programa hospedeiro para se propagar. Diferentemente dos vírus, esse programa não embute cópias de si mesmo em outros programas ou arquivos – além de não precisarem ser explicitamente executados para se propagar.



WORM = VERME

ALGUNS DIZEM QUE SEU NOME VEM DE: WRITE ONCE RUN EVERYWHERE

(FUNCERN / Prefeitura de Apodi-RN - 2019) Os malwares são programas maliciosos cujo objetivo é roubar informações ou contaminar os computadores. O malware que tem a capacidade de se propagar na rede de computadores é o:

- a) vírus
- b) worm
- c) netmal
- d) trojan.

Comentários: (a) Errado. O vírus precisa da ação do usuário e de um programa hospedeiro para se propagar, não se replica automaticamente pela rede; (b) Correto. O *worm* (verme) é um malware que se propaga automaticamente pela rede, explorando vulnerabilidades para infectar outros sistemas sem intervenção do usuário; (c) Errado. “Netmal” não é uma classificação reconhecida de malware na literatura técnica; (d) Errado. O *trojan* (cavalo de troia) se disfarça de software legítimo para enganar o usuário, mas não se propaga automaticamente pela rede (Letra B).

(FGV / PC-MG - 2018) O tipo de ameaça à segurança de um computador que consiste em um programa completo que se replica de forma autônoma para se propagar para outros computadores é:

- a) Worm
- b) Vírus
- c) Spyware
- d) Spam.

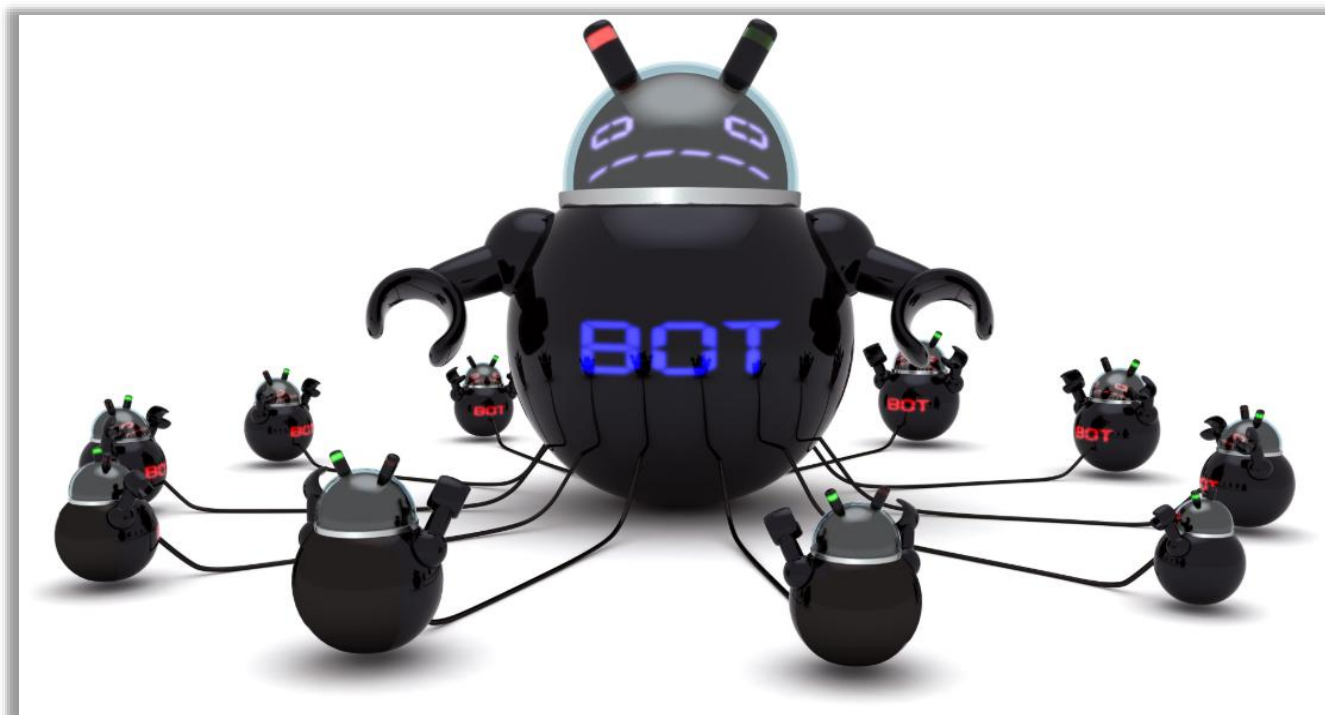


Comentários: (a) Correto. Worms são programas completos e independentes que se replicam automaticamente e se propagam pela rede sem depender de um programa hospedeiro ou da ação do usuário; (b) Errado. Vírus precisam de um arquivo hospedeiro e geralmente exigem a execução desse arquivo pelo usuário para se espalharem; (c) Errado. Spyware é projetado para espionar o usuário e capturar dados sem consentimento, não se propaga automaticamente; (d) Errado. Spam é o envio massivo de mensagens não solicitadas, normalmente por e-mail, mas não é um programa que se replica (Letra A).



Bot e Botnet

INCIDÊNCIA EM PROVA: ALTA



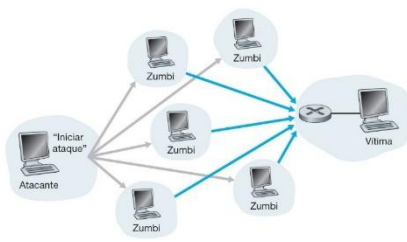
Bot é um programa que dispõe de mecanismos de comunicação com o invasor que permitem que ele seja controlado remotamente. Possui processo de infecção e propagação similar ao do Worm, ou seja, é capaz de se propagar automaticamente, explorando vulnerabilidades existentes em programas instalados em computadores. A comunicação entre o invasor e o computador infectado pode ocorrer via IRC, Servidor Web, Redes P2P, entre outros.

Ao se comunicar, o invasor pode enviar instruções para que ações maliciosas sejam executadas, como desferir ataques, furtar dados do computador infectado e enviar spam. Um computador infectado por um bot costuma ser chamado de zumbi, porque ele pode ser controlado remotamente e sem o conhecimento do seu dono. É chamado de Zumbi de Spam quando o bot instalado o transforma em um servidor de e-mails e o utiliza para o envio de spam.

*Diegão, não entendi muito bem! Galera, imagine que você está aí todo feliz no seu computador, mas ele possui um bot zumbi instalado. Sabe o que isso significa? Significa que alguém pode estar controlando à distância o bot presente no seu computador, podendo realizar diversas atividades maliciosas. **Em alguns casos específicos, o hacker nem quer destruir nada em seu computador, ele quer apenas utilizá-lo para enviar e-mails spam para outras pessoas.***

O ideal para proteger seus dados quando se detecta que ele está infectado por um bot é desconectar o computador da rede o mais rápido possível. **Já uma Botnet é uma rede formada por centenas ou milhares de computadores zumbis e que permitem potencializar as ações danosas executadas pelos bots.** Quanto mais zumbis participarem da Botnet, mais potente serão as ações danosas. Compreendido?





O atacante que a controlar - além de usá-la para seus próprios ataques - também pode alugá-la para outras pessoas ou grupos que desejem que uma ação maliciosa específica seja executada. As ações maliciosas mais comuns são: ataques de negação de serviço; propagação de códigos maliciosos (inclusive do próprio Bot); coleta de informações de outros computadores; envio de spam; camuflagem da identidade de hackers; etc.

O esquema simplificado apresentado a seguir exemplifica o funcionamento básico de uma botnet (rede de bots):

1. Um atacante propaga um tipo específico de bot na esperança de infectar e conseguir a maior quantidade possível de zumbis;
2. Os zumbis ficam então à disposição do atacante, agora seu controlador, à espera dos comandos a serem executados;
3. Quando o controlador deseja que uma ação seja realizada, ele envia aos zumbis os comandos a serem executados, usando, por exemplo, redes do tipo P2P ou servidores centralizados;
4. Os zumbis executam então os comandos recebidos, durante o período predeterminado pelo controlador;
5. Quando a ação se encerra, os zumbis voltam a ficar à espera dos próximos comandos a serem executados.

Em suma: Bot é um programa que possui mecanismos de replicação, infecção e ações maliciosas similares aos de um worm, entretanto dispõe de mecanismos de comunicação que permitem que ele seja controlado remotamente. É utilizado para realizar ações repetitivas, se fazendo passar por um ser humano, em que a máquina infectada passa a ser chamada de zumbi e sem o conhecimento do usuário pode ser utilizada para ações maliciosas.



BOT = DIMINUTIVO DE ROBOT = ROBÔ; NET = REDE;
BOT = ROBÔ; BOTNET = REDE DE ROBÔS

(CEBRASPE / Polícia Federal - 2014) Computadores infectados por botnets podem ser controlados remotamente bem como podem atacar outros computadores sem que os usuários percebam.

Comentários: computadores infectados por bots que formam botnets realmente podem ser controlados remotamente como podem atacar outros computadores sem serem notados (Correto).



Trojan Horse

INCIDÊNCIA EM PROVA: ALTA



O Trojan é um software malicioso que age por meio da utilização do princípio do Cavalo de Troia.

Quem se lembra dessa história? Os gregos queriam invadir a cidade de Troia, no entanto essa cidade era cercada por uma grande muralha. Como a invasão de uma cidade fortificada era bastante complexa, os gregos tiveram a ideia de dar um presente aos troianos. *O que era, Diego?* Era uma grande estátua de madeira no formato de um cavalo, mas tinha uma particularidade...

Dentro do cavalo de madeira estavam diversos soldados gregos. Os troianos acharam que os gregos estavam sendo corteses, aceitaram o presente e levaram o cavalo para dentro da cidade fortificada. À noite, os soldados gregos que estavam escondidos dentro do cavalo saíram, dominaram os sentinelas e possibilitaram a entrada do exército grego, levando a cidade à ruína. **Resumo da história: muito cuidado com os “presentes de grego” que vocês aceitam!**

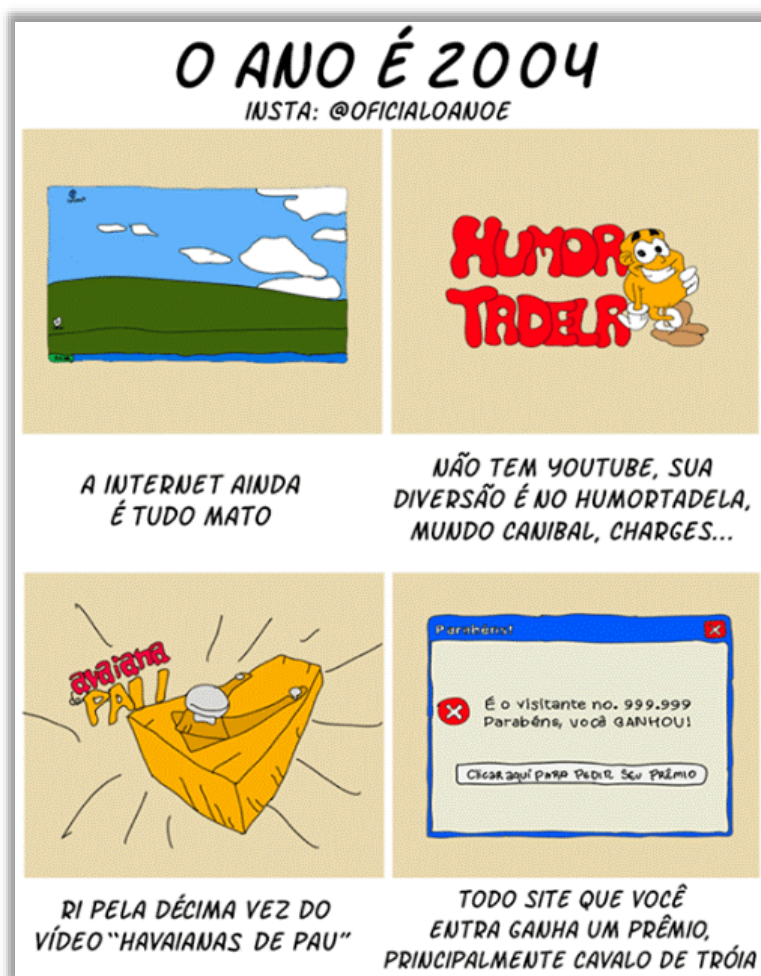
O Trojan Horse - também chamado de Cavalo de Troia - é um programa que, além de executar as funções para as quais foi aparentemente projetado, também executa outras funções, normalmente maliciosas, e sem o conhecimento do usuário. Ele é enviado se fazendo passar por um aplicativo útil, mas é capaz de abrir portas de comunicação de um computador para que a máquina possa ser invadida ou monitorada através da Internet.

Em outras palavras, eles podem ser instalados por atacantes que - após invadirem um computador - alteram programas já existentes para que, além de continuarem a desempenhar as funções originais, também executem ações maliciosas. Exemplos de trojans são programas que você recebe ou obtém de sites na Internet e que parecem ser apenas cartões virtuais animados, álbuns de fotos, jogos e protetores de tela, entre outros.

Estes programas, geralmente, consistem em um único arquivo e necessitam ser explicitamente executados para que sejam instalados no computador - ao contrário dos vírus, ele não se replica



automaticamente. O Cavalo de Troia trabalha com um modo de infecção que envolve despertar a curiosidade do usuário para que este o execute e, assim, possa infectar e comprometer o sistema. Galera, a variedade de atividade maliciosa que um Trojan pode fazer é inacreditável...



Professor, o que eu tenho que fazer para evitar que um Trojan seja instalado no meu computador? Pois é! Quem é mais velho como eu (36 anos) se identificará com a imagem anterior.

Você acessava um site e, não mais que de repente, aparecia um pop-up na tela informando que você havia ganhado um prêmio. Para buscá-lo, bastava clicar no botão apresentado. Esse era o momento em que você fazia o download de um trojan capaz de comprometer a segurança do seu computador. Então prestem bastante atenção em tudo que vocês baixam na internet, em especial aqueles arquivos recebidos por e-mail e não baixem softwares piratas!

Galera... algumas bancas (em especial, CESPE³) consideram o cavalo de troia como um tipo de vírus, podendo ser instalados por outros vírus ou programas – além de poder infectar o ambiente por meio de links durante a navegação ou até mesmo por meio de phishing. *Não adianta brigar com a banca, ok?*
Bem... como prova de que se trata de um malware extremamente versátil, existem vários tipos de trojans, classificados de acordo com as ações maliciosas que costumam executar.

³ Atenção: em 2024, tivemos uma questão afirmando que Cavalo de Troia era um tipo de vírus. O gabarito preliminar foi verdadeiro, mas o gabarito definitivo foi falso, com a seguinte justificativa: "Cavalo de Troia é um tipo de malware que pode conter ou não um vírus". Então, agora não sabemos que essa banca manterá esse último entendimento como jurisprudência ou não.



TIPO DE TROJAN	DESCRIÇÃO
TROJAN DOWNLOADER	Instala outros códigos maliciosos, obtidos de sites na Internet.
TROJAN DROPPER	Instala outros códigos maliciosos, embutidos no próprio código do trojan.
TROJAN BACKDOOR	Inclui backdoors, possibilitando o acesso remoto do atacante ao computador.
TROJAN DOS	Instala ferramentas de negação de serviço e as utiliza para desferir ataques.
TROJAN DESTRUTIVO	Altera ou apaga arquivos e diretórios, formata o disco rígido e pode deixar o computador fora de operação.
TROJAN CLICKER	Redireciona a navegação do usuário para sites específicos, com o objetivo de aumentar a quantidade de acessos a estes sites ou apresentar propagandas.
TROJAN PROXY	Instala um servidor de proxy, possibilitando que o computador seja utilizado para navegação anônima e para envio de spam.
TROJAN SPY	Instala programas spyware e os utiliza para coletar informações sensíveis, como senhas e números de cartão de crédito, e enviá-las ao atacante.
TROJAN BANKER	Coleta dados bancários do usuário através da instalação spyware que são ativados quando sites de Internet Banking são acessados – similar ao Trojan Spy, mas com objetivos específicos.



TROJAN = TROIA; HORSE = CAVALO
TROJAN HORSE = CAVALO DE TROIA

(FCC / TRT/PE - 2018) Considere o texto abaixo:

Um grupo de especialistas em segurança encontrou um novo tipo de malware, que está se espalhando massivamente por meio do Facebook Messenger. Trata-se do Digmine, um malware que usa sistemas infectados para extrair a criptomoeda Monero. Esse malware é enviado às vítimas como um link para um arquivo de vídeo, quando na verdade é um script executável que afeta as versões desktop e web do Facebook Messenger, usando o navegador Google Chrome para minerar a moeda Monero no computador.

(Adaptado de: <https://guiadobitcoin.com.br/>)

Esse tipo de malware, que parece ser uma coisa (vídeo), mas na realidade é outra (script de mineração), é categorizado como:

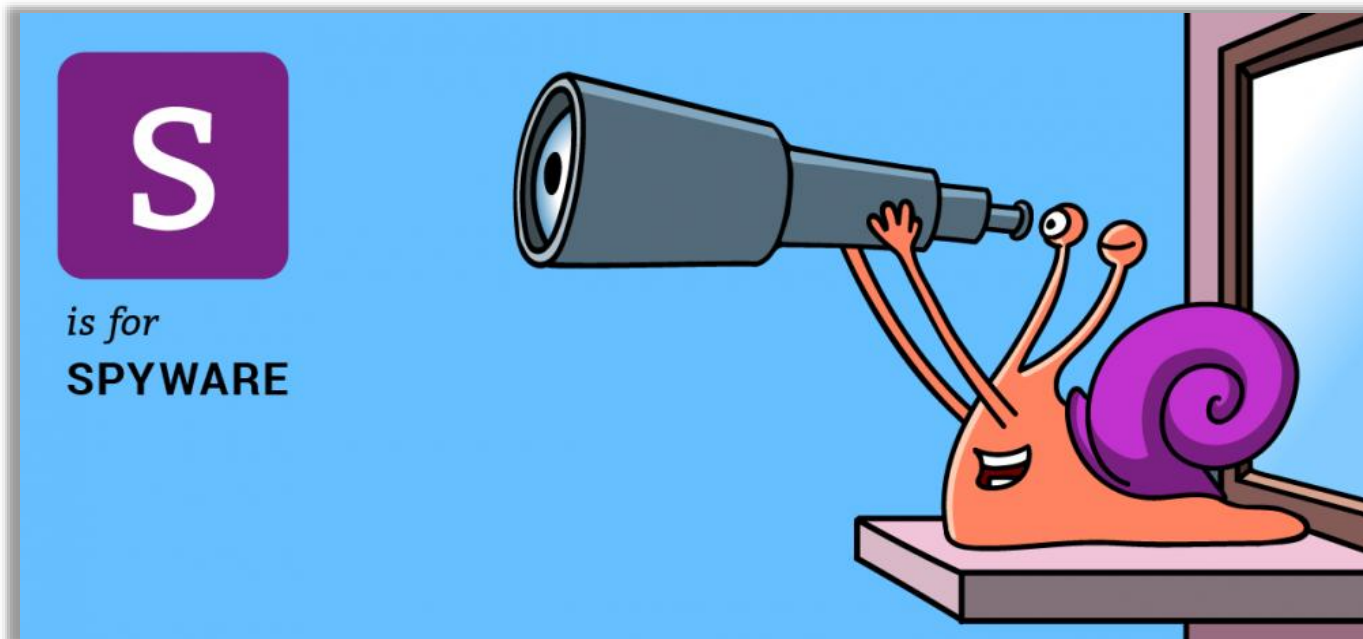
- a) trojan.
- b) backdoor.
- c) adware.
- d) rootkit.
- e) ransomware.

Comentários: (a) Correto. *Trojan* (ou cavalo de troia) é um tipo de malware que se disfarça como algo inofensivo (como um vídeo), mas executa ações maliciosas ao ser ativado, como mineração de criptomoedas; (b) Errado. *Backdoor* é um tipo de malware que cria portas de acesso remoto ao sistema, mas não necessariamente se disfarça ou visa mineração; (c) Errado. *Adware* exibe propagandas indesejadas e não está relacionado a disfarces ou mineração de criptomoedas; (d) Errado. *Rootkit* busca esconder a presença de outros malwares no sistema, geralmente com acesso privilegiado, mas não tem como principal característica o disfarce; (e) Errado. *Ransomware* sequestra dados do usuário exigindo resgate, diferente do comportamento de mineração descrito no enunciado (Letra A).



Spyware

INCIDÊNCIA EM PROVA: ALTÍSSIMA



Um spyware é um software espião, capaz de violar a privacidade das informações de usuários, coletando dados da máquina ou da rede e disponibilizando-as a terceiros. Pode ser usado tanto de forma legítima quanto maliciosa, dependendo de como é instalado, das ações realizadas, do tipo de informação monitorada e do uso que é feito por quem recebe as informações coletadas. Pode ser considerado de uso:

- **Legítimo:** quando instalado em um computador pessoal, pelo próprio dono ou com consentimento deste, com o objetivo de verificar se outras pessoas o estão utilizando de modo abusivo ou não autorizado.
- **Malicioso:** quando executa ações que podem comprometer a privacidade do usuário e a segurança do computador, como monitorar e capturar informações referentes à navegação do usuário ou inseridas em outros programas (por exemplo, conta de usuário e senha).

Como esse é um dos malwares que mais cai em prova, eu resolvi fazer uma **consolidação das principais definições encontradas em prova.** Dessa forma, pode-se dizer que um *Spyware* é:

DEFINIÇÕES DE SPYWARE

Um programa automático de computador que recolhe informações sobre o usuário e as envia a uma entidade externa na Internet, sem o conhecimento/consentimento do usuário.

Um software malicioso que recolhe informações sobre o usuário do computador e as transmite para alguém externo, sem conhecimento do usuário.

Um programa espião que monitora as atividades de um sistema e envia as informações coletadas para os invasores/terceiros.

Uma praga virtual que se aloja em uma máquina e, quando em ação, produz uma falsa impressão de normalidade, obtendo dados importantes (Ex: senhas).

Um programa automático instalado em um computador, que têm como finalidade capturar informações sobre o usuário e transmiti-las externamente sem a sua prévia autorização.



Uma aplicação que recolhe automaticamente dados sobre atividades e hábitos de um usuário na internet e transmite essa informação a uma entidade externa.

Diferentemente dos vírus, os spywares precisam ser explicitamente executados pelo usuário para infectar⁴ uma máquina (a infecção de vírus é feita pela execução do arquivo hospedeiro). Ademais, para combatê-los, recomenda-se a utilização de um Anti-Spyware, que são softwares que se destinam a detectar e remover spywares. *Bacana?* Os tipos mais comuns de spywares são os keyloggers, screenloggers e adwares.

CoolWebSearch



SPY = ESPIÃO

SPYWARE = SOFTWARE ESPIÃO

(CEBRASPE / PC/ES - 2012) Ter receio de se fazer compras on-line ou de se acessar o sítio de um banco pela Internet justifica-se, atualmente, pela possibilidade de perda de privacidade causada por softwares maliciosos capazes de enviar dados privativos referentes a senhas de acesso a contas bancárias e números de cartão de crédito a outras máquinas conectadas remotamente na Internet.

Comentários: softwares maliciosos como *spywares* e *keyloggers* podem capturar dados sensíveis, como senhas e números de cartão, comprometendo a privacidade e segurança do usuário em transações on-line (Correto).

(VUNESP / TCE-SP - 2015) Dentre os tipos de malwares, o spyware se caracteriza por:

- a) capturar as teclas digitadas no computador infectado e enviar as informações para o invasor.
- b) explorar falhas do sistema operacional para controlar o computador infectado.
- c) permitir o acesso contínuo ao computador infectado.
- d) propagar-se automaticamente pela rede enviando cópias para outros computadores.
- e) monitorar as atividades de um sistema e enviar as informações coletadas para o invasor.

Comentários: (a) Errado. Essa é uma característica típica de *keyloggers*, que registram as teclas digitadas, embora alguns spywares possam incluí-los; (b) Errado. Explorar falhas do sistema é comum em *worms* ou *exploit kits*, não sendo a função principal do spyware; (c) Errado. Permitir acesso contínuo é característica de um *backdoor*, não de spyware; (d) Errado. A propagação automática pela rede é típica de *worms*, não de spywares; (e) Correto. *Spyware* monitora atividades do sistema (como navegação, cliques, uso de programas) e envia essas informações para terceiros, geralmente sem o conhecimento do usuário (Letra E).

⁴ Note que eu disse que é necessário que ele seja executado para infectar uma máquina e, não, para se propagar. Vírus se propagam inserindo cópias de si próprios em arquivos; Worms se propagam enviando cópias de si próprios automaticamente pela rede ou e-mail; e spywares não se propagam.



Backdoor

INCIDÊNCIA EM PROVA: ALTA



Backdoor (em português, Porta dos Fundos) é um programa que permite o retorno de um invasor a um computador comprometido, por meio da inclusão de serviços criados ou modificados para este fim. Pode ser incluído pela ação de outros códigos maliciosos, que tenham previamente infectado o computador, ou por atacantes, que exploram vulnerabilidades existentes nos programas instalados no computador para invadi-lo.

Após incluído, ele é utilizado para assegurar o acesso futuro ao computador comprometido, permitindo que ele seja acessado remotamente, **sem que haja necessidade de recorrer novamente aos métodos utilizados na realização da invasão ou infecção e, na maioria dos casos, sem que seja notado.** Há casos, inclusive, de Backdoors incluídos propositalmente por fabricantes de programas, sob alegação de necessidades administrativas. *Sinistro, não é?*

Esses casos constituem uma séria ameaça à segurança de um computador que contenha um destes programas instalados, pois - além de comprometerem a privacidade do usuário - também podem ser usados por invasores para acessarem remotamente computadores. **Em suma: esse software malicioso é capaz de abrir Portas TCP para que seja possível que um invasor acesse o computador remotamente.** Professor, qual é a diferença entre Backdoor e Bot? São muitas...



BACKDOORS	BOTS
São obtidos somente pela inserção por um invasor ou pela ação de outro código malicioso	Podem ser obtidos de diversas outras maneiras
São instalados via execução de outro código malicioso	São instalados pela sua execução explícita
Não são capazes de se propagar	São capazes de propagar
Buscam possibilitar o retorno do invasor a própria, mantendo-se escondidos	Possuem realizar ataques coordenados a máquinas de terceiros.





BACK = FUNDO; DOOR = PORTA
BACKDOOR = PORTA DOS FUNDOS

(FGV / COMPESA - 2018) Os códigos maliciosos fazem inúmeras vítimas e provocam os mais variados prejuízos. Quando esse código se instala na máquina da vítima para permitir conexões remotas, funcionando como um controle remoto, é classificado como:

- a) Adware.
- b) Spyware.
- c) Keylogger.
- d) Worm.
- e) Backdoor.

Comentários: (a) Errado. *Adware* exibe anúncios indesejados no sistema, mas não permite controle remoto do computador; (b) Errado. *Spyware* coleta informações do usuário sem autorização, mas não fornece acesso remoto ao sistema; (c) Errado. *Keylogger* registra teclas digitadas para capturar dados como senhas, mas não permite conexão remota; (d) Errado. *Worm* é um malware que se propaga automaticamente em redes, mas não tem como principal função o controle remoto; (e) Correto. *Backdoor* cria uma porta de acesso secreta no sistema, permitindo que invasores se conectem remotamente e controlem a máquina infectada (Letra E).

(FGV / IBGE - 2017) Curioso, um usuário baixou e instalou em seu computador um suposto jogo erótico que viu em um site desconhecido. O jogo era, na verdade, um software que passou a permitir remotamente o controle do computador do usuário. É possível concluir que esse comportamento é típico de um malware denominado:

- a) vírus
- b) keylogger
- c) adware
- d) worm
- e) backdoor

Comentários: (a) Errado. Vírus precisa de um programa hospedeiro e normalmente se propaga com intervenção do usuário, as não é focado em controle remoto; (b) Errado. Keylogger registra teclas digitadas, mas não necessariamente permite o controle remoto da máquina; (c) Errado. Adware exibe anúncios indesejados, mas não habilita controle remoto; (d) Errado. Worm se propaga automaticamente por redes, sem depender da instalação por curiosidade do usuário; (e) Correto. Backdoor é um malware que, muitas vezes disfarçado de programa legítimo, abre uma "porta dos fundos" no sistema para permitir acesso e controle remoto por terceiros (Letra E).



Rootkit

INCIDÊNCIA EM PROVA: MÉDIA



Rootkit é um conjunto de programas e técnicas que permite esconder e assegurar a presença de um invasor ou de outro código malicioso em um computador comprometido. Devido à sua complexidade, o ele é notoriamente difícil de ser detectado e removido, operando em níveis profundos do sistema operacional para evitar mecanismos de segurança. É muito importante ressaltar que o nome rootkit não indica que os programas e as técnicas que o compõem são usados para obter acesso privilegiado a um computador, mas – sim – para mantê-lo.

O conjunto de programas e técnicas fornecido pelos rootkits pode ser usado para:

- Remover evidências em arquivos de logs (arquivos de registro de ações de um sistema);
- Instalar códigos maliciosos (ex: *backdoors*), para assegurar acesso futuro à máquina infectada;
- Esconder atividades/informações (Ex: arquivos, diretórios, processos, chave de registro, etc);
- Mapear potenciais vulnerabilidades em outros computadores, através de varreduras na rede;
- Capturar informações da rede do computador pela interceptação de tráfego.

Rootkits inicialmente eram usados por atacantes que, após invadirem um computador, os instalavam para manter o acesso privilegiado, **sem precisar recorrer novamente aos métodos utilizados na invasão, e para esconder suas atividades do responsável e/ou dos usuários do computador**. Apesar de ainda serem bastante usados por atacantes, os rootkits atualmente têm sido também tem uma outra função.

Eles são utilizados e incorporados por outros códigos maliciosos para ficarem ocultos e não serem detectados pelo usuário e nem por mecanismos de proteção. **Galera, os rootkits são um dos tipos de malware mais sofisticados que existem atualmente**. Por anos, as soluções de segurança têm lutado contra a sua detecção e remoção, principalmente porque eles comprometem o sistema operacional. *Como é, professor?*

Sim, eles comprometem o sistema operacional em um nível tão profundo que podem camuflar sua presença tanto das soluções antimalware quanto do próprio sistema operacional. Ao contrário do malwares tradicionais, os *rootkits* introduzem uma falha fundamental nos computadores que infectam:



eles não comprometem arquivos ou pastas - em vez disso, eles alteram tudo o que o sistema operacional informa de acordo com as necessidades do criador.

Quando algum sistema operacional efetua um pedido de leitura de um arquivo, o rootkit intercepta os dados que são requisitados e faz uma filtragem dessa informação, deixando o sistema ler apenas arquivos não infectados. Dessa forma, ferramentas antimalware ficam impossibilitadas de encontrar o arquivo malicioso no computador. Galera, mesmo que você consiga remover o rootkit, o sistema operacional não volta a sua condição original porque já foi modificado.

Ao utilizar um rootkit, um criminoso tem privilégios totais de administrador para o seu computador e softwares, convenientemente acessando logs, monitorando sua atividade, roubando informações e arquivos privados, e mexendo em suas configurações. Sem você saber, todas as suas senhas e informações poderão ser roubadas. É interessante enfatizar também que ele geralmente é formado por um conjunto de arquivos executáveis.

Rootkits podem se instalar em diferentes níveis do sistema. Para cada nível, o rootkit se estabelece de uma forma diferente e requer, portanto, estratégias diferenciadas para ser detectado. À medida em que ficamos mais próximos do hardware, aumenta-se o poder de controle do atacante, assim como a complexidade de sua detecção. **Os principais modos de operação são em Modo Usuário (que se instala em aplicativos) e Modo Kernel⁵ (que se instala no núcleo do sistema operacional).**



Alunos sempre me perguntam no fórum qual é a diferença entre Rootkit e Backdoor. Eles realmente são bastante parecidos em relação à obtenção, instalação e propagação. No entanto, os rootkit são bem mais avançados e complexos - trata-se de um conjunto de funcionalidades maliciosas capaz de camuflar a presença do invasor, apagar evidências, remover logs e infectar o núcleo do sistema operacional, geralmente implicando a formatação da máquina do usuário.



ROOT = ADMINISTRADOR (LINUX)

ROOTKIT = KIT DO ADMINISTRADOR

(FCC / TRT-24 - 2017) *É um conjunto de programas e técnicas que permite esconder e assegurar a presença de um invasor ou de outro código malicioso em um computador comprometido. Pode ser usado para: remover evidências em arquivos de logs; instalar outros códigos maliciosos, como backdoors, para assegurar o acesso futuro ao computador infectado; esconder atividades e informações, como arquivos, diretórios, processos, chaves de registro, conexões de rede etc.; mapear potenciais vulnerabilidades em outros computadores, por meio de varreduras na rede; capturar informações da rede onde o computador comprometido está localizado, pela interceptação de tráfego; dentre outras possibilidades. No entanto, seu nome não indica que os programas e as técnicas que o compõem são usadas para obter acesso privilegiado a um computador, mas sim para manter o acesso privilegiado.*

(Disponível em: <http://cartilha.cert.br/malware/>)

⁵ Kernel é o núcleo do sistema operacional, a camada que liga os aplicativos ao hardware - é ele que controla a CPU, a memória, e os dispositivos de entrada e saída.



O texto descreve um tipo de ameaça à segurança das informações conhecido como:

- a) rootkit.
- b) engenharia social.
- c) wardriving.
- d) worm.
- e) bot.

Comentários: (a) Correto. Rootkit é um conjunto de ferramentas usado para manter acesso privilegiado a um sistema comprometido, ocultando a presença de invasores ou outros malwares e suas atividades; (b) Errado. Engenharia social refere-se à manipulação de pessoas para obter informações confidenciais, não envolve ocultação técnica dentro do sistema; (c) Errado. Wardriving é a prática de procurar redes Wi-Fi usando dispositivos móveis, geralmente com intenção de identificar redes vulneráveis; (d) Errado. Worm é um malware que se replica automaticamente, mas não é projetado para manter e ocultar acesso privilegiado; (e) Errado. Bot é um computador infectado que pode ser controlado remotamente como parte de uma botnet, mas não possui os mecanismos de ocultação descritos no texto (Letra A).

(IBFC / IDAM - 2019) *"A capacidade de se esconder permite que este tipo de malware permaneça no sistema da vítima por meses, às vezes até anos, deixando que um hacker use o computador para o que bem entender. Mesmo uma máquina que não contém informações valiosas, o que é pouco comum, pode ser útil para produzir bitcoins (moeda digital), enviar spam e participar de ataques DDoS."* Essa é uma definição do malware denominado:

- a) adware
- b) spyware
- c) keylogger
- d) rootkit

Comentários: a descrição refere-se a um malware que permanece oculto no sistema por longos períodos, permitindo controle remoto e execução de diversas atividades maliciosas sem ser detectado. Essas são características típicas de um *rootkit*, que visa manter o acesso privilegiado e ocultar sua presença (Correto).



Tabela Comparativa

RESUMO DE CÓDIGOS MALICIOSOS

	VÍRUS	WORM	BOT	TROJAN	SPYWARE	BACKDOOR	ROOTKIT
FORMA DE OBTENÇÃO							
RECEBIDO AUTOMATICAMENTE PELA REDE		X	X				
RECEBIDO POR E-MAIL	X	X	X	X	X		
BAIXADO DE SITES NA INTERNET	X	X	X	X	X		
COMPARTILHAMENTO DE ARQUIVOS	X	X	X	X	X		
USO DE MÍDIAS REMOVÍVEIS INFECTADAS	X	X	X	X	X		
REDES SOCIAIS	X	X	X	X	X		
MENSAGENS INSTANTÂNEAS	X	X	X	X	X		
INSERIDO POR UM INVASOR		X	X	X	X	X	X
AÇÃO DE OUTRO CÓDIGO MALICIOSO		X	X	X	X	X	X
FORMA DE INSTALAÇÃO							
EXECUÇÃO DE UM ARQUIVO INFECTADO	X						
EXECUÇÃO EXPLÍCITA DO CÓDIGO MALICIOSO		X	X	X	X		
VIA EXECUÇÃO DE OUTRO CÓDIGO MALICIOSO						X	X
EXPLORAÇÃO DE VULNERABILIDADES		X	X			X	X
FORMA DE PROPAGAÇÃO							
INSERE CÓPIA DE SI PRÓPRIO EM ARQUIVOS	X						
ENVIA CÓPIA DE SI PRÓPRIO AUTOMATICAMENTE PELA REDE		X	X				
ENVIA CÓPIA DE SI PRÓPRIO AUTOMATICAMENTE POR EMAIL		X	X				
NÃO SE PROPAGA				X	X	X	X
AÇÕES MALICIOSAS MAIS COMUNS							
ALTERA E/OU REMOVE ARQUIVOS	X			X			X
CONSUME GRANDE QUANTIDADE DE RECURSOS		X	X				
FURTA INFORMAÇÕES SENSÍVEIS			X	X	X		
INSTALA OUTROS CÓDIGOS MALICIOSOS		X	X	X			X
POSSIBILITA O RETORNO DO INVASOR						X	X
ENVIA SPAM E PHISHING			X				
DESFERE ATAQUES NA INTERNET		X	X				
PROCURA SE MANTER ESCONDIDO	X				X	X	X



Outros Malwares

Ransomware

INCIDÊNCIA EM PROVA: ALTÍSSIMA



Esse tem começado a cair com mais frequência recentemente em provas de concurso, mas é minha aposta nesses novos tempos de moedas digitais. O *Ransomware* é um tipo de código malicioso que torna inacessíveis os dados armazenados em um equipamento, geralmente utilizando criptografia, e que exige pagamento de um resgate (*ransom*, em inglês) para restabelecer o acesso ao usuário – trata-se de uma espécie de extorsão virtual.

Ele pode se propagar de diversas formas, embora as mais comuns sejam: através de correios eletrônicos com o código malicioso em anexo ou que induzam o usuário a seguir um link; ou explorando vulnerabilidades em sistemas operacionais comprometidos que não tenham recebido as devidas atualizações de segurança. Atualmente, existem dois tipos básicos da praga virtual *ransomware*:

- **Ransomware Locker:** impede que você acesse o equipamento infectado.
- **Ransomware Crypto:** impede que você acesse dados no equipamento infectado.

Esse segundo tipo utiliza criptografia para impedir que o usuário tenha acesso aos dados. Além de infectar o equipamento, ele também costuma buscar outros dispositivos conectados, locais ou em rede, e criptografá-los também. Para se proteger, recomenda-se manter o sistema operacional e os programas instalados com todas as atualizações aplicadas; ter um antivírus instalado; e ser cuidadoso ao clicar em links ou abrir arquivos.

Fazer backups regularmente também é essencial para proteger os seus dados, pois – se seu equipamento for infectado – a única garantia de que você conseguirá acessá-los novamente é possuir backups atualizados. **Em geral, o pagamento é feito utilizando moedas digitais (Ex: Bitcoin), de modo que se torne não-rastreável, e infelizmente não garante o restabelecimento do acesso aos dados.**



o bastidor

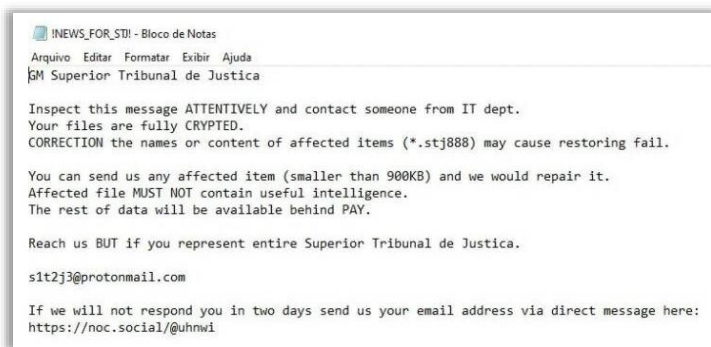
JUSTIÇA

Hacker cobra resgate de dados sequestrados do STJ

Técnicos do Superior Tribunal de Justiça acabam de encontrar – quinta, dia 5, na hora do almoço – um pedido de resgate dos dados sequestrados por um hacker na terça. O pedido, obtido pelo **Bastidor**, segue a linha comum a ataques dessa natureza, chamados de **ransomware**.

O STJ está refém de criminosos.

Atualização: quem aí ficou sabendo do ataque às bases de dados do Superior Tribunal de Justiça (STJ)? Pois é, trata-se de um ransomware (tomem cuidado com seus arquivos!)



Vejam o texto que os cybercriminosos enviaram com o pedido de resgate:

“Inspecionem esta mensagem atentamente e contacte alguém do Departamento de TI. Seus arquivos foram completamente criptografados (...). O restante dos dados estará disponível mediante pagamento. Entre em contato apenas se você representar totalmente o Superior Tribunal de Justiça: s1t2j3@protonmail.com”.

Um ransomware que ficou bastante famoso foi o WannaCry. Tratava-se de um ransomware com características de worm que, em maio de 2017, causou uma infecção global ao explorar uma vulnerabilidade no Windows (EternalBlue). Assim que infectava o computador, ele criptografava os arquivos do usuário e exigia pagamento em bitcoins para liberá-los. Sua capacidade de se propagar automaticamente em redes corporativas e governamentais fez com que atingisse rapidamente hospitais, empresas, bancos e órgãos públicos em mais de 150 países. O ataque evidenciou a importância de manter sistemas atualizados e realizar backups regulares como forma de prevenção.



RANSOM = RESGATE

RANSOMWARE = SOFTWARE DE RESGATE

(CEBRASPE / SERES/PE - 2017) Praga virtual que informa, por meio de mensagem, que o usuário está impossibilitado de acessar arquivos de determinado equipamento porque tais arquivos foram criptografados e somente poderão ser recuperados mediante pagamento de resgate denomina-se:

- a) ransomware.
- b) trojan.
- c) spyware.
- d) backdoor.
- e) vírus.

Comentários: (a) Correto. *Ransomware* é um tipo de malware que criptografa os arquivos da vítima e exige pagamento de resgate para a liberação do acesso, sendo amplamente usado em ataques recentes; (b) Errado. *Trojan* disfarça-se como software legítimo, mas não necessariamente criptografa arquivos ou exige resgate; (c) Errado. *Spyware* coleta informações do usuário de forma oculta, sem bloquear arquivos nem exigir pagamento; (d) Errado. *Backdoor* permite acesso remoto ao sistema, mas não realiza sequestro de dados; (e) Errado. *Vírus* infecta arquivos e pode causar danos diversos, mas não tem, por definição, o comportamento de sequestro e resgate (Letra A).



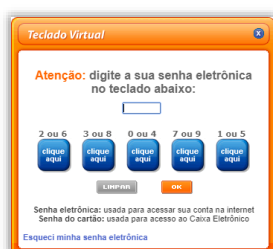
Keyloggers

INCIDÊNCIA EM PROVA: MÉDIA



Vocês se lembram que nós vimos os spywares? **Pois é, keylogger é um tipo de spyware capaz de capturar e armazenar as teclas digitadas pelo usuário no teclado do computador e enviá-las a um invasor.** Imaginem que tudo que vocês digitam no teclado é armazenado pelo software malicioso e enviado para o atacante, que pode eventualmente capturar senhas ou outras informações relevantes.

Criado inicialmente com a intenção de ser utilizado para auxiliar o suporte técnico e fiscalização, **ele adquire uma característica maliciosa quando é integrado a malwares e usado para coletar informações pessoais.** O uso ilícito tem o objetivo de coletar dados como nomes de usuário e senhas de contas de e-mail, sites de relacionamento, mensageiros instantâneos e qualquer outro serviço que precise de senha para se conectar, inclusive dados de acesso às contas bancárias.



Sua ativação, em muitos casos, é condicionada a uma ação prévia do usuário, como o acesso a um site específico de comércio eletrônico ou de Internet Banking. **Para aumentar a proteção dos seus clientes, alguns bancos online utilizam a tecnologia do teclado virtual, com recursos que reduzem a probabilidade de sucesso desses softwares.** A ideia é que caracteres não sejam digitados pelo teclado físico e, sim, clicados com o auxílio do mouse em um teclado virtual que aparece na tela do computador.



KEY = TECLA; LOGGER = REGISTRADOR

KEYLOGGER = REGISTRADOR DE TECLA

(FUNDEP / CAU-MG - 2019) Qual é o software malicioso criado para gravar informações digitadas por um determinado usuário no teclado de um computador, a fim de obter dados sigilosos?

- a) Keylogger
- b) Spam



- c) Firewall
- d) Scan

Comentários: (a) Correto. *Keylogger* é um tipo de malware projetado para registrar tudo o que o usuário digita no teclado, com objetivo de capturar dados sigilosos, como senhas e informações bancárias; (b) Errado. *Spam* refere-se ao envio de mensagens eletrônicas não solicitadas, geralmente com fins publicitários ou fraudulentos, mas não grava digitação; (c) Errado. *Firewall* é um mecanismo de segurança que controla o tráfego de rede, não sendo um software malicioso; (d) Errado. *Scan* é uma ação ou ferramenta de varredura usada para detectar vulnerabilidades ou dispositivos, mas não captura digitação (Letra A).

(CIEE / TRT-10 - 2019) "Programa que armazena todas as informações que um usuário digitou em um micro infectado por esse tipo de programa". A afirmativa se refere a:

- a) Adware.
- b) Spyware.
- c) Keylogger.
- d) Screenlogger.

Comentários: (a) Errado. *Adware* exibe anúncios publicitários indesejados, mas não registra o que o usuário digita; (b) Errado. *Spyware* coleta informações do sistema e do usuário, mas de forma mais ampla e não necessariamente por meio da captura de teclas; (c) Correto. *Keylogger* é especificamente projetado para registrar tudo o que é digitado no teclado, armazenando essas informações para possível uso malicioso; (d) Errado. *Screenlogger* captura imagens da tela (screenshots), não os dados digitados pelo usuário (Letra C).

(FCC / TRT-BA - 2013) Um site de segurança publicou uma notícia informando sobre um tipo de e-mail falso que vem atacando as redes sociais. Trata-se de um falso aviso de segurança informando que a conta será bloqueada caso não seja atualizada. Com aparência semelhante à do Facebook, este tipo de e-mail oferece um link para que a pessoa acesse uma página da rede social para iniciar o processo de atualização dos dados. Na verdade, o que ocorre ao clicar no link é a instalação de um spyware, capaz de capturar e armazenar as teclas digitadas pelo usuário no teclado do computador. O spyware capaz de realizar o que está sublinhado no texto, de acordo com a cartilha de segurança para internet do CERT.BR, é denominado:

- a) Adware.
- b) Keylogger.
- c) Rootkit.
- d) Bot.
- e) Trojan.

Comentários: (a) Errado. *Adware* é voltado à exibição de anúncios publicitários, não à captura de teclas digitadas; (b) Correto. *Keylogger* é o tipo de spyware que registra as teclas digitadas pelo usuário, permitindo capturar informações como senhas e dados pessoais; (c) Errado. *Rootkit* serve para ocultar a presença de outros malwares no sistema, mas não tem como função principal a captura de teclas; (d) Errado. *Bot* transforma o computador em parte de uma rede zumbi, podendo executar várias ações, mas não é especificamente focado na captura de digitação; (e) Errado. *Trojan* pode conter um *keylogger*, mas o nome específico para a função descrita é *keylogger*, conforme solicitado pela questão (Letra B).



Screenloggers

INCIDÊNCIA EM PROVA: MÉDIA



Trata-se também de um *spyware* - similar ao *keylogger* - capaz de armazenar a posição do cursor e a tela apresentada no monitor nos momentos em que o mouse é clicado, ou a região que circunda a posição onde o mouse é clicado. *Vocês se lembram que uma das soluções contra os keyloggers foi a utilização de teclados virtuais?* **Pois é, o screenlogger foi criado principalmente para capturar as teclas digitadas pelos usuários nesses teclados virtuais.**

Professor, como ele faz isso? **Ele permite capturar uma foto instantânea da tela (Print Screen) e assim observar uma sequência de cliques.** Ele era bastante utilizado por atacantes para capturar as teclas digitadas pelos usuários em teclados virtuais, disponíveis principalmente em sites de internet Banking. *Por que era utilizado?* Porque, hoje em dia, é mais raro utilizar teclados virtuais e porque atualmente há diversas maneiras de impedir esse tipo de praga virtual.



SCREEN = TELA; LOGGER = REGISTRADOR
SCREENLOGGER = REGISTRADOR DE TELA

(IESES / TRT-AM - 2017) Spyware é um programa projetado para monitorar as atividades de um sistema e enviar as informações coletadas para terceiros. Existem tipos específicos deste programa, como o que é capaz de armazenar a posição do cursor e a tela apresentada no monitor, nos momentos em que o mouse é clicado, ou a região que circunda a posição onde o mouse é clicado. Este tipo de spyware é denominado de:

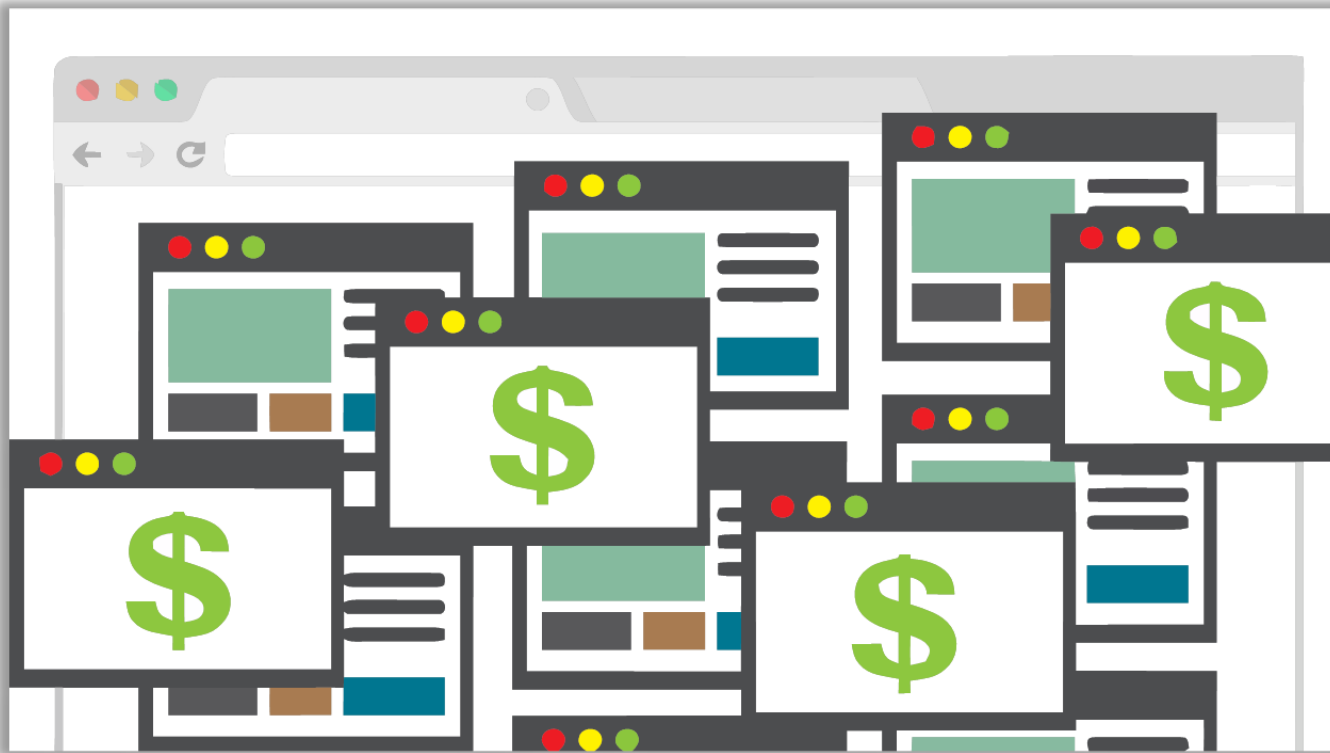
- a) KeyLogger
- b) Mouselogger
- c) Adware
- d) Screenlogger

Comentários: a descrição corresponde ao tipo de spyware que registra a posição do cursor e as telas exibidas no momento do clique do mouse. Esse comportamento é característico de um *screenlogger*, que captura imagens da tela ou regiões específicas com base na interação do usuário, como cliques (Letra D).

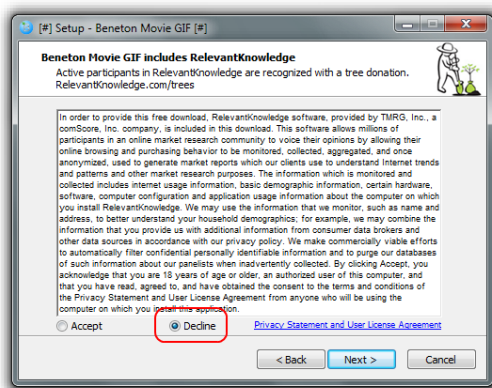


Adwares

INCIDÊNCIA EM PROVA: ALTA



Trata-se de um spyware projetado especificamente para apresentar propagandas. Pode ser usado para fins legítimos, quando incorporado a programas e serviços, como forma de patrocínio ou retorno financeiro para quem desenvolve programas livres ou presta serviços gratuitos. Também pode ser usado para fins maliciosos, quando as propagandas são direcionadas de acordo com a navegação do usuário sem que este saiba que tal monitoramento está sendo feito.



É um programa executado de forma automática e geralmente instalado sem o consentimento do usuário durante a instalação de outro software. É utilizado para divulgação de links publicitários, muitas vezes através de pop-ups.

Quem nunca fez download de um software, não prestou atenção nas instruções de instalação e acabou instalando algum outro software de propaganda que não gostaria de ter instalado? Prestem muita atenção na instalação, como na imagem ao lado!

Em suma: consiste em um programa projetado para exibir propagandas e anúncios normalmente sem a autorização do usuário, tornando o computador mais lento e a navegação mais incômoda. Geralmente vêm em formato de diversos pop-ups e notificações inseridas em outro programa (em geral, um navegador) e pode ser considerado um malware na hipótese de sua propaganda variar de acordo com hábitos de navegação do usuário.





AD (ADVERTISEMENT) = PROPAGANDA OU ANÚNCIO

ADWARE = SOFTWARE DE PROPAGANDA

(FCC / DETRAN-MA - 2018) Após acessar um website para o download de músicas da internet foi notado que o navegador internet passou a mostrar janelas pop-up com propagandas de forma infinita, ou seja, após o fechamento de uma janela, outra é apresentada em seguida de forma contínua. Esse efeito é característico do ataque do malware conhecido como:

- a) adware.
- b) spyware.
- c) botnet.
- d) worm.
- e) rootkit.

Comentários: (a) Correto. *Adware* é um tipo de malware que exibe propagandas de forma abusiva, frequentemente por meio e janelas pop-up, como descrito no enunciado; (b) Errado. *Spyware* coleta informações do usuário sem consentimento, mas não tem como foco principal a exibição de propagandas; (c) Errado. *Botnet* é uma rede de computadores infectados usados para ações coordenadas, como ataques DDoS, não relacionada diretamente a pop-ups; (d) Errado. *Worm* é um malware que se propaga automaticamente pela rede, sem gerar pop-ups publicitários; (e) Errado. *Rootkit* visa ocultar malwares e acessos indevidos, não tem como função principal a exibição de propagandas (Letra A).

(CEBRASPE / INPI - 2013) A principal atividade de programas com códigos maliciosos e que funcionam na função de keylogger é apresentar propagandas não solicitadas pelo usuário, direcionando-o a sítios maliciosos.

Comentários: Keyloggers não têm como principal função exibir propagandas. Eles são projetados para registrar as teclas digitadas pelo usuário, com o objetivo de capturar informações sigilosas como senhas e dados bancários. Exibir anúncios é característica de adware (Errado).



Sniffer

INCIDÊNCIA EM PROVA: BAIXA



Por padrão, computadores em uma mesma rede “farejam” e respondem somente pacotes endereçados a eles. **No entanto, é possível utilizar um analisador de pacotes de dados chamado *sniffer* capaz de monitorar, interceptar e registrar tráfego de dados em segmentos de rede de computadores.** Esse software pode ser utilizado de forma legítima ou pode ser utilizado de forma maliciosa. *Diego, você pode explicar melhor? Claro...*

Ele é utilizado de forma legítima por administradores de redes, para detectar problemas, analisar desempenho e monitorar atividades maliciosas relativas aos computadores ou redes por eles administrados. **Ele também pode ser utilizado por atacantes, para capturar informações sensíveis, como senhas, números de cartão de crédito e o conteúdo de arquivos confidenciais que estejam trafegando por meio de conexões inseguras, ou seja, sem criptografia.**

Nesse último caso, dizemos que ele está configurado em modo promíscuo. Notem que as informações capturadas por este software malicioso são armazenadas na forma como trafegam, ou seja, informações que trafegam criptografadas apenas serão úteis ao atacante se ele conseguir decodificá-las. Os hackers costumam colocar sniffers em locais que ofereçam redes wi-fi inseguras, como cafeterias, hotéis e aeroportos.

Um sniffer é programa que age monitorando o tráfego na rede, através da captura de pacotes de dados, em busca de informações sensíveis como o endereço dos sites acessados, senhas de acesso, e-mails, entre outros. No entanto, é bom enfatizar que eles não são necessariamente maliciosos (aliás, em regra eles são legítimos). Este tipo de software é usado com frequência para monitorar e analisar o tráfego de rede para detectar problemas e manter um fluxo eficiente.

Por outro lado, se utilizados de má-fé, eles podem capturar tudo o que passa por eles, inclusive senhas e nomes de usuários não criptografados. Além disso, um *sniffer* pode ser instalado em qualquer computador conectado a uma rede local. Ele não precisa ser instalado no próprio aparelho que se deseja monitorar. Em outras palavras, ele pode permanecer oculto durante a conexão em um outro computador conectado à rede local.

Professor, qual é a diferença entre sniffers e spywares? Eles são bem parecidos, mas há duas diferenças principais: em primeiro lugar, sniffers são comumente utilizados de forma legítima ou malicioso; spywares geralmente são maliciosos. Em segundo lugar, sniffers podem ser instalados em qualquer máquina conectada à rede local – eles não precisam estar instalados na máquina que desejam monitorar; spywares precisam estar instalados na máquina monitorada.





SNIFF = FAREJAR
SNIFFER = FAREJADOR

(CEBRASPE / TCE-SP - 2015) Os Sniffers, utilizados para monitorar o tráfego da rede por meio da interceptação de dados por ela transmitidos, não podem ser utilizados por empresas porque violam as políticas de segurança da informação.

Comentários: sniffers podem, sim, ser utilizados legalmente por empresas, desde que com fins autorizados, como monitoramento, auditoria ou diagnóstico de rede. O uso indevido é que configura violação de políticas de segurança (Errado).

(QUADRIX / CRF-PR - 2019) Os programas que são considerados como muito parecidos com os spywares e que têm como função principal interceptar e registrar dados trafegados na rede são os:

- a) hijackers
- b) vírus time bomb
- c) sniffers
- d) spams
- e) de engenharia social.

Comentários: (a) Errado. *Hijackers* alteram configurações do navegador, como a página inicial ou mecanismos de busca, mas não interceptam dados de rede; (b) Errado. *Vírus time bomb* ativam-se em datas ou condições específicas, não têm como função principal interceptar tráfego de rede; (c) Correto. *Sniffers* monitoram e capturam dados trafegados em redes, podendo registrar informações sensíveis, como senhas e dados pessoais, quando usados maliciosamente; (d) Errado. *Spams* são mensagens eletrônicas não solicitadas, geralmente de conteúdo publicitário ou fraudulento; (e) Errado. *Engenharia social* é uma técnica de manipulação humana para obtenção de informações, e não um programa de interceptação de rede (Letra C).

(MAKIYAMA / BANESTES - 2015) Um SNIFFER de rede é um programa que:

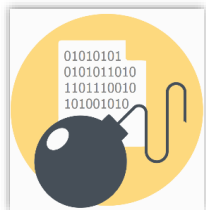
- a) Põe em risco as informações que trefegam em rede, pois captura pacotes desse ambiente.
- b) Não põe em risco as informações que trefegam em rede, pois protege os pacotes desse ambiente.
- c) Não põe em risco as informações que trefegam em rede, pois criptografa em IPSEC os pacotes desse ambiente.
- d) Põe em risco as informações que trefegam em rede, apesar de criptografar em HTTPS os pacotes desse ambiente.
- e) Não pode ser utilizado em protocolos TCP/IP.

Comentários: (a) Correto, ele pode pôr as informações em risco por capturar pacotes de dados; (b) Errado, ele compromete pacotes de dados; (c) Errado, ele não criptografa pacotes de dados; (d) Errado, ele não criptografa pacotes de dados; (e) Errado, ele pode - sim - ser utilizado com protocolos da arquitetura TCP/IP (Letra A).



Bombas Lógicas

INCIDÊNCIA EM PROVA: BAIXA



Trata-se de um software malicioso normalmente instalado por um usuário autorizado, como um administrador da rede, que o mantém no sistema deixando-o programado para causar danos (como excluir arquivos importantes) em um determinado evento, como - por exemplo - um código que monitora o sistema de pagamentos de uma empresa e deleta arquivos críticos para a organização caso um determinado funcionário seja demitido.

Imaginem um camarada que tenha sido demitido por qualquer que seja a razão e, insatisfeito, decide criar uma bomba lógica que apagará arquivos importantes caso ele seja excluído da base de dados da empresa (significando a sua demissão) - de forma que ninguém desconfie que ele foi o responsável pelos danos causados pelo software malicioso. **Esse é geralmente o tipo de situação em que esse malware aparece.**

Lembrando que uma bomba lógica pode ser configurada via disparo positivo ou negativo. Na forma positiva, a carga útil do malware ficará inativa até que um evento específico ocorra; na forma negativa, a carga útil do malware será ativada a não ser que um evento específico ocorra. *Professor, qual é a diferença do vírus Time Bomb para uma Bomba Lógica?* **A Bomba Lógica pode ser utilizada por outros tipos de malware; já o Vírus Time Bomb é apenas para vírus...**

(QUADRIX / CRQ-SP - 2011) O programador escreve uma parte do código e o insere secretamente no sistema operacional para utilizá-lo em represália a um possível afastamento involuntário do ambiente de trabalho. Dessa forma, a execução bem-sucedida do programa depende desse programador alimentá-lo diariamente, por meio de uma senha. O tipo de ataque descrito acima é conhecido por:

- a) alçapão.
- b) conexão impostora.
- c) transbordo do buffer.
- d) código móvel.
- e) bomba lógica.

Comentários: (a) Errado. Alçapão (trapdoor/backdoor) é um mecanismo de acesso oculto ao sistema, mas não depende de uma condição específica para ser acionado; (b) Errado. Conexão impostora refere-se à tentativa de se passar por entidade legítima em uma comunicação; (c) Errado. Transbordo de buffer explora falhas de memória para executar código malicioso; (d) Errado. Código móvel é aquele que pode ser transferido e executado em diferentes ambientes, como applets e scripts; (e) Correto. Bomba lógica é um código malicioso programado para ser executado quando determinada condição ocorre. No caso, a ausência da alimentação diária por senha aciona a ação planejada pelo programador (Letra E).

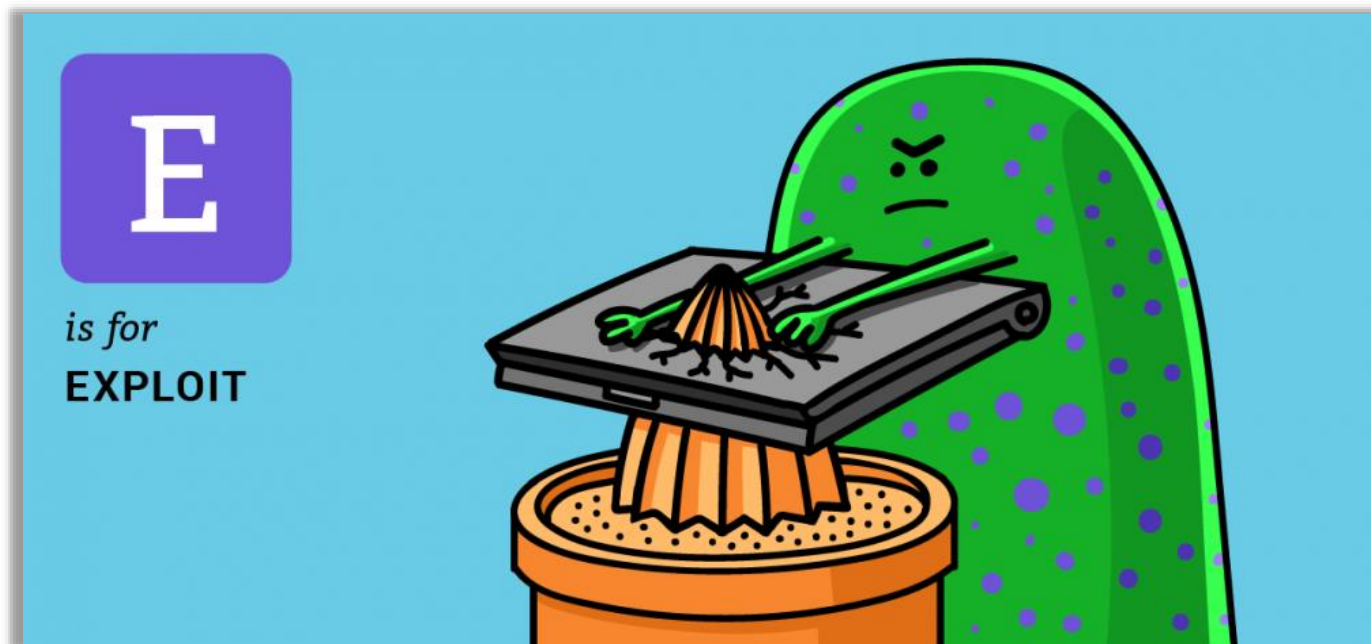
(QUADRIX / CRO-AC - 2019) A bomba lógica tem como característica principal enviar várias requisições de informação para um sistema de computação, com o objetivo de paralisá-lo.

Comentários: o envio massivo de requisições para sobrecarregar e paralisar um sistema é característica de ataque DoS (Denial of Service). *Bomba lógica* é um código que permanece inativo até ser acionado por uma condição específica, como data ou evento (Errado).



Exploits

INCIDÊNCIA EM PROVA: BAIXÍSSIMA



Trata-se de um software criado por hackers para permitir explorar vulnerabilidades ou brechas de segurança conhecidas de sistemas e assim permitir que atacantes possam praticar ações de invasões sem conhecimentos avançados. Eles geralmente causam instabilidade no sistema para diminuir temporariamente a sua segurança, passando então a executar ordens para roubar informações, invadir acessos bloqueados ou propagar vírus.

Outra coisa interessante é que eles podem explorar de vulnerabilidades zero-day. *Zero o que, Diego?* Zero-day! No contexto de segurança da informação, trata-se de uma vulnerabilidade desconhecida por administradores de um sistema que pode ser explorada por hackers. **O termo zero-day (ou dia zero) é o dia em que o administrador de um sistema descobre essa vulnerabilidade e começa a tomar ações para mitigá-la.**



EXPLOIT = EXPLORAR

EM NOSSO CONTEXTO, UTILIZAR ALGO TIRAR VANTAGENS

(COPEVE-UFAL / UFAL - 2016) Exploit é um software malicioso projetado para explorar uma vulnerabilidade existente em um software de computador.

Comentários: *exploit* é um código ou software desenvolvido para tirar proveito de vulnerabilidades em sistemas ou aplicativos, permitindo ações maliciosas como acesso não autorizado ou execução de código arbitrário (Correto).

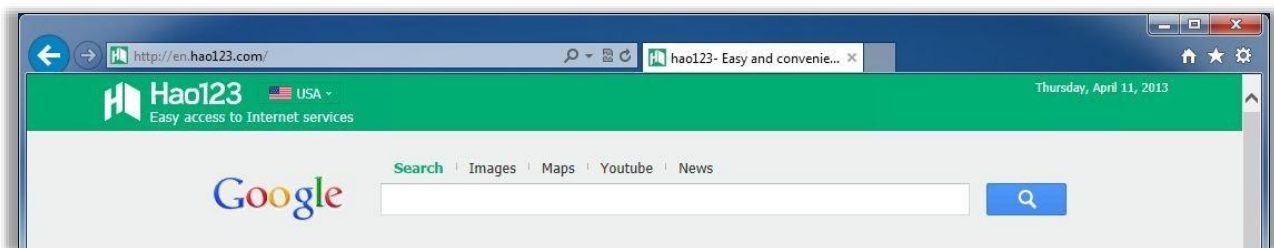


Hijacker

INCIDÊNCIA EM PROVA: MÉDIA



O Browser Hijacker é um software malicioso que modifica o registro do sistema operacional, alterando o funcionamento do navegador, modificando sua página inicial, abrindo páginas automaticamente ou inserindo botões inadvertidamente. Como muitos sites patrocinam o acesso a seu conteúdo, remunerando por cliques em links, o desenvolvedor do Hijacker costuma receber quantias financeiras sempre que estas páginas são abertas.



Essa praga virtual assume o controle do navegador e muda a forma como seu conteúdo é exibido quando você está navegando na web (em geral, modificando os registros do sistema operacional). Quem nunca instalou sem querer o HAO123? Gente, esse maldito malware se instala, bagunça seu navegador inteiro e é terrível para desinstalar (eu odeio essa @#&*@# desse software). Eu já tive que formatar meu computador várias vezes por conta de hijackers.



HIJACK = SEQUESTRAR

HIJACKER = SEQUESTRADOR

(FADESP / Prefeitura de Rurópolis-PA - 2019) Os programas que alteram a página inicial do navegador e também são capazes de redirecionar qualquer página visitada para outra, escolhida pelo criador da praga, são denominados de:



- a) sniffers.
- b) snappers.
- c) hijackers.
- d) screenloggers.

Comentários: (a) Errado. *Sniffers* monitoram o tráfego de rede, capturando dados transmitidos, mas não alteram configurações de navegador; (b) Errado. *Snappers* não são uma classificação reconhecida de malware relacionada à alteração de navegador; (c) Correto. *Hijackers* são malwares que alteram configurações do navegador, como a página inicial e redirecionamento de sites, sem o consentimento do usuário; (d) Errado. *Screenloggers* capturam imagens da tela do usuário, mas não interferem nas configurações de navegação (Letra C).

(IESES / TRE-MA - 2015) Alcebiades queria instalar um software em seu computador rapidamente para modificar umas fotos. Procurou na internet e achou um software freeware. Baixou e instalou, sem perceber que alguns softwares adicionais foram instalados também. Como a prioridade era a rapidez e não a segurança, ele pagou o preço. Sua página inicial do browser foi alterada, sua página de procura principal e redirecionamentos de páginas. Qual destas pragas virtuais ele instalou?

- a) Browser Hijacker.
- b) Trojans.
- c) Spyware.
- d) Worms.

Comentários: (a) Correto. *Browser Hijacker* é o tipo de praga virtual que altera configurações do navegador, como página inicial e motor de busca, além de redirecionar acessos para sites indesejados; (b) Errado. *Trojans* disfarçam-se como softwares legítimos para executar ações maliciosas, mas não são especificamente voltados à alteração de configurações de navegador; (c) Errado. *Spyware* monitora e coleta informações do usuário, mas não tem como foco principal o redirecionamento ou alteração do navegador; (d) Errado. *Worms* são malwares que se propagam automaticamente por redes, sem alterar especificamente o comportamento do navegador (Letra A).

(FCC / TRT-MA - 2014) Após a instalação de um programa obtido na internet, o navegador Internet Explorer utilizado por Luis apresenta uma página inicial diferente da configurada por ele, além de exibir pop-up indesejável. A partir dessas informações, pode-se concluir que o tipo de malware que atacou o computador do Luis é:

- a) Hijacker.
- b) Rootkit.
- c) Worm.
- d) Bootnet.
- e) Keylogger.

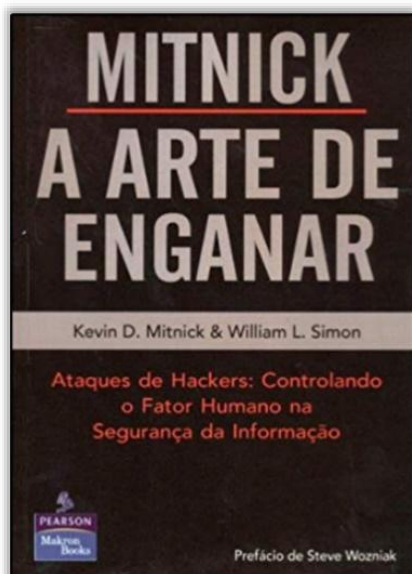
Comentários: (a) Correto. *Hijacker* é o malware responsável por alterar configurações do navegador, como a página inicial, e exibir pop-ups indesejáveis, exatamente como descrito no caso de Luis; (b) Errado. *Rootkit* oculta a presença de malwares e permite acesso privilegiado, mas não altera diretamente configurações do navegador; (c) Errado. *Worm* se propaga automaticamente por redes, mas não costuma afetar configurações de navegador; (d) Errado. *Bootnet* (correto: *botnet*) refere-se a uma rede de máquinas controladas remotamente, e não à alteração direta de páginas de navegador; (e) Errado. *Keylogger* registra as teclas digitadas, sem modificar a interface ou comportamento do navegador (Letra A).



Ataques e Golpes

Engenharia Social

INCIDÊNCIA EM PROVA: MÉDIA



Quando eu tinha uns 14 anos, eu já era fissurado com computadores e ficava encantado com todas as histórias de hackers que invadiam computadores, etc. À época, eu fiquei sabendo de um livro que contava a história do maior hacker de todos os tempos: Kevin Mitnick. **Eu comprei e fui logo ler a história desse cara que *hackeou* computadores e sistemas de diversas empresas de tecnologia e provedores de internet na década de noventa.**



Ele era tão ousado que - para mostrar como ele era competente - ele invadiu o computador pessoal de um dos maiores especialistas em segurança computacional do mundo: Tsutomu Shimomura. Esse cara evidentemente não deixou barato e, no ano seguinte, conseguiu capturá-lo e prendê-lo com a ajuda do FBI. Ele ficou cinco anos preso e depois mais três anos sem poder chegar perto de um computador, celular ou internet.

Essa história é contada no filme chamado Take Down (Caçada Virtual)! Eu - ávido por entender como esse hacker conseguiu fazer tudo isso - comprei o livro pensando que descobriria técnicas mirabolantes sobre como *hackear* computadores e sistemas. No entanto, em determinado momento do livro, Mitnick surpreende e diz:

Mitnick: *Vocês sabem qual é a melhor técnica para descobrir uma senha?*

E ele respondeu: *Perguntando!*



Galera, leiam o subtítulo do livro na página anterior. Ele diz: "*Ataques de Hackers: controlando o fator humano na Segurança da Informação*". É claro que existem técnicas para invadir sistemas, mas tantas outras envolvem mais o fator humano do que o fator computacional! **A Engenharia Social é uma técnica por meio da qual uma pessoa procura persuadir outra a executar determinadas ações por má-fé.** Trata-se de uma técnica utilizada por golpistas para tentar explorar a confiança, ingenuidade, ganância, vaidade ou boa-fé de outras pessoas, a fim de aplicar golpes, ludibriar ou obter informações sigilosas e importantes.

Ela é utilizada para obter informações importantes do usuário, através de sua ingenuidade ou da confiança. Quem está mal-intencionado geralmente utiliza telefone, e-mails ou salas de bate-papo para obter as informações que necessita. Por exemplo: algum desconhecido liga para a sua casa e se diz do suporte técnico do seu provedor de internet. Nessa ligação, ele te convence de que sua conexão está com problemas e pede sua senha para corrigir.

Duvide desse tipo de abordagem e contate o provedor caso algum técnico ligue para sua casa pedindo dados confidenciais a seu respeito (senhas, números de cartões, etc.) avisando-o do ocorrido. **Em suma: Engenharia Social é um conjunto de práticas utilizadas para obter acesso a informações importantes ou sigilosas em organizações/sistemas, através da persuasão e se aproveitando da ingenuidade ou confiança das pessoas.** Um exemplo comum é o *Phishing*.

(CEBRASPE / BB - 2013) Analise o diálogo apresentado a seguir.

- Sr. José, bom dia: Aqui fala o suporte técnico do seu provedor de Internet. O senhor está feliz com o nosso atendimento?
- Sim, bastante.
- Sr. José, constatamos uma ligeira redução na velocidade da sua conexão e por isso gostaríamos de confirmar alguns dados para poder estar melhorando o serviço que lhe prestamos. É possível?
- Pois não!
- O seu endereço é rua do Bastião, 37?
- Sim.
- O seu e-mail é jose.arrose@empresa.com.br?
- Sim.
- Muito obrigado, Sr. José, seus dados foram confirmados e podemos continuar nossa entrevista. O seu histórico de cliente bom pagador gerou um benefício. A sua velocidade de conexão será aumentada sem qualquer acréscimo na sua mensalidade. Bons clientes, melhores serviços. O senhor aceita esse prêmio por bom relacionamento?
- Sim.
- Sr. José, podemos fazer isso imediatamente, nossos recursos de acesso remoto incorporaram novas funcionalidades que permitem que eu mesmo, com um simples comando no meu computador, modifique a configuração do seu modem e troque essa velocidade. O senhor autoriza essa manobra? São 10 M em lugar do seus 2 M atuais.
- Sim.
- O senhor, então, pode ditar sua senha de acesso, por favor?
- 4 5 2 8 4 7 9 3.
- Muito obrigado, Sr. José. Aguarde uns 30 min e verifique como estarão mais rápidos os seus acessos. O seu provedor agradece.

Esse diálogo caracteriza um ataque à segurança da informação conhecido por:

- a) port scanner
- b) cavalo de troia
- c) spyware
- d) técnica de entrevista
- e) engenharia social

Comentários: (a) Errado. *Port scanner* é uma técnica usada para identificar portas abertas em um sistema, geralmente como parte de um reconhecimento técnico, e não envolve interação humana direta; (b) Errado. *Cavalo de troia* é um software malicioso disfarçado de programa legítimo, não se aplica a situações baseadas em engano verbal direto; (c) Errado. *Spyware* é um tipo de malware que coleta informações do sistema sem o conhecimento do usuário, diferente de uma conversa manipulativa; (d) Errado. "Técnica de entrevista" não é um conceito de segurança da informação relacionado a ataques sociais, e não descreve um tipo de ameaça; (e) Correto. *Engenharia social* é o uso de manipulação psicológica para enganar pessoas e levá-las a fornecer informações confidenciais, como senhas, como no caso descrito no diálogo (Letra E).



(CESGRANRIO / ANP - 2016) Uma hacker ameaçou divulgar na Web informações sigilosas de uma empresa após ter conseguido acesso a seus sistemas de informação. Para conseguir o acesso, ela telefonou para uma das secretárias da diretoria, passando-se por esposa de um dos diretores. Em seguida, ela disse à secretária que seu marido tinha sofrido um acidente e estava hospitalizado. Porém, antes de ficar inconsciente, o diretor lhe havia pedido que entrasse em contato com a empresa a fim de que uma de suas secretárias solicitasse a mudança do seu login e da sua senha, pois ele havia perdido sua agenda no acidente e temia que alguém pudesse invadir os sistemas da empresa, uma vez que esses dados, por descuido seu, estavam anotados na agenda perdida. Em seguida, a suposta esposa forneceu os novos login e senha à secretária.

Esse tipo de ataque para obtenção de informações é chamado de:

- a) informações livres
- b) engenharia social
- c) varredura de vulnerabilidades
- d) dumpster diving
- e) ataque físico

Comentários: (a) Errado. Informações Livres é uma técnica de análise de informações que podem ser obtidas livremente na internet sem a necessidade de ações intrusivas; (b) Correto. Engenharia Social é uma técnica de obtenção de informações explorando vulnerabilidades humanas e sociais dos funcionários de uma organização; (c) Errado. Varredura de Vulnerabilidades é uma técnica de envio de tipos de pacotes com o objetivo de obter informações relevantes para um ataque sobre um computador ou uma rede; (d) Errado. Dumpster Diving é uma técnica de vasculhar o lixo (sim, lixo mesmo) de empresas e pessoas com o objetivo de encontrar algo de valor; (e) Errado. Ataque Físico é basicamente o roubo de equipamentos ou dispositivos de armazenamento realizado diretamente em uma organização (Letra B).

(QUADRIX / CFO-DF - 2017) Não revelar informações confidenciais para outra pessoa, via telefone, sem confirmar sua legitimidade é uma das formas de evitar a engenharia social.

Comentários: a *engenharia social* explora a confiança humana para obter informações sigilosas. Confirmar a identidade de quem solicita dados antes de fornecê-los é uma prática essencial de segurança da informação (Correto).



Força Bruta

INCIDÊNCIA EM PROVA: BAIXA



Galera, deixa eu contar uma historinha para vocês! Era uma vez, um professor de informática que estava viajando para curtir as férias. No fim da viagem, antes de ir para o aeroporto, ele fechou sua mala e - bastante inteligente que é - trancou seus documentos dentro. Na hora do check-in, ele lembrou que os documentos estavam dentro da mala, mas esqueceu a maldita da senha desse cadeado embutido que vem em algumas malas. O *que ele teve que fazer?* Testar todas as possibilidades de combinação desses três números até descobrir a senha correta que abre a mala. **Esse é um exemplo de força bruta e eu sou um exemplo de professor mané** (sim, o professor sou eu!).

Um Ataque de Força Bruta (Brute Force) consiste em adivinhar, por tentativa e erro, um nome de usuário e senha e, assim, executar processos e acessar sites, computadores e serviços em nome e com os mesmos privilégios deste usuário. Qualquer computador, equipamento de rede ou serviço que seja acessível via Internet, com um nome de usuário e uma senha, pode ser alvo de um ataque de força bruta.

Mesmo que o atacante não consiga descobrir a sua senha, você pode ter problemas ao acessar a sua conta caso ela tenha sofrido um ataque de força bruta, pois muitos sistemas bloqueiam as contas quando há várias tentativas de acesso sem sucesso. **Apesar dos ataques de força bruta poderem ser realizados manualmente, em geral eles são realizados com o uso de ferramentas facilmente obtidas na Internet.** As tentativas de adivinhação são baseadas em:

- Dicionários de diferentes idiomas e que podem ser facilmente obtidos na Internet;
- Listas de palavras comumente usadas (Ex: personagens de filmes, nomes de times, etc);
- Substituições óbvias de caracteres, como trocar "a" por "@" e "o" por "0";
- Sequências numéricas e de teclado, como "123456", "qwert" e "1qaz2wsx";
- Informações pessoais (Ex: nome, sobrenome, datas e números de documentos).

Um ataque de força bruta, dependendo de como é realizado, pode resultar em um ataque de negação de serviço, devido à sobrecarga produzida pela grande quantidade de tentativas realizadas em um pequeno período de tempo. Vamos ver exatamente o que é um ataque de negação de serviço no próximo tópico, mas é basicamente um ataque massivo que resulta na interrupção de um serviço. *Bacana?*

(FGV / CODEBA - 2016) Um grupo de hackers chamado DarkSide tem como objetivo executar processos e acessar sites, computadores e serviços em nome e com os privilégios de um usuário da rede. Para isso, os integrantes do DarkSide tentam adivinhar, por tentativa e erro, um nome de usuário da rede e sua respectiva senha.

De acordo com a Cartilha de Segurança para Internet do Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil (cert.br), a técnica utilizada pelos integrantes da DarkSide é:

- a) varredura em redes, ou scan.
- b) interceptação de tráfego, ou sniffing.
- c) ataque de força bruta, ou brute force.
- d) falsificação de e-mail, ou e-mail spoofing.



e) negação de serviço, ou DoS (Denial of Service).

Comentários: (a) Errado. *Scan* ou varredura em redes é usado para identificar dispositivos e portas abertas, mas não tenta adivinhar credenciais; (b) Errado. *Sniffing* intercepta dados em trânsito na rede, mas não envolve tentativa e erro de senhas; (c) Correto. *Ataque de força bruta* consiste em testar sistematicamente várias combinações de usuário e senha até encontrar a correta, exatamente como descrito no enunciado; (d) Errado. *E-mail spoofing* envolve falsificação de remetente em mensagens de e-mail, sem relação com tentativas de login; (e) Errado. *DoS* visa indisponibilizar serviços por meio de sobrecarga, não é usado para obtenção de credenciais (Letra C).

(FUNDEP / Câmara de Ponte Nova-MG - 2018) A maioria dos computadores, tanto pessoais quanto corporativos, hoje em dia, trabalha conectada à internet. Por isso, eles se tornam vulneráveis a vários tipos de ataques. Um desses ataques consiste em adivinhar, por tentativa e erro, um nome de usuário e senha e, assim, executar processos e acessar sites, computadores e serviços em nome e com os mesmos privilégios desse usuário.

O ataque que contém essa técnica, conforme o <cert.br>, é chamado de:

- a) defacement.
- b) sniffing.
- c) força bruta.
- d) e-mail spoofing.

Comentários: (a) Errado. *Defacement* é o ataque que modifica a aparência de sites ou páginas da web, geralmente com objetivos de protesto ou vandalismo digital; (b) Errado. *Sniffing* é a interceptação de tráfego de rede para capturar dados, como senhas em texto claro, e não envolve tentativa e erro; (c) Correto. *Força bruta* é a técnica de adivinhação de credenciais por tentativa e erro, testando diversas combinações de usuário e senha até encontrar a correta; (d) Errado. *E-mail spoofing* é a falsificação do endereço do remetente em e-mails, usado geralmente para enganar usuários, mas não envolve adivinhação de senhas (Letra C).

(AOCP / UFBA - 2017) Um exemplo de ataque por força bruta (brute force) seria adivinhar, por tentativa e erro, um nome de usuário e senha, por exemplo, e, assim, executar processos e acessar sites, computadores e serviços em nome e com os mesmos privilégios desse usuário.

Comentários: o ataque por força bruta consiste em tentar várias combinações de nome de usuário e senha até encontrar a correta, permitindo acesso não autorizado com os privilégios do usuário alvo (Correto).



Denial of Service (DoS)

INCIDÊNCIA EM PROVA: MÉDIA



Negação de serviço (Denial of Service - DoS) é uma técnica pela qual um atacante busca retirar de operação um serviço, um computador ou uma rede conectada à Internet. Quando utilizada de forma coordenada e distribuída, ou seja, quando um conjunto de equipamentos é utilizado no ataque, recebe o nome de Ataque Distribuído de Negação de Serviço (*Distributed Denial of Service - DDoS*).

O objetivo destes ataques não é invadir nem coletar informações, mas - sim - exaurir recursos e causar indisponibilidades. Nesse caso, todas as pessoas que dependem do serviço são prejudicadas, visto que ficam impossibilitadas de acessar ou realizar as operações desejadas. Em geral, os alvos ficaram impedidos de oferecer serviços durante o ataque, mas voltam a operar normalmente ao final sem vazamento de informações ou comprometimento de sistemas.

Uma pessoa pode voluntariamente usar ferramentas e fazer com que seu computador seja utilizado em ataques. **No entanto, a grande maioria dos computadores participa dos ataques sem sequer ter conhecimento.** Por vezes, eu computador pode estar infectado (por exemplo, com Worms) ou fazendo parte de botnets. Ataques de negação de serviço podem ser realizados de diversas maneiras, tais como:

- Pelo envio de grande quantidade de requisições para um serviço, consumindo os recursos necessários ao seu funcionamento (processamento, número de conexões simultâneas, memória e espaço em disco, por exemplo) e impedindo que as requisições dos demais usuários sejam atendidas;
- Pela geração de grande tráfego de dados para uma rede, ocupando toda a banda disponível e tornando indisponível qualquer acesso a computadores ou serviços desta rede; ou pela exploração de vulnerabilidades existentes em programas, que podem fazer com que um determinado serviço fique inacessível.

(FCM / IF-MG - 2016) A respeito da segurança de redes, o ataque conhecido por tornar inacessíveis os serviços providos pela vítima e usuários legítimos, e normalmente nenhum tipo de informação é roubado ou alterado e nem é feito um acesso não autorizado à vítima é o:

- a) Sniffer.
- b) Wepattack.
- c) Man-in-the-middle.
- d) Endereçamento MAC.
- e) DoS (Denial of Service).

Comentários: (a) Errado. *Sniffer* é uma ferramenta usada para capturar e analisar pacotes de dados em trânsito, com foco em interceptar informações, não em indisponibilizar serviços; (b) Errado. *Wepattack* é uma ferramenta de ataque a redes Wi-Fi que usam WEP, mas não tem como objetivo tornar serviços indisponíveis; (c) Errado. *Man-in-the-middle* é um ataque que intercepta a comunicação entre duas partes para espionar ou modificar dados, diferente de causar indisponibilidade; (d) Errado.



Endereçamento MAC é uma técnica de identificação de dispositivos na rede, não um tipo de ataque; (e) Correto. *DoS (Denial of Service)* é um ataque que visa sobrecarregar recursos da vítima, tornando os serviços indisponíveis para usuários legítimos, sem necessariamente roubar ou modificar dados (Letra E).

(FCC / SEGEPI-MA - 2016) Um cracker passou a controlar diversos computadores remotamente após infectá-los com um tipo de programa malicioso chamado bot. Por meio desse programa, ele enviou instruções para desferir ataques maciços para tirar de operação serviços, computadores e redes conectadas à internet. Assim, conseguiu enviar grande quantidade de requisições para um serviço, tirando-o de operação. Conseguiu também gerar grande tráfego de dados para uma rede, ocupando toda a banda disponível, até conseguir sua queda. Esse tipo de ataque é conhecido como:

- a) Ping of Death.
- b) Sniffing.
- c) Spoofing.
- d) Defacement.
- e) DoS.

Comentários: (a) Errado. *Ping of Death* é um tipo específico e antigo de ataque DoS que envia pacotes ICMP malformados, mas não descreve o uso de bots em ataques coordenados; (b) Errado. *Sniffing* consiste em capturar pacotes de dados na rede para espionagem, e não causar indisponibilidade de serviços; (c) Errado. *Spoofing* envolve falsificação de identidade (como IP ou e-mail), não necessariamente ataques de sobrecarga; (d) Errado. *Defacement* é a modificação de sites ou páginas da web, com foco em vandalismo e não em negação de serviço; (e) Correto. *DoS (Denial of Service)*, e mais especificamente *DDoS (Distributed Denial of Service)*, é o ataque descrito: uso de múltiplos computadores infectados (bots) para sobrecarregar e derrubar serviços redes (Letra E).

(ESAF / FUNAI - 2016) Há ataques que consistem em sobrecarregar um servidor com uma quantidade excessiva de solicitações de serviços. Há muitas variantes desse tipo de ataque. Em uma delas o agressor invade muitos computadores e instala neles um software zumbi. Quando recebem a ordem para iniciar o ataque, os zumbis bombardeiam o servidor-alvo, tirando-o do ar. Esse tipo de ataque é conhecido como:

- a) NGSV.
- b) DDoS.
- c) ServBlock.
- d) Worm.
- e) Cavalo de Tróia.

Comentários: (a) Errado. *NGSV* não é um termo reconhecido ou padrão relacionado a ataques de negação de serviço; (b) Correto. *DDoS (Distributed Denial of Service)* é um ataque em que múltiplos computadores zumbis (infectados por bots) são controlados remotamente para sobrecarregar um servidor com solicitações simultâneas, causando sua queda; (c) Errado. *ServBlock* não é um termo técnico reconhecido na área de segurança da informação; (d) Errado. *Worm* é um tipo de malware que se propaga automaticamente por redes, mas não define por si só o ataque descrito; (e) Errado. *Cavalo de Tróia* é um malware que se disfarça como algo legítimo para enganar o usuário, não descreve o ataque coordenado de múltiplos sistemas (Letra B).

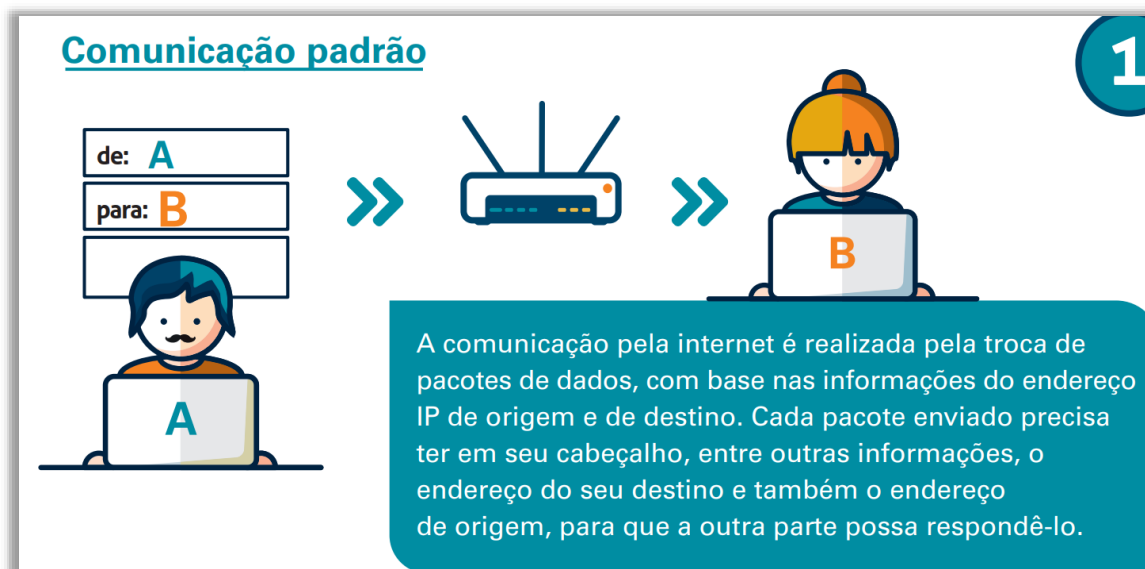


IP Spoofing

INCIDÊNCIA EM PROVA: BAIXA

O IP Spoofing (Falsificação/Mascaramento de IP) é uma técnica de invasão comumente empregada quando o mecanismo de autenticação de uma rede é baseado em endereços IP, isto é, quando a identificação de um usuário é realizada baseado em seu número de endereço IP. **Nesse caso, um atacante pode clonar o IP de um usuário legítimo, mascarando-se e fazendo-se passar pelo usuário autorizado, podendo ganhar acessos não autorizados na rede.**

COMUNICAÇÃO PADRÃO



TÉCNICA DE SPOOFING



(FGV / DPE-RJ - 2014) Muitos ataques utilizam uma técnica chamada IP spoofing, tanto individualmente para conseguir acesso a outros hosts bem como em conjunto com outras ferramentas de ataque. Basicamente, IP spoofing gera pacotes?

- a) para o endereço de broadcast da rede destino.
- b) com o endereço IP de origem forjado.
- c) para o endereço de destino de loopback.
- d) com cabeçalhos inválidos ou corrompidos.
- e) para endereços multicast.

Comentários: (a) Errado. Enviar pacotes para o endereço de *broadcast* pode ser usado em ataques, mas não caracteriza *IP spoofing*; (b) Correto. *IP spoofing* consiste em forjar o endereço IP de origem nos pacotes, fazendo parecer que eles vieram de outro host. Isso pode ser usado para enganar sistemas ou mascarar a identidade do atacante; (c) Errado. O endereço de *loopback* (127.0.0.1) é usado para testes locais e não está relacionado à técnica de *IP spoofing*; (d) Errado. Cabeçalhos inválidos ou corrompidos podem causar falhas, mas não fazem parte da definição de *IP spoofing*; (e) Errado. Pacotes enviados para endereços *multicast* fazem parte de comunicações em grupo, e não da técnica de falsificação de IP (Letra B).

(AOCP / EBSEH - 2015) Ataque que objetiva mascarar pacotes IP utilizando endereços de remetentes falsos. Esse tipo de ataque é definido como:

- a) Honeypot.
- b) IP Flooding.
- c) SYN Flooding.
- d) IP Spoofing.
- e) DNS Spoofing.

Comentários: (a) Errado. *Honeypot* é uma técnica defensiva que simula um sistema vulnerável para atrair e monitorar atacantes, não é um ataque em si; (b) Errado. *IP Flooding* refere-se a sobrecarga da rede com pacotes IP, mas não necessariamente com endereços falsificados; (c) Errado. *SYN Flooding* é um ataque que explora o protocolo TCP enviando múltiplos pacotes SYN para esgotar os recursos do servidor, sem mascaramento de IP; (d) Correto. *IP Spoofing* é o ataque em que pacotes são enviados com endereços IP de remetente falsificados, com o objetivo de mascarar a identidade do atacante ou enganar sistemas; (e) Errado. *DNS Spoofing* é a falsificação de respostas DNS para redirecionar tráfego, diferente da falsificação de endereços IP (Letra D).

(FUNCAB / FUNASG - 2015) Uma rede de computadores foi atacada com um vírus que cria endereços de rede falsos e permite que um usuário interno cause dano à rede sem ser descoberto com facilidade. Esse tipo de ameaça é denominado:

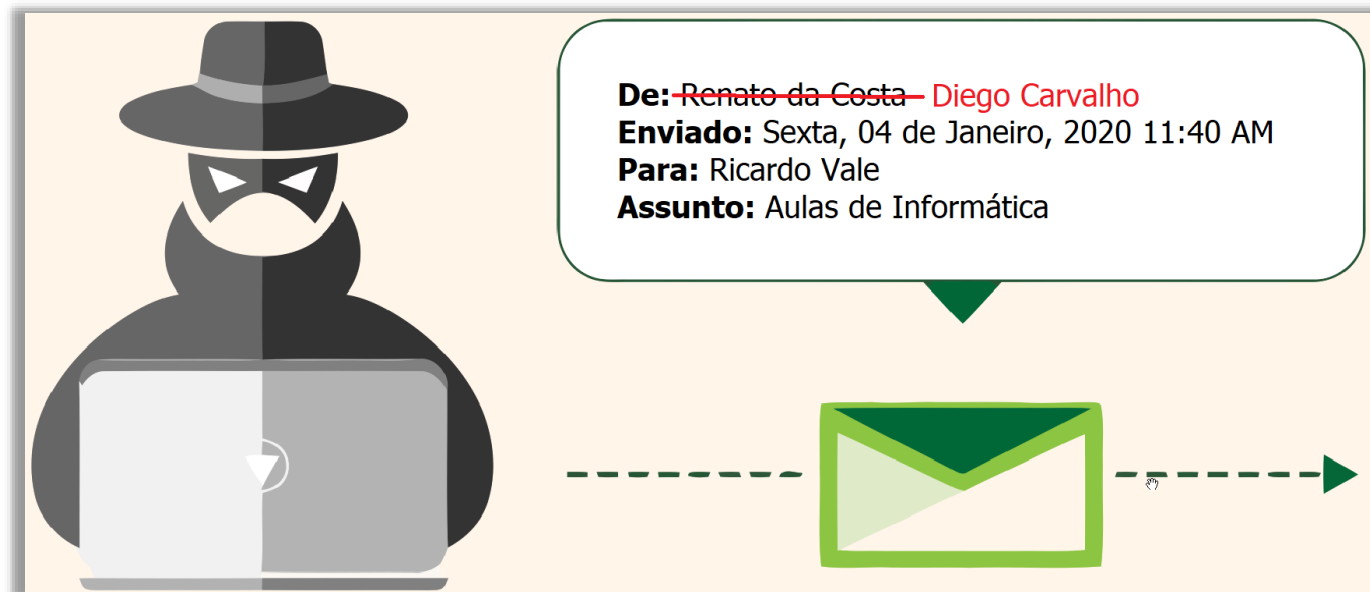
- a) combolist.
- b) bruteforce.
- c) keylogger.
- d) sniffer.
- e) spoofing.

Comentários: (a) Errado. *Combolist* refere-se a listas combinadas de logins e senhas utilizadas em ataques de preenchimento de credenciais (*credential stuffing*), e não à criação de endereços de rede falsos; (b) Errado. *Bruteforce* é um ataque que tenta adivinhar senhas por tentativa e erro, sem envolver falsificação de endereços de rede; (c) Errado. *Keylogger* registra teclas digitadas pelo usuário, mas não altera ou falsifica endereços de rede; (d) Errado. *Sniffer* captura pacotes de dados em trânsito na rede, mas não cria endereços falsos; (e) Correto. *Spoofing* é a técnica de falsificação de identidade, incluindo IP ou MAC, permitindo que o atacante se disfarce na rede, dificultando sua detecção (Letra E).



E-mail Spoofing

INCIDÊNCIA EM PROVA: ALTA



E-Mail Spoofing (Falsificação/Mascaramento de E-Mail) é uma técnica que consiste em alterar campos do cabeçalho de um e-mail, de forma a aparentar que ele foi enviado de uma determinada origem quando, na verdade, foi enviado de outra. Essa técnica é possível devido a características do protocolo SMTP (*Simple Mail Transfer Protocol*) que permitem que campos do cabeçalho sejam falsificados.

Ataques deste tipo são bastante usados para propagação de códigos maliciosos, envio de spam e em golpes de phishing. Atacantes utilizam-se de endereços de e-mail coletados de computadores infectados para enviar mensagens e tentar fazer com que os seus destinatários acreditem que elas partiram de pessoas conhecidas. Exemplos de e-mails com campos falsificados são aqueles recebidos como sendo:

- de alguém conhecido, solicitando que você clique em algum link ou que você execute algum arquivo em anexo;
- do seu banco, solicitando que você siga um link fornecido na própria mensagem e informe dados da sua conta bancária;
- do administrador do serviço de e-mail que você utiliza, solicitando informações pessoais e ameaçando bloquear a sua conta caso você não as envie.

Você também pode já ter observado situações em que o seu próprio endereço de e-mail foi indevidamente utilizado. Alguns indícios são, por exemplo, quando você recebe respostas de e-mails que você nunca enviou; quando recebe e-mails aparentemente enviados por você mesmo, sem que você tenha feito isto; ou quando recebe mensagens de devolução de e-mails que você nunca enviou, reportando erros como usuário desconhecido e caixa de entrada lotada.

Existem diversos tipos de Spoofing! Nós já estudamos o IP Spoofing e E-Mail Spoofing, existem também ARP Spoofing, MAC Spoofing, DNS Spoofing, entre outros.

(UFMT / Câmara de Boa Vista - 2014) A respeito de ataques na internet, pode-se afirmar que e-mail spoofing:



- a) é o termo usado para se referir aos e-mails não solicitados, que geralmente são enviados para um grande número de pessoas.
- b) é uma técnica que consiste em espionar os dados de emails trafegados em redes de computadores, por meio do uso de programas específicos chamados de sniffers.
- c) é uma técnica pela qual um atacante utiliza um computador para tirar de operação um serviço, um computador ou uma rede conectada à internet.
- d) é uma técnica que consiste em alterar campos do cabeçalho de um e-mail, de forma a aparentar que ele foi enviado de uma determinada origem quando, na verdade, foi enviado de outra.

Comentários: (a) Errado, o item trata de spam; (b) Errado, o item trata de sniffing; (c) Errado, o item trata de negação de serviço; (d) Correto, essa é a definição correta de e-mail spoofing (Letra D).

(AOCF / Câmara de Boa Vista - 2014) Qual é o nome da técnica que consiste em alterar campos do cabeçalho de um e-mail, de forma a aparentar que ele foi enviado de uma determinada origem quando na verdade, foi enviado de outra?

- a) Spoofing
- b) Sniffing
- c) Brute Force
- d) Defacement

Comentários: (a) Correto. *Spoofing*, especificamente *e-mail spoofing*, é a técnica que altera os campos do cabeçalho de um e-mail (como o remetente) para que ele pareça ter sido enviado por outra origem, sendo comum em golpes e phishing; (b) Errado. *Sniffing* é a interceptação de dados em trânsito na rede, não envolve modificação de cabeçalhos de e-mail; (c) Errado. *Brute Force* é a tentativa repetitiva de adivinhar senhas, sem relação com falsificação de remetente; (d) Errado. *Defacement* é o ataque que altera visualmente páginas de sites, não relacionado ao envio de e-mails (Letra A).



Phishing Scam

INCIDÊNCIA EM PROVA: ALTÍSSIMA



O Phishing Scam é uma fraude em que o golpista tenta enganar um usuário para obtenção de dados pessoais e financeiros que permitam a aplicação de um golpe, combinando técnicas computacionais e de engenharia social. Um exemplo de *phishing* é um e-mail que possa induzir o usuário a clicar em um link falso levando-o para uma página clonada ou para um arquivo malicioso. O *Phishing* ocorre por meio do envio de mensagens eletrônicas que:

- Tentam se passar pela comunicação oficial de uma instituição conhecida, como um banco, uma empresa ou um site popular; ou que procuram atrair a atenção do usuário, seja por curiosidade, por caridade ou pela possibilidade de obter alguma vantagem financeira;
- Informam que a não execução dos procedimentos descritos pode acarretar sérias consequências, como a inscrição em serviços de proteção de crédito e o cancelamento de um cadastro, de uma conta bancária ou de um cartão de crédito;
- Tentam induzir o usuário a fornecer dados pessoais e financeiros, por meio do acesso a páginas falsas, que tentam se passar pela página oficial da instituição; da instalação de malwares; e do preenchimento de formulários contidos na mensagem ou em páginas Web.

Para atrair a atenção do usuário, as mensagens apresentam diferentes tópicos e temas, normalmente explorando campanhas de publicidade, serviços, a imagem de pessoas e assuntos em destaque no momento. Galera, todos vocês já devem ter sido alvos de algum tipo de Phishing alguma vez na vida – eu mesmo vou mostrar alguns casos que aconteceram comigo. Por enquanto, vamos ver alguns exemplos de situações envolvendo esse golpe:

- **Páginas falsas de comércio eletrônico ou Internet Banking:** você recebe um e-mail em nome de um site de comércio eletrônico ou de uma instituição financeira, que tenta induzi-lo a clicar em um link. Ao fazer isto, você é direcionado para uma página falsa, semelhante ao site que você realmente deseja acessar, onde são solicitados dados pessoais e financeiros.



- **Páginas falsas de redes sociais ou de companhias aéreas:** você recebe uma mensagem contendo um link para o site da rede social ou da companhia aérea que você utiliza. Ao clicar, você é direcionado para uma página falsa em que são solicitados o seu nome de usuário e a sua senha que, ao serem fornecidos, serão enviados aos golpistas.
- **Mensagens contendo formulários:** você recebe uma mensagem contendo um formulário com campos para a digitação de dados pessoais e financeiros. A mensagem solicita que você preencha o formulário e apresenta um botão para confirmar o envio das informações. Ao preencher os campos e confirmar o envio, seus dados são transmitidos para os golpistas.
- **Mensagens contendo links para códigos maliciosos:** você recebe um e-mail que tenta induzi-lo a clicar em um link, para baixar e abrir/executar um arquivo. Ao clicar, é apresentada uma mensagem de erro ou uma janela pedindo que você salve o arquivo. Após salvo, quando você o abrir ou o executar, será instalado um código malicioso em seu computador.
- **Solicitação de recadastramento:** você recebe uma mensagem, supostamente enviada pelo grupo de suporte da instituição de ensino que frequenta ou da empresa em que trabalha, informando que o serviço de e-mail está passando por manutenção e que é necessário o recadastramento. Para isto, é preciso que você forneça dados como nome de usuário e senha.

Professor, estou assustado. Como eu faço para me prevenir de cair em golpes semelhantes a esses apresentados anteriormente? Vejamos as formas de prevenção:

PREVENÇÃO

Fique atento a mensagens recebidas em nome de alguma instituição que tentem induzi-lo a fornecer informações, instalar/executar programas ou clicar em links.

Questione-se por que instituições com as quais você não tem contato estão lhe enviando mensagens, como se houvesse alguma relação prévia entre vocês (Ex: se você não tem conta em um banco, não há por que recadastrar dados ou atualizar módulos de segurança).

Fique atento a mensagens que apelem demasiadamente pela sua atenção e que, de alguma forma, o ameacem caso você não execute os procedimentos descritos.

Não considere que uma mensagem é confiável com base na confiança que você deposita em seu remetente, pois ela pode ter sido enviada de contas invadidas, de perfis falsos ou pode ter sido forjada.

Seja cuidadoso ao acessar links – procure digitar o endereço diretamente no navegador web.

Verifique o link apresentado na mensagem. Golpistas costumam usar técnicas para ofuscar o link real para o *phishing*. Ao posicionar o mouse sobre o link, muitas vezes é possível ver o endereço real da página falsa ou código malicioso.

Utilize mecanismos de segurança, como programas *antimalware*, *firewall* pessoal e filtros *antiphishing*.

Verifique se a página utiliza conexão segura. Sites de comércio eletrônico ou Internet Banking confiáveis sempre utilizam conexões seguras quando dados sensíveis são solicitados.

Verifique as informações mostradas no certificado. Caso a página falsa utilize conexão segura, um novo certificado será apresentado e, possivelmente, o endereço mostrado no navegador web será diferente do endereço correspondente ao site verdadeiro.



Acesse a página da instituição que supostamente enviou a mensagem e procure por informações (você vai observar que não faz parte da política da maioria das empresas o envio de mensagens, de forma indiscriminada, para os seus usuários).

Galera, eu recebi um e-mail um dia desses do Bradesco! Eu achei estranho e fui ver o que era porque eu realmente tenho conta no Bradesco. Vejam só a imagem abaixo:



Notem que o título já é estranho, porque “você” está escrito com erro! Outra coisa importante de observar é o endereço do remetente: banco.bradesco@netmail2.bradesco.com.br. Galera, isso parece ser um e-mail real do Bradesco? Não, está esquisito! O banco não envia e-mails aos clientes sem autorização prévia. Eu entrei no site do banco e procurei pela seção de segurança. Logo, ficou claro que se tratava de uma tentativa de *phishing*...

Atualmente, as próprias instituições financeiras colocam em suas páginas web informações sobre como se proteger de e-mails falsos.



Vejam essa lista de recomendações extremamente útil da empresa Clavis - Segurança da Informação sobre golpes no período de COVID-19 (Novo Coronavírus):

Phishing

ENTENDA O QUE É ???

Phishing é o ato de tentar adquirir informações como nomes de usuário, senhas, detalhes do cartão de crédito e, às vezes, indiretamente, dinheiro fingindo ser uma entidade confiável em uma comunicação eletrônica

OS ATAQUES DE PHISHING PODEM RESULTAR NA EXPOSIÇÃO E PERDA DE INFORMAÇÕES CRÍTICAS QUE PODEM SER USADAS DE MANEIRA MALICIOSA E PREJUDICAR A REPUTAÇÃO DA VÍTIMA. ESTES SÃO RISCOS QUE EXIGEM INTERVENÇÕES DE CONSCIENTIZAÇÃO E EDUCAÇÃO

NÃO CAIA NA ISCA

Não clique em links contidos em e-mails, SMS, mensagens instantâneas ou postagens em mídias sociais vindos de pessoas ou organizações desconhecidas, que têm endereços suspeitos ou estranhos

NÃO DEIXE O COVID-19 ATACAR SUA ORGANIZAÇÃO

GOLPES DO CORONAVÍRUS
Dentre os ataques identificados utilizando o tema Corona Virus podemos destacar:

- 01** Netflix - Liberação de acesso grátis
- 02** Aplicativos rastreadores de doença pelo mundo
- 03** Álcool gel da Ambev. Registre-se
- 04** Kit gratuito com máscara e álcool gel dado pelo governo
- 05** Fabricação de vacina Covid-19
- 06** Agende teste do Coronavírus em casa

EM CASO DE DÚVIDAS OU PROBLEMAS NÃO CLIQUE E ENTRE EM CONTATO COM A EQUIPE DE SEGURANÇA DA INFORMAÇÃO / TI

CLAVIS
segurança da informação

(FUNCERN / Prefeitura de Jardim de Piranhas-RN - 2019) O nome da técnica de fraude online que é utilizada por criminosos, os quais utilizam armadilhas virtuais como e-mails falsos, websites ou, até mesmo, mensagens, para roubar senhas de banco e demais informações pessoais, usando-as de maneira fraudulenta, é o:

- a) Worm
- b) Keylogger
- c) Ransomware
- d) Phishing.

Comentários: (a) Errado. *Worm* é um malware que se propaga automaticamente em redes, mas não tem como foco a coleta de dados pessoais por meio de engano; (b) Errado. *Keylogger* registra tudo o que o usuário digita, mas não utiliza armadilhas como e-mails falsos ou websites fraudulentos; (c) Errado. *Ransomware* criptografa arquivos da vítima e exige pagamento de resgate, não é focado em roubo de informações via engano; (d) Correto. *Phishing* é a técnica de fraude que utiliza e-mails, sites ou mensagens falsas para enganar o usuário e obter informações sensíveis como senhas e dados bancários (Letra D).

(FCC / SEFAZ-BA - 2019) Um Auditor recebeu uma mensagem de e-mail, aparentemente de seu banco, com um link para verificar a existência de uma dívida de cartão de crédito não paga. Preocupado com a situação, clicou no link e forneceu os dados de seu cartão de crédito para pagar a suposta conta. Dias depois percebeu na fatura do seu cartão que foram feitas diversas compras online em sites de comércio eletrônico na Internet. A situação descrita permite concluir que esse Auditor foi vítima de:



- a) rot
- b) backdoor
- c) worm
- d) phishing
- e) ransomware

Comentários: (a) Errado. *Rot* não é um tipo reconhecido de malware ou ataque no contexto descrito; (b) Errado. *Backdoor* é um tipo de malware que permite acesso remoto ao sistema, mas não envolve enganar o usuário com mensagens falsas; (c) Errado. *Worm* é um malware autorreplicante que se propaga por redes, sem envolvimento direto de engenharia social; (d) Correto. *Phishing* é a técnica usada para enganar o usuário com e-mails falsos que imitam comunicações legítimas, como as de bancos, com o objetivo de obter dados confidenciais; (e) Errado. *Ransomware* sequestra dados do usuário por meio de criptografia e exige resgate, diferente do golpe descrito (Letra D).

(VUNESP / Prefeitura de Valinhos-SP - 2019) Frequentemente, os usuários de Correio Eletrônico recebem mensagens contendo frases como "atualize seus dados bancários" ou, então, "parabéns, você é o novo milionário", cujo objetivo é capturar informações como senhas de banco e demais informações pessoais para utilizá-las de maneira fraudulenta. Esse tipo de crime, que cresce em ritmo acelerado, é chamado:

- a) Accounting
- b) Backdoor
- c) Download
- d) Phishing
- e) Redirecting

Comentários: (a) Errado, esse conceito não existe no contexto de segurança da informação; (b) Errado, isso é um malware e, não, um crime; (c) Errado, esse é o processo de transferir dados geralmente de um servidor; (d) Correto, e-mails com informações falsas que induzem o usuário a clicar em links para capturar informações pessoais ou financeiras é típico de phishing; (e) Errado, esse é o processo de redirecionar um usuário de uma página para outra (Letra D).

Smishing

INCIDÊNCIA EM PROVA: BAIXA

Smishing pode até parecer uma palavra estranha, mas o golpe que ela representa é bem real – e, infelizmente, cada vez mais comum. O nome vem da junção de "SMS" com "phishing", e se refere a uma prática de enganar pessoas por meio de mensagens de texto no celular, com o objetivo de roubar dados pessoais, financeiros ou instalar vírus no aparelho.

Funciona assim: você recebe um SMS aparentemente legítimo, muitas vezes com o nome de um banco, operadora, loja ou até órgão público. A mensagem costuma ser alarmante ou tentadora – algo como "sua conta foi bloqueada", "você tem uma cobrança pendente" ou "parabéns, você ganhou um prêmio!". Junto com o texto, vem um link ou número de telefone.

Se a vítima clicar nesse link, pode ser redirecionada para um site falso, que imita perfeitamente o site da instituição verdadeira. Lá, o golpe acontece: o usuário é induzido a digitar informações pessoais como CPF, número do cartão, senhas ou códigos de verificação. Em outros casos, o link pode até iniciar o download automático de um malware, comprometendo o celular sem que a pessoa perceba.

Também existem casos em que o golpista pede que a pessoa responda o SMS com dados pessoais, como nome completo ou código de segurança. Tudo isso feito com base em uma falsa sensação de urgência – o que leva muita gente a agir por impulso. O smishing é perigoso porque chega direto no celular, um dispositivo que a gente costuma associar a segurança e privacidade. Além disso, o formato das mensagens e o uso de nomes reais de empresas fazem tudo parecer legítimo. Então, como se proteger?



- Não clique em links suspeitos recebidos por SMS, mesmo que a mensagem pareça confiável;
- Nunca forneça dados pessoais ou financeiros por mensagem de texto;
- Prefira sempre acessar sites digitando o endereço no navegador, e não por links recebidos;
- Desconfie de mensagens com tom de urgência, prêmios ou ameaças de bloqueio;
- Ative filtros de spam no seu celular e, se possível, use aplicativos de segurança;
- Quando estiver em dúvida, entre em contato com a empresa diretamente pelos canais oficiais.

(CEBRASPE / TJ-SE - 2023) Na área de segurança da informação, o termo smishing refere-se a vírus especificamente projetados para infectar smartphones com sistema operacional Android ou iOS e, com isso, prejudicar o uso do aparelho e roubar informações do usuário.

Comentários: o termo "smishing" não se refere especificamente a vírus projetados para infectar smartphones com sistemas operacionais Android ou iOS. Em vez disso, smishing é uma técnica de fraude que envolve o envio de mensagens de texto fraudulentas para enganar os destinatários e fazê-los revelar informações pessoais ou confidenciais. Embora possa, em alguns casos, levar à instalação de malware nos dispositivos das vítimas, o smishing em si não é um vírus, mas sim um método de engenharia social (Errado).

(CEBRASPE / TJ-SE - 2023) Uma técnica comum de smishing consiste em enviar para um telefone celular um SMS que contém um link clicável ou um número de telefone de retorno.

Comentários: uma técnica comum de smishing realmente envolve o envio de uma mensagem SMS para um telefone celular que contém um link clicável ou um número de telefone para o qual a vítima é incentivada a ligar. Neste tipo de ataque, o link geralmente direciona a vítima para um site fraudulento que imita uma entidade confiável (como um banco ou serviço governamental) e solicita informações sensíveis, como detalhes de login, números de cartão de crédito ou informações pessoais. Alternativamente, o número de telefone fornecido pode conectar a vítima a um golpista que se passa por um representante legítimo de uma organização para extrair diretamente essas informações (Correto).

Pharming

INCIDÊNCIA EM PROVA: ALTA

Para entender a mecânica de um ataque de Pharming e como eles são realizados, precisamos explorar como os servidores DNS (Domain Name System) funcionam. A tarefa do DNS é converter nomes de domínio em endereços IP, o que representa a localização real do site, permitindo que o navegador da Internet se conecte ao servidor em que o site está hospedado. **O método mais comum de executar esse ataque é por meio do envenenamento de cache.**

Quando você digita o endereço de um site, seu navegador cria um cache (memória rápida) de DNS para que você não precise retornar ao servidor toda vez que quiser visitar um site. O Pharming é um tipo de Phishing que "envenena" a tabela de cache do navegador web, corrompendo-o por meio da alteração de IPs e redirecionando o tráfego da Internet para sites fraudulentos para capturar informações e permitir a ação de golpistas⁶.

Neste caso, quando você tenta acessar um site legítimo, o seu navegador é redirecionado para uma página falsa de forma transparente, isto é, sem que você esteja ciente. Logo, você digita no navegador www.bb.com.br, por exemplo. No entanto, você é redirecionado para uma página cujo endereço é www.bb.net.br e sequer percebe. Galera, existem tipos diferentes de redirecionamento. Vejamos...

⁶ Há um tipo específico de Pharming chamado DNS Spoofing ou DNS Poisoning, que – em vez de envenenar a tabela de cache do Navegador – envenena o próprio Servidor DNS de um provedor de internet para atingir inúmeros usuários em larga escala.



TIPOS DE REDIRECIONAMENTO

Por meio do comprometimento do servidor de DNS do provedor que você utiliza;

Pela ação de códigos maliciosos projetados para alterar o comportamento do serviço de DNS do seu computador;

Pela ação direta de um invasor, que venha a ter acesso às configurações do serviço de DNS do seu computador ou modem de banda larga.

PREVENÇÃO

Desconfie se, ao digitar uma URL, for redirecionado para outro site, o qual tenta realizar alguma ação suspeita, como abrir um arquivo ou tentar instalar um programa;

Desconfie imediatamente caso o site de comércio eletrônico ou Internet Banking que você está acessando não utilize conexão segura. Sites confiáveis de comércio eletrônico e Internet Banking sempre usam conexões seguras quando dados pessoais e financeiros são solicitados;

Observe se o certificado apresentado corresponde ao do site verdadeiro.

Em suma: Pharming é um ataque que possui como estratégia corromper o DNS e direcionar o endereço de um sítio para um servidor diferente do original. É um tipo específico de Phishing que envolve o redirecionamento da navegação do usuário para sites falsos, por meio de alterações no serviço de DNS. Nesse caso, quando o usuário tenta acessar um site legítimo, o seu navegador web é redirecionado, de forma transparente, para uma página falsa.

(FAURGS / HCPA - 2016) Assinale a alternativa que apresenta um método utilizado como base para o ataque de segurança chamado de pharming:

- a) Envenenamento de cache de DNS.
- b) Negação de serviço distribuída.
- c) Código malicioso escondido em arquivos.
- d) Troca de endereços nos cabeçalhos IP das mensagens.
- e) Troca de portas nos cabeçalhos TCP das mensagens.

Comentários: (a) Correto. O *pharming* redireciona o acesso do usuário a sites falsos, mesmo quando o endereço digitado está correto. Isso é frequentemente feito por meio do *envenenamento de cache DNS*, que altera a resolução de nomes para redirecionar o tráfego a servidores maliciosos; (b) Errado. *Negação de serviço distribuída (DDoS)* visa indisponibilizar serviços, e não redirecionar acessos; (c) Errado. *Código malicioso escondido em arquivos* é técnica de infecção por malware, mas não está relacionada diretamente ao redirecionamento de tráfego típico do *pharming*; (d) Errado. *Troca de endereços nos cabeçalhos IP* pode estar relacionada a spoofing, mas não é a base do *pharming*; (e) Errado. *Troca de portas TCP* está relacionada a técnicas de evasão ou controle de tráfego, e não ao redirecionamento de sites falsos (Letra A).

(CEBRASPE / TJ-AC - 2012) Pharming é um ataque que possui como estratégia corromper o DNS e direcionar o endereço de um sítio para um servidor diferente do original.

Comentários: *Pharming* é um ataque que manipula a resolução de nomes de domínio, redirecionando o usuário para um site falso mesmo quando o endereço correto é digitado, geralmente por meio do comprometimento do DNS (Correto).

Vishing

INCIDÊNCIA EM PROVA: BAIXÍSSIMA



Você já ouviu falar em vishing? O nome pode parecer estranho à primeira vista, mas é bem fácil de entender: vem da junção de "voice" (voz) com "phishing". Em outras palavras, é um tipo de golpe feito por telefone, usando engenharia social para enganar a vítima e conseguir informações confidenciais, como senhas, dados bancários ou códigos de segurança.

Funciona assim: o criminoso liga para pessoa se passando por alguém de confiança – pode ser um funcionário do banco, técnico de suporte, atendente da operadora ou até um agente de segurança. A conversa é convincente e o golpista geralmente adota um tom de urgência, dizendo que há um problema na sua conta, uma compra suspeita ou algo que exige ação imediata.

Para dar mais credibilidade à farsa, eles podem usar uma técnica chamada spoofing, que falsifica o número de telefone, fazendo parecer que a ligação vem de uma instituição oficial. A vítima, ao ver um número "conhecido", tende a confiar e seguir as instruções – e é aí que mora o perigo.

Um exemplo típico: a pessoa recebe uma ligação dizendo que há uma movimentação estranha no cartão de crédito. O golpista então pede que a vítima confirme alguns dados, informe um código que chegou por SMS, ou até mesmo que faça uma transferência para a "verificação". Tudo com aparência de ajuda, mas com o real objetivo de aplicar um golpe.

Esse tipo de ataque funciona porque explora a confiança natural que muita gente ainda tem em atendimentos por telefone – especialmente quando a ligação vem acompanhada de preocupação, pressão e um discurso bem montado. Muitas vezes, o criminoso já tem informações básicas sobre a vítima (como nome, CPF ou número do banco), o que torna a fraude ainda mais convincente. Então, como se proteger do vishing?

- Nunca forneça senhas, códigos ou dados bancários por telefone, mesmo que a ligação pareça ser uma ligação oficial;
- Desconfie de chamadas inesperadas pedindo ações urgentes – principalmente nos casos de filhos e filhas;
- Desligue e ligue de volta para o canal oficial da empresa – de preferência, o número que está no site ou no cartão do banco;
- Compartilhe esse tipo de informação com outras pessoas. Muitas vítimas caem nesses golpes por falta de orientação.

(QUADRIX / CAU-AC - 2024) Vishing é uma técnica de engenharia social que faz uso de chamadas telefônicas para obter informações confidenciais, passando-se, muitas vezes, por uma entidade legítima.

Comentários: o Vishing (Voice Phishing) é uma técnica de engenharia social que utiliza chamadas telefônicas para enganar as vítimas, simulando a identidade de instituições confiáveis com o objetivo de obter dados sensíveis, como senhas ou informações bancárias (Correto).

Baiting

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

O nome vem do inglês bait, que significa "isca" – e é exatamente isso que esse tipo de ataque faz: joga uma isca, esperando que alguém morda. O baiting é um golpe baseado em engenharia social, ou seja, ele explora o comportamento humano – principalmente a curiosidade, a distração e, muitas vezes, a



ganância. Em vez de atacar diretamente um sistema, o atacante prepara uma armadilha e espera que a vítima, por vontade própria, dê o passo que compromete sua segurança.

Um exemplo clássico envolve pendrives deixados em locais públicos, como recepções, banheiros, elevadores ou estacionamentos. O dispositivo geralmente vem com uma etiqueta chamativa: "fotos pessoais", "confidencial", "folha de pagamento"... algo que desperte a curiosidade. Quando alguém pega o pen drive e o conecta no computador, achando que vai descobrir algo interessante, um malware é instalado automaticamente – e pronto: o sistema está comprometido.

Mas o baiting também acontece no mundo virtual. Sabe aqueles links tentadores em e-mails ou redes sociais oferecendo músicas grátis, filmes, cursos ou programas? Muitas vezes, é só uma fachada. Ao clicar, a pessoa pode ser redirecionada para um site falso que instala vírus ou pede informações pessoais, como senhas e dados bancários. O que torna esse tipo de ataque tão perigoso é justamente o fato de que ele não depende de falhas técnicas – ele se aproveita do comportamento humano. E, convenhamos, quem nunca clicou num link suspeito por impulso, né? Então, como se proteger?

- Desconfie de brindes, promessas e links "bons demais pra ser verdade";
- Nunca conecte dispositivos desconhecidos no computador – mesmo que pareçam inofensivos;
- Desative a execução automática de mídias removíveis no seu sistema;
- Mantenha antivírus e sistema operacional atualizados para ajudar a bloquear malwares.

E o mais importante: informe-se e eduque os outros ao seu redor. Muitas vezes, o conhecimento é a melhor defesa. No fim das contas, o baiting é como uma armadilha disfarçada de oportunidade. E o melhor jeito de não cair nela é manter a atenção e resistir à curiosidade ou ao impulso de aproveitar algo "de graça" sem pensar duas vezes.

(EDUCA / Prefeitura de Alhandra-PB - 2024) Engenharia social é uma técnica utilizada por hackers para explorar a confiança e a ingenuidade humana para obter informações confidenciais ou acesso a sistemas. Ao invés de atacar diretamente uma rede ou sistema, os hackers aproveitam-se da ingenuidade ou desconhecimento das vítimas, utilizando métodos persuasivos para enganá-las. São exemplos de ataques de engenharia social:

- a) Man-in-the-Middle, Baiting, e Vishing.
- b) Man-in-the-Middle, DDoS, e Vishing.
- c) Man-in-the-Middle, DDoS, e Ataque de Força Bruta.
- d) Phishing, DDoS, e Ataque de Força Bruta.
- e) Phishing, Baiting, e Vishing.

Comentários: (a) Errado. O ataque Man-in-the-Middle não é classificado como engenharia social, pois envolve interceptação técnica de comunicações. Baiting e Vishing, sim, são exemplos de engenharia social; (b) Errado. DDoS (negação de serviço) e Man-in-the-Middle são ataques técnicos, não dependem da manipulação psicológica da vítima, ao contrário do Vishing, que é engenharia social; (c) Errado. Nenhum dos itens citados (Man-in-the-Middle, DDoS e Força Bruta) envolve manipulação direta da vítima. Todos são ataques técnicos, não exemplos de engenharia social; (d) Errado. Apenas o Phishing é um exemplo de engenharia social. DDoS e Força Bruta são ataques técnicos, que não exploram o comportamento humano de forma direta; (e) Correto. Phishing (e-mail falso), Baiting (isca com recompensa) e Vishing (chamada telefônica falsa) são técnicas de engenharia social que exploram a confiança humana para obter informações (Letra E).

Whaling

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

Esse é um tipo de golpe digital que merece atenção especial – especialmente em ambientes corporativos. O nome vem de "whale", que em inglês significa "baleia", e representa aqueles "peixes grandes" dentro



de uma empresa: diretores, executivos, gerentes de alto escalão... ou seja, gente com poder de decisão e acesso a informações valiosas.

O whaling é uma variação mais sofisticada do phishing, mas, ao contrário dos ataques em massa que tentam enganar qualquer um, ele é altamente direcionado e personalizado. Os criminosos fazem a lição de casa: pesquisam o perfil da vítima, entendem sua rotina, seu cargo, os contatos com quem se comunica e até o jeito como escreve. Com essas informações, eles montam um e-mail ou mensagem que parece extremamente legítimo – pode ser algo vindo de um fornecedor, de um parceiro comercial ou até de outro executivo da empresa.

E qual é o objetivo? Roubar informações sigilosas ou causar prejuízo financeiro direto. Um exemplo comum é o envio de um e-mail falso em nome do CEO pedindo, com urgência, uma transferência bancária ou o envio de documentos confidenciais. Como a ordem parece vir “de cima”, muita gente cumpre sem questionar.

Esse golpe funciona tão bem porque explora a hierarquia e o senso de urgência. Afinal, quem é que vai desconfiar de um pedido vindo do chefe? E se for uma situação “urgente”, então... a chance de a vítima agir no impulso é ainda maior. Por isso, o whaling é considerado um dos ataques mais perigosos – uma única ação bem-sucedida pode comprometer dados estratégicos, causar perdas financeiras e abalar a reputação da empresa. Então, como se proteger?

- **Autenticação Multifator:** mais de um tipo de autenticação, especialmente para acessos sensíveis e aprovações de transações;
- **Treinamentos de Conscientização:** todos os colaboradores, principalmente os líderes, devem saber identificar sinais de golpe;
- **Verificação de Ordens Incomuns:** se surgir um pedido fora do padrão, confirme por outro canal (ligação, chamada de vídeo, entre outros);
- **Cultura de Segurança:** a cultura deve estar presente no dia a dia da empresa, do estagiário ao presidente.

(FUNDATEC / BRDE - 2023) Microsoft Azure defende que planejar-se antecipadamente contra ataques de phishing comuns, incluindo spear phishing, whaling, smishing e vishing é a melhor proteção. Sendo assim, o ataque de _____ é um método que criminosos virtuais usam para se disfarçar como se fossem participantes de alto escalão de uma organização e atingir diretamente outras pessoas importantes, visando roubar dinheiro e informações sigilosas ou obter acesso a seus sistemas de computadores para fins criminosos. Também conhecido como fraude do CEO, esse ataque usa métodos como a falsificação de e-mails e sites para enganar um alvo e fazê-lo realizar ações específicas, como revelar dados confidenciais ou transferir dinheiro. Assinale a alternativa que preenche corretamente a lacuna do trecho acima.

- a) phishing
- b) whaling
- c) smishing
- d) vishing
- e) spear phishing

Comentários: (a) Errado. Phishing é uma técnica genérica de engenharia social, geralmente em massa, sem foco específico em alvos de alto escalão de uma organização; (b) Correto. Whaling é uma forma de spear phishing direcionada a executivos ou



pessoas de alto escalão, simulando comunicações legítimas com o objetivo de obter informações sensíveis ou desviar dinheiro; (c) Errado. Smishing é uma forma de phishing via SMS e não se refere especificamente a ataques contra altos executivos; (d) Errado. Vishing é o phishing realizado por meio de chamadas telefônicas, sem foco exclusivo em alvos de alto nível hierárquico; (e) Errado. Spear phishing é um ataque direcionado, mas não necessariamente a pessoas de alto escalão como no whaling, que é uma forma mais específica desse tipo de ataque (Letra B).

Spear Phishing

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

Spear phishing é um tipo de ataque cibernético que, diferentemente do phishing tradicional, é altamente direcionado e personalizado. Enquanto o phishing comum envia mensagens genéricas para um grande número de pessoas, esperando que alguma caia no golpe, o spear phishing tem como alvo uma ou poucas vítimas específicas, com mensagens adaptadas à realidade dessas pessoas, o que o torna muito mais convincente e perigoso.

Para aplicar o golpe, o atacante realiza uma pesquisa prévia sobre a vítima, utilizando informações disponíveis em redes sociais, sites corporativos ou vazamentos de dados anteriores. Com esses dados, ele elabora e-mails ou mensagens que parecem legítimos, muitas vezes imitando colegas de trabalho, parceiros comerciais ou sistemas da própria empresa. A vítima, por confiar no remetente ou no conteúdo, é induzida a clicar em links maliciosos, baixar arquivos infectados ou fornecer informações sigilosas.

Esse tipo de ataque costuma ter como objetivo roubar dados confidenciais, como credenciais de acesso, informações financeiras ou estratégicas, ou até instalar malwares nos sistemas da organização. Em ambientes corporativos, o spear phishing é usado com frequência para abrir portas para ataques mais complexos, como ransomware ou acesso persistente a redes internas.

O spear phishing é particularmente perigoso porque passa despercebido pelos filtros tradicionais de segurança. Como as mensagens não contêm elementos suspeitos em massa (como spam ou vírus conhecidos), elas frequentemente conseguem passar por firewalls e antivírus sem serem detectadas. Além disso, o grau de personalização faz com que a vítima confie no conteúdo e aja rapidamente.

Para se proteger, é fundamental adotar boas práticas de cibersegurança, como verificar cuidadosamente o remetente de e-mails, desconfiar de mensagens com senso de urgência, nunca clicar em links desconhecidos e utilizar autenticação multifator. Treinamentos regulares de conscientização também são essenciais para preparar usuários e equipes a identificar tentativas de spear phishing antes que causem danos reais.

(EDUCA / Prefeitura de Alhandra-PB - 2024) Phishing é uma técnica de fraude cibernética onde atacantes tentam enganar indivíduos para que divulguem informações confidenciais, como senhas, números de cartão de crédito ou outras informações pessoais. Existem vários tipos de phishing, cada um com métodos específicos para atingir suas vítimas. Analise as seguintes afirmativas sobre diferentes tipos de phishing.

I. Um ataque direcionado, onde o atacante personaliza o e-mail para uma pessoa específica ou grupo dentro de uma organização. Ele usa informações pessoais da vítima para tornar a mensagem mais convincente.

II. Phishing realizado por meio de chamadas telefônicas. O atacante finge ser de uma organização legítima para enganar a vítima a fornecer informações confidenciais por telefone.



III. Phishing realizado através de mensagens de texto (SMS). O atacante envia uma mensagem que parece ser de uma entidade confiável, solicitando que a vítima clique em um link ou ligue para um número de telefone.

Analise as afirmações apresentadas e marque a alternativa que RELACIONA CORRETAMENTE as afirmações e tipos de Phishing descritos:

- a) I - Vishing, II - Smishing, III - SpearPhishing.
- b) I - SpearPhishing, II - Smishing, III - Vishing.
- c) I - SpearPhishing, II - Vishing, III - Smishing.
- d) I - Whaling, II - Smishing, III - Vishing.
- e) I - Whaling, II - Vishing, III - Smishing.

Comentários: (I) Spear Phishing é o ataque direcionado e personalizado com base em informações específicas da vítima, geralmente mais eficaz por parecer legítimo ao alvo; (II) Vishing é o phishing via telefone, onde o atacante se passa por representante de uma entidade confiável para extrair informações confidenciais da vítima; (III) Smishing é o phishing por SMS, onde links ou instruções enganosas são enviados via mensagens de texto, explorando a confiança da vítima para induzi-la ao erro (Letra C).



Hoax

INCIDÊNCIA EM PROVA: MÉDIA



O Hoax (Boato) é uma mensagem que possui conteúdo alarmante ou falso e que, geralmente, tem como remetente, ou aponta como autora, alguma instituição, empresa importante ou órgão governamental. Por meio de uma leitura minuciosa de seu conteúdo, normalmente, é possível identificar informações sem sentido ou tentativas de golpes, como correntes de e-mail e pirâmides financeiras.

CONTEÚDO DE HOAX

Conter códigos maliciosos, espalhar desinformação pela internet ou ocupar - desnecessariamente - espaço nas caixas de e-mails dos usuários.

Comprometer a credibilidade e a reputação de pessoas ou entidades referenciadas na mensagem.

Comprometer a credibilidade e a reputação da pessoa que o repassa, pois, ao fazer isto, esta pessoa estará supostamente endossando ou concordando com o conteúdo da mensagem.

Aumentar excessivamente a carga de servidores de e-mail e o consumo de banda de rede, necessários para a transmissão e o processamento das mensagens.

Indicar, no conteúdo da mensagem, ações a serem realizadas e que, se forem efetivadas, podem resultar em sérios danos.

Em geral, boatos se propagam pela boa vontade e solidariedade de quem os recebe, pois há uma grande tendência das pessoas em confiar no remetente, não verificar a procedência e não conferir a veracidade do conteúdo da mensagem. Para que você possa evitar a distribuição de boatos é muito importante conferir a procedência dos e-mails e, mesmo que tenham como remetente alguém conhecido, é preciso certificar-se de que a mensagem não é um boato.



(QUADRIX / CRBM6 - 2018) A principal característica do vírus Hoax é que ele é utilizado para "pescar" senhas e(ou) dados financeiros dos usuários, como, por exemplo, do cartão de crédito.

Comentários: hoax é um boato ou alerta falso, geralmente enviado por e-mail, que espalha desinformação ou induz o usuário a tomar ações desnecessárias. Não tem como objetivo principal capturar senhas ou dados financeiros – isso é típico de phishing. (Errado).

(FUNRIO / IF-BA - 2014) A Internet propicia muitas facilidades e tornou-se indispensável na atualidade. Ela expõe, porém, seus usuários a muitas ameaças. Uma das principais ameaças dos usuários da Internet são os vírus, que existem em diversas categorias. A categoria de vírus que visa a difundir histórias enganosas ou boatos é o:

- a) Backdoor.
- b) Cavalo de Troia.
- c) Hoax.
- d) Phishing.
- e) Spyware.

Comentários: (a) Errado. *Backdoor* é um tipo de malware que permite acesso remoto não autorizado ao sistema, não tem relação com a disseminação de boatos; (b) Errado. *Cavalo de Troia* é um software malicioso disfarçado de programa legítimo, mas também não visa espalhar histórias enganosas; (c) Correto. *Hoax* é uma mensagem falsa ou boato disseminado pela Internet, geralmente por e-mail ou redes sociais, com o objetivo de enganar ou alarmar os usuários; (d) Errado. *Phishing* é uma técnica de fraude que visa roubar dados sensíveis por meio de mensagens enganosas, mas com objetivo de obtenção de informações e não de espalhar boatos; (e) Errado. *Spyware* coleta informações do usuário sem consentimento, não tem relação com difusão de histórias falsas (Letra C).

(FCC / TRT24 - 2011) O usuário do computador recebe uma mensagem não solicitada, geralmente de conteúdo alarmista, a fim de assustá-lo e convencê-lo a continuar a corrente interminável de e-mails para gerar congestionamento na rede. Trata-se de um ataque denominado:

- a) Hoax.
- b) Worms.
- c) Trojans.
- d) Spam.
- e) Backdoors.

Comentários: (a) Correto. *Hoax* é uma mensagem falsa, geralmente alarmista, que induz o usuário a repassá-la para outros contatos, gerando desinformação e sobrecarga na rede; (b) Errado. *Worms* são malwares autorreplicantes que se espalham automaticamente pela rede, não dependem de mensagens de alerta ou ação do usuário para se propagar; (c) Errado. *Trojans* se disfarçam como programas legítimos para executar ações maliciosas, não têm como objetivo principal espalhar mensagens alarmistas; (d) Errado. *Spam* são mensagens não solicitadas, geralmente com fins publicitários, mas não necessariamente alarmistas ou com o objetivo de gerar correntes; (e) Errado. *Backdoors* permitem acesso remoto ao sistema, sem relação com envio de mensagens em cadeia (Letra A).



Man in the Middle

INCIDÊNCIA EM PROVA: BAIXA



O Man in the Middle é um ataque em que os dados trocados entre duas partes (Ex: você e o seu banco) são de alguma forma interceptados, registrados e possivelmente alterados pelo atacante sem que as vítimas percebam. Durante o ataque, a comunicação é interceptada pelo atacante e retransmitida. O atacante pode decidir retransmitir entre os legítimos participantes os dados inalterados, com alterações ou bloquear partes da informação.

(FADESP / BANPARÁ- 2018 - Item II) O ataque do homem-do-meio refere-se à forma de ataque em que uma comunicação entre duas pessoas é interceptada por uma terceira. O atacante simplesmente recebe e, opcionalmente, repassa as informações do transmissor para o receptor, sem que ambos percebam que a comunicação não está sendo, de fato, direta.

Comentários: o ataque homem-do-meio (man-in-the-middle) consiste na interceptação da comunicação entre duas partes por um terceiro, que pode apenas monitorar ou até alterar os dados, tudo sem que os envolvidos percebam (Correto).

(FCC / TRF4 - 2019) Em redes de computadores, é o tipo de ataque em que o espião intercepta a comunicação entre dois usuários, de forma que o usuário A comunique-se com ele mesmo pensando ser o usuário B, e o usuário B também o faz, pensando ser o usuário A. Trata-se de:

- a) SYN Flooding.
- b) Pharming.
- c) Man-in-The-Middle.
- d) DoS.
- e) Spoofing.

Comentários: (a) Errado. *SYN Flooding* é um tipo de ataque DoS que explora o protocolo TCP enviando múltiplas requisições incompletas para esgotar recursos do servidor; (b) Errado. *Pharming* redireciona o tráfego de forma maliciosa por meio da manipulação de DNS, mas não envolve interceptação direta entre dois usuários; (c) Correto. *Man-in-the-Middle* (Homem-no-Meio) é o ataque em que um invasor intercepta a comunicação entre duas partes, fazendo cada uma acreditar que está se comunicando diretamente com a outra; (d) Errado. *DoS* (Denial of Service) tem como objetivo tornar um serviço indisponível por sobrecarga, e não interceptar comunicações; (e) Errado. *Spoofing* finge ser outro usuário ou sistema, podendo ser parte de um *Man-in-the-Middle*, mas o ataque descrito é especificamente esse último (Letra C).

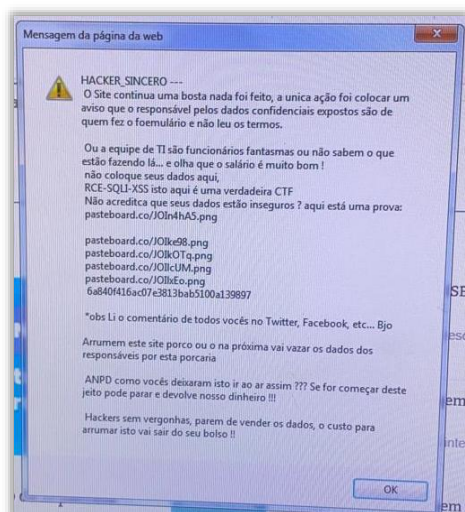


Defacement

INCIDÊNCIA EM PROVA: BAIXÍSSIMA



Desfiguração de página (Defacement ou Pichação) é uma técnica que consiste em alterar o conteúdo da página web. Para ganhar mais visibilidade, chamar mais atenção e atingir maior número de visitantes, geralmente os atacantes alteram a página principal do site, porém páginas internas também podem ser alteradas. As principais formas que um atacante, neste caso também chamado de *Defacer*, pode utilizar para desfigurar uma página web são:



- explorar vulnerabilidades da linguagem de programação ou dos pacotes utilizados no desenvolvimento da aplicação Web;
- invadir o servidor onde a aplicação Web está hospedada e alterar diretamente os arquivos que compõem o site;
- explorar erros da aplicação Web ou vulnerabilidades do servidor de aplicação web;
- ou furtar senhas de acesso à interface Web usada para administração remota.

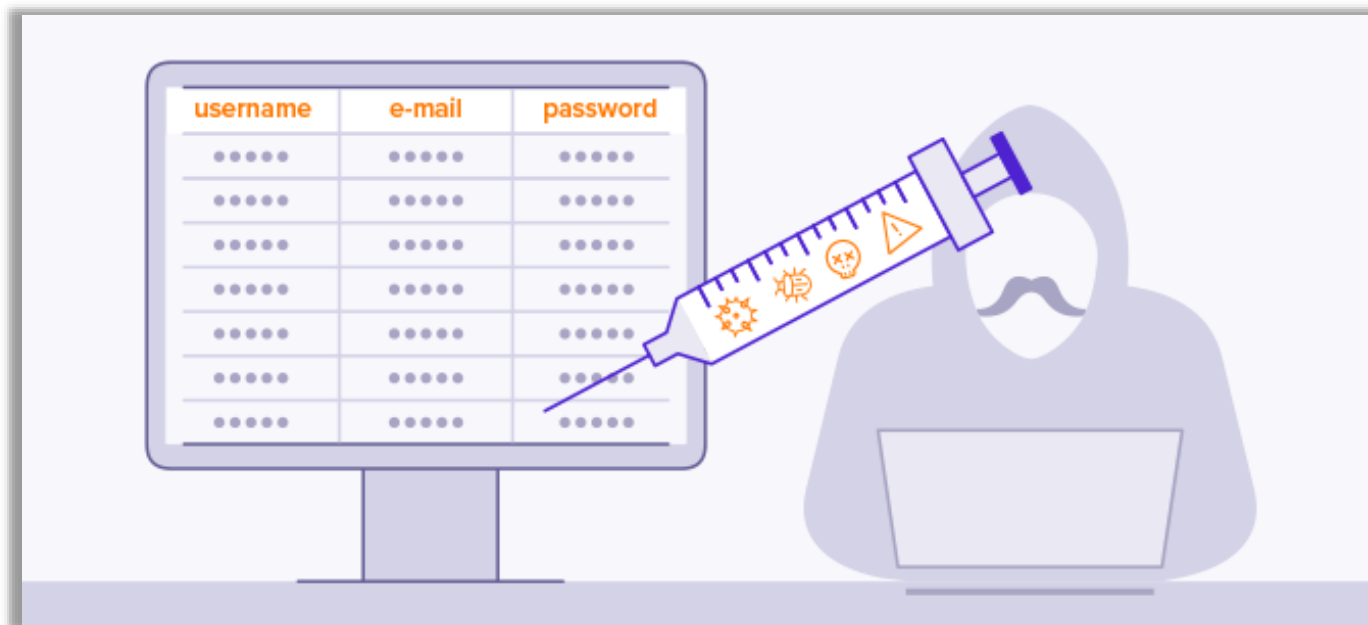
(CEBRASPE / TRE-RJ - 2012) É possível executar um ataque de desfiguração (*defacement*) – que consiste em alterar o conteúdo da página web de um sítio – aproveitando-se da vulnerabilidade da linguagem de programação ou dos pacotes utilizados no desenvolvimento de aplicação web.

Comentários: o defacement ocorre quando um atacante explora vulnerabilidades em aplicações web – como falhas em scripts, bibliotecas ou pacotes desatualizados – para alterar o conteúdo de páginas, geralmente com mensagens de protesto ou vandalismo digital (Correto).



SQL Injection

INCIDÊNCIA EM PROVA: BAIXÍSSIMA



A injeção de SQL (SQL Injection) é uma vulnerabilidade de segurança que ocorre quando um invasor insere instruções SQL maliciosas em uma entrada de dados, como campos de formulário ou parâmetros de URL, com o objetivo de manipular o banco de dados subjacente. Essa técnica é amplamente explorada em sistemas que utilizam consultas SQL⁷ dinâmicas para interagir com um banco de dados. *Entendi nada, professor!* Então vamos ver uma analogia...

Imagine que um restaurante tem um sistema de pedidos online, onde os clientes podem inserir o número de mesa e o item que desejam pedir em um formulário da web. O restaurante então usa esse sistema para buscar os pedidos no banco de dados e preparar os pratos correspondentes. Agora, suponha que o restaurante não valide corretamente as entradas do cliente antes de buscar os pedidos no banco de dados.

Ora, isso é como permitir que os clientes escrevam suas próprias instruções para os chefs, em vez de preencherem um formulário com itens de menu específicos. Nesse cenário, temos:

- 1. Pedido Normal:** um cliente insere o número da mesa e seleciona um prato do menu disponível na página web do restaurante. O sistema do restaurante, como esperado, busca o pedido correspondente no banco de dados e prepara o prato solicitado.
- 2. SQL Injection:** um invasor malicioso, em vez de selecionar um item do menu, insere instruções SQL diretamente no campo de pedido. Por exemplo, ele pode digitar "OR 1=1", que é uma instrução SQL que sempre retorna verdadeiro (dado que 1 é sempre igual a 1). O sistema, sem validar corretamente essa entrada, executa a consulta diretamente no banco de dados, resultando na busca de todos os pedidos em todas as mesas, em vez de apenas na mesa especificada. Isso pode levar a uma situação em que o invasor pode ver todos os pedidos do restaurante, comprometendo a segurança do sistema.

⁷ SQL (Structured Query Language) é uma linguagem de consulta utilizada para gerenciar e manipular bancos de dados relacionais. Por meio dele, é possível executar operações como inserção, atualização, exclusão e recuperação de dados em um banco de dados, além de definir e manipular sua estrutura.



Nesta analogia, a injeção de SQL é como permitir que um cliente escreva instruções diretamente para os chefes de cozinha, em vez de pedir pratos específicos do menu. Sem a validação adequada, isso pode levar a uma situação em que um invasor pode manipular o sistema para obter acesso não autorizado ou informações confidenciais do banco de dados, assim como um cliente mal-intencionado pode tentar manipular um restaurante para obter mais do que o que está no menu.

Quando um sistema não valida ou sanitiza adequadamente as entradas do usuário, um invasor pode inserir comandos SQL maliciosos que são executados pelo banco de dados. Isso pode permitir que o invasor acesse, modifique ou exclua dados no banco de dados, comprometendo a integridade e a segurança do sistema. Para mitigar o risco de injeção de SQL, é crucial implementar práticas de segurança como a validação e sanitização de entradas de usuário.

Além disso, é interessante manter o software atualizado, realizar testes regulares e utilizar consultas parametrizadas ou preparadas, e a aplicação de princípios de menor privilégio ao conceder acesso ao banco de dados, isto é, **usuários e processos devem ter acesso apenas às informações e recursos essenciais para executar suas tarefas, limitando assim o potencial de danos caso ocorra uma violação de segurança.**

(FGV / MPE-AL - 2018) Na prática de programação segura, a ação que pode ser adotada para mitigar ataques que exploram a inserção de comandos em campos de formulários dos sistemas, especialmente em sistemas web, como o ataque de "SQL Injection", é descrita como

- a) codificação dos dados de entrada.
- b) criptografia dos dados de entrada.
- c) autenticação de usuários.
- d) controle de acesso dos dados de entrada.
- e) validação dos dados de entrada.

Comentários: (a) Errado. *Codificação* (como base64 ou URL encoding) transforma os dados, mas não impede diretamente a execução de comandos maliciosos em campos de formulário; (b) Errado. *Criptografia* protege dados em trânsito ou em repouso, mas não previne a inserção de comandos maliciosos em formulários; (c) Errado. *Autenticação* verifica a identidade do usuário, mas não trata da segurança dos dados inseridos nos campos de entrada; (d) Errado. *Controle de acesso* restringe quem pode acessar determinados dados ou funções, mas não impede injeções em campos de entrada; (e) Correto. *Validação dos dados de entrada* é uma prática essencial na programação segura para garantir que os dados recebidos estejam no formato e conteúdo esperados, prevenindo ataques como SQL Injection (Letra E)



Furto de Identidade

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

O Furto de Identidade (Identity Theft) é o ato pelo qual uma pessoa tenta se passar por outra, atribuindo-se uma falsa identidade, com o objetivo de obter vantagens indevidas. Alguns casos de furto de identidade podem ser considerados como crime contra a fé pública, tipificados como falsa identidade. No seu dia a dia, sua identidade pode ser furtada caso, por exemplo, alguém abra uma empresa ou uma conta bancária usando seu nome e seus documentos.

Na Internet isto também pode ocorrer, caso alguém crie um perfil em seu nome em uma rede social, acesse sua conta de e-mail e envie mensagens se passando por você ou falsifique os campos de e-mail, fazendo parecer que ele foi enviado por você. **Quanto mais informações você disponibiliza sobre a sua vida e rotina, mais fácil se torna para um golpista furtrar a sua identidade, pois mais dados ele tem disponíveis e mais convincente ele pode ser.**

Além disto, o golpista pode usar outros tipos de golpes e ataques para coletar informações sobre você, inclusive suas senhas, como códigos maliciosos, ataques de força bruta e interceptação de tráfego. **Caso a sua identidade seja furtada, você poderá arcar com consequências como perdas financeiras, perda de reputação e falta de crédito.** Além disto, pode levar muito tempo e ser bastante desgastante até que você consiga reverter todos os problemas causados pelo impostor.

E como me prevenir, professor? A melhor forma de impedir que sua identidade seja furtada é evitar que o impostor tenha acesso aos seus dados e às suas contas de usuário. Além disto, para evitar que suas senhas sejam obtidas e indevidamente usadas, é muito importante que você seja cuidadoso, tanto ao usá-las quanto ao elaborá-las. É necessário também que você fique atento a alguns indícios que podem demonstrar que sua identidade está sendo indevidamente usada por golpistas:

PRINCIPAIS INDÍCIOS

Você começa a ter problemas com órgãos de proteção de crédito;

Você recebe o retorno de e-mails que não foram enviados por você;

Você verifica nas notificações de acesso que a sua conta de e-mail ou seu perfil na rede social foi acessado em horários ou locais em que você próprio não estava acessando;

Ao analisar o extrato da sua conta bancária ou do seu cartão de crédito você percebe transações que não foram realizadas por você;

Você recebe ligações telefônicas, correspondências e e-mails se referindo a assuntos sobre os quais você não sabe nada a respeito, como uma conta bancária que não lhe pertence e uma compra não realizada por você.

(AOCF / FHSTE-RS - 2019) Furto de identidade é o ato pelo qual uma pessoa tenta se passar por outra, atribuindo-se uma falsa identidade, com o objetivo de obter vantagens indevidas.

Comentários: furto de identidade ocorre quando alguém utiliza dados pessoais de outra pessoa – como nome, CPF ou informações bancárias – para se passar por ela, geralmente visando obter benefícios ilícitos ou cometer fraudes (Correto).



Fraude de Antecipação de Recursos

INCIDÊNCIA EM PROVA: BAIXÍSSIMA

A Fraude de Antecipação de Recursos (Advance Fee Fraud) é aquela na qual um golpista procura induzir uma pessoa a fornecer informações confidenciais ou a realizar um pagamento adiantado, com a promessa de futuramente receber algum tipo de benefício. Por meio do recebimento de mensagens eletrônicas ou do acesso a sites fraudulentos, a pessoa é envolvida em alguma situação ou história mirabolante.

Em geral, essa situação justifica a necessidade de envio de informações pessoais ou a realização de algum pagamento adiantado para a obtenção de um benefício futuro. Após fornecer os recursos solicitados a pessoa percebe que o tal benefício prometido não existe, constata que foi vítima de um golpe e que seus dados/dinheiro estão em posse de golpistas. Existem variações desse golpe: Golpe da Nigéria, Loteria Internacional, Crédito Fácil, Noiva Russa, entre outros.

GOLPE	DESCRIÇÃO
GOLPE DA NIGÉRIA	A vítima recebe uma mensagem eletrônica em nome de alguém ou de alguma instituição, na qual é solicitado que ela atue como intermediária em uma transferência de fundos.
LOTERIA INTERNACIONAL	A vítima recebe um e-mail informando que foi sorteado em uma loteria internacional, mas que para receber o prêmio a que tem direito, precisa fornecer seus dados pessoais e informações sobre a sua conta bancária.
CRÉDITO FÁCIL	Você recebe um e-mail contendo uma oferta de empréstimo ou financiamento com taxas de juros muito inferiores às praticadas no mercado. Após o seu crédito ser supostamente aprovado você é informado que necessita efetuar um depósito bancário para o ressarcimento das despesas.
OFERTA DE EMPREGO	Você recebe uma mensagem em seu celular contendo uma proposta tentadora de emprego. Para efetivar a contratação, no entanto, é necessário que você informe detalhes de sua conta bancária.
DOAÇÃO DE ANIMAIS	Você deseja adquirir um animal de uma raça bastante cara e, ao pesquisar por possíveis vendedores, descobre que há sites oferecendo estes animais para doação. Após entrar em contato, é solicitado que você envie dinheiro para despesas de transporte.
NOIVA RUSSA	Alguém deixa um recado em sua rede social contendo insinuações sobre um possível relacionamento amoroso entre vocês. Esta pessoa mora em outro país, geralmente a Rússia, e após alguns contatos iniciais sugere que vocês se encontrem pessoalmente, mas, para que ela possa vir até o seu país, necessita ajuda financeira para as despesas de viagem.

Eu já recebi diversas mensagens no fórum me perguntando se alguém realmente cai nesses golpes (principalmente no golpe da noiva russa). Galera, cai demaaaaaaaais... absolutamente todos os dias! Como diz aquele antigo ditado: *"O golpe tá aí, cai quem quer"*! Eu só enfatizo em relação outros golpes que é preciso tomar muito cuidado com nossos pais e avós porque eles tendem a ser mais ingênuos quanto a isso! **Vamos ver como nos prevenir desse tipo de fraude...**

A melhor maneira é identificar algumas características: alguém oferecendo quantias astronômicas de dinheiro; alguém solicitando sigilo nas transações; alguém solicitando que você a responda rapidamente; alguém apresentando palavras como "urgente" e "confidencial" no campo de assunto; alguém



apresentando erros gramaticais e de ortografia (muitas mensagens são escritas por meio do uso de programas tradutores e podem apresentar diversos erros).

Além disto, adotar uma postura preventiva pode, muitas vezes, evitar que você seja vítima de golpes. Por isto, é muito importante que você: questione-se por que justamente você, entre os inúmeros usuários da Internet, foi escolhido para receber o benefício proposto na mensagem e como chegaram até você; desconfie de situações onde é necessário efetuar algum pagamento com a promessa de futuramente receber um valor maior.

Além desses, a principal dica para evitar esse tipo de golpe é aplicar a sabedoria popular de ditados como: "Quando a esmola é demais, o santo desconfia"! Vale alertar que mensagens deste tipo nunca devem ser respondidas, pois isto pode servir para confirmar que o seu endereço de e-mail é válido. Esta informação pode ser utilizada, por exemplo, para incluí-lo em listas de spam ou de possíveis vítimas em outros tipos de golpes.

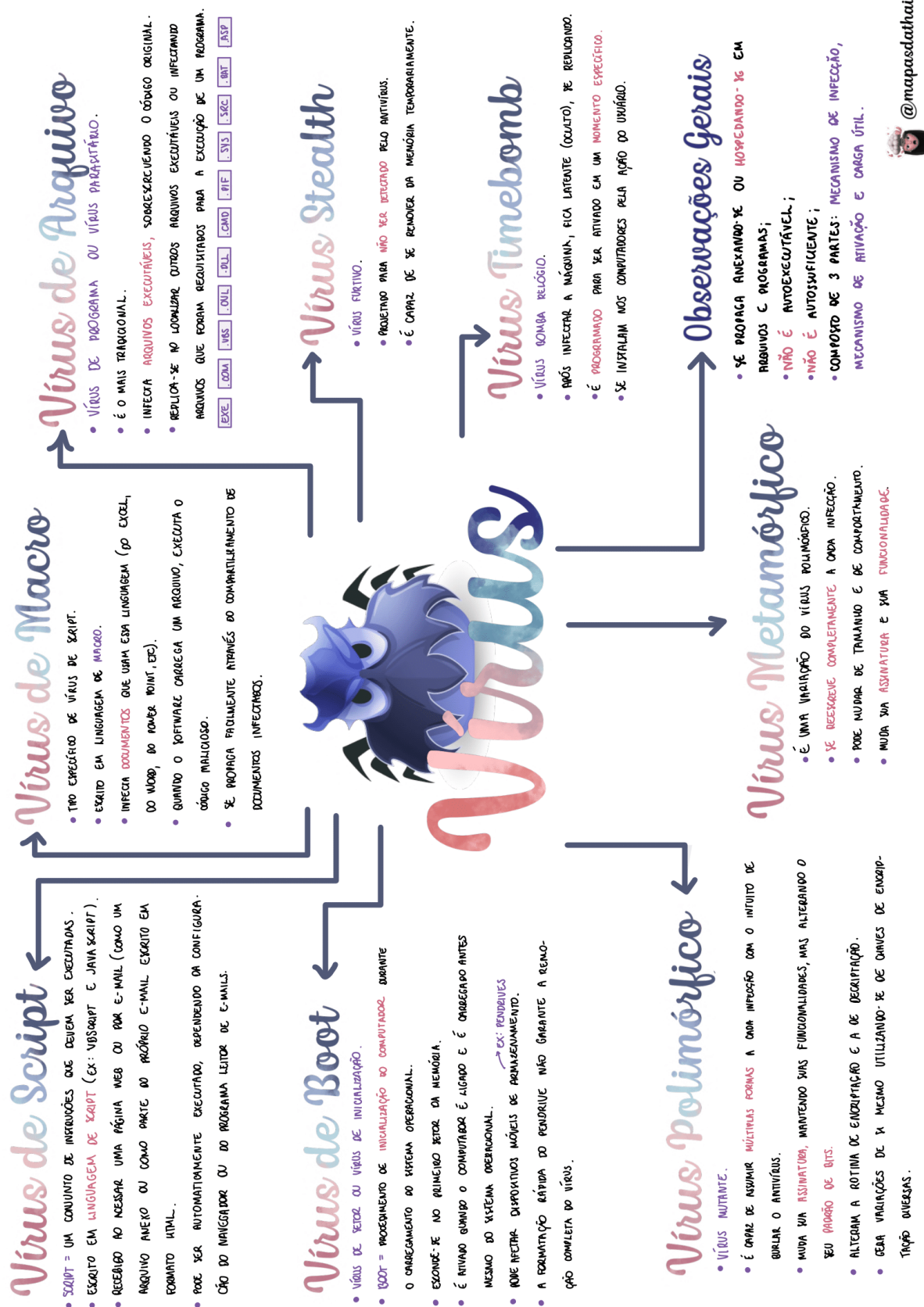
(AOCF / FUNPAPA - 2018) Assinale a alternativa que descreve uma situação que pode ocorrer com uma vítima de um ataque conhecido como Fraude de antecipação de recursos (Advance fee fraud):

- a) A vítima recebe uma mensagem eletrônica em nome de alguém ou de alguma instituição, na qual é solicitado que ela atue como intermediária em uma transferência de fundos.
- b) A vítima recebe ligações telefônicas, correspondências e e-mails se referindo a assuntos sobre os quais ela não sabe nada a respeito, como uma conta bancária que não lhe pertence e uma compra não realizada por ela.
- c) Ao analisar o extrato da sua conta bancária ou do seu cartão de crédito, a vítima percebe transações que não foram realizadas por ela.
- d) O golpista cria um site fraudulento com o objetivo específico de enganar os possíveis clientes que, após efetuarem os pagamentos, não recebem as mercadorias.
- e) A vítima tenta receber a mercadoria sem realizar o pagamento ou o realiza por meio de transferência efetuada de uma conta bancária ilegítima ou furtada.

Comentários: (a) Correto, esse é um caso de Golpe da Nigéria; (b) Errado, esse é um caso de Furto de Identidade; (c) Errado, esse é um caso de Furto de Identidade; (d) Errado, esse é um caso de Pharming; (e) Errado, isso não seria uma vítima e, sim, um golpista (Letra A).



MAPA MENTAL





@mapasdathai



Worm

- CAPAZ DE SE REPLICAR AUTOMATICAMENTE, ENVIANDO CÓPIAS DE SI MESMO.
- CONSUME MUITOS RECURSOS, AFETA O DESEMPENHO DA REDE E PODE LOTAR O DISCO RÍGIDO.
- WORMS NÃO INFECTAM ARQUIVOS. SÃO AUTÔNOMOS.
- SÃO CAPAZES DE ENTRAR EM UMA MÁQUINA SEM QUALQUER INTERAÇÃO COM O USUÁRIO.

PROCESSO DE INFECÇÃO E PROPAGAÇÃO

- 1ª FASE: SCANNING (IDENTIFICAÇÃO DOS COMPUTADORES - ALVO E OS QUAIS TENTARÁ SE COPIAR);
- 2ª FASE: ENVIO DE CÓPIAS;
- 3ª FASE: ATIVAÇÃO DAS CÓPIAS (EM REGRA, PRECISA SER EXECUTADO PARA QUE A INFECÇÃO OCORRA).



Bot

MINUTIVO DE ROBOT = ROBÔ

- PROGRAMA QUE DISPÕE DE MECANISMOS DE COMUNICAÇÃO COM O INVASOR QUE PERMITEM QUE A MÁQUINA INVADIDA SEJA CONTROLADA REMOTAMENTE.
- SE PROPAGA AUTOMATICAMENTE EXPLORANDO VULNERABILIDADES DOS PROGRAMAS.
- COMPUTADOR INFECTADO = ZUMBI.
- BOTNET = REDE DE ZUMBIS PRONTA PARA EXECUTAR AÇÕES EM MASSA SOB COMANDO DO INVASOR.



Spywares

- SOFTWARE ESPÃO QUE COLETA DADOS DA MÁQUINA OU DA REDE E DISPONIBILIZA-OS A TERCEIROS.
- PODE SER LEGÍTIMO OU MALICIOSO, DEPENDENDO DA FORMA COMO FOI INSTALADO.
- PRECISA SER EXPLICITAMENTE EXECUTADO PELO USUÁRIO.
- KEYLOGGER: CAPTURA AS TECLAS DIGITADAS PELO USUÁRIO.
- SCREENLOGGER: CAPTURA A POSIÇÃO DO CURSOR E A TELA APRESENTADA NO MOMENTO EM QUE O MOUSE É CLICADO.
- ADWARE: PROJETADO P/ APRESENTAR PROPAGANDAS.

Principais Malwares



Trojan

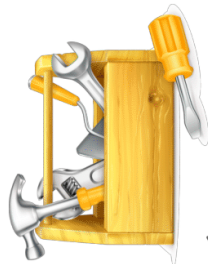
CAVALO DE TROIA

- PROGRAMA QUE, ALÉM DE EXECUTAR AS FUNÇÕES PARA AS QUAIS FOI APARENTEMENTE PROJETADO, TAMBÉM EXECUTA FUNÇÕES MALICIOSAS.
- PRECISA EXPLICITAMENTE SER EXECUTADO P/ SER INSTALADO.
- NÃO SE PROPAGA.
- PODE SER CONSIDERADO UM TIPO DE VÍRUS.
- SUA ATUAÇÃO MALICIOSA É EXTREMAMENTE VERSÁTIL, PODENDO REALIZAR ATIVIDADES TÍPICAS DE OUTROS MALWARES.
- TIPOS DE TROJAN: DOWNLOADER, DROPPER, BACKDOOR, DOS, DESTRUTIVO, CLICKER, PROXY, SPY E BANNER.



Backdoor

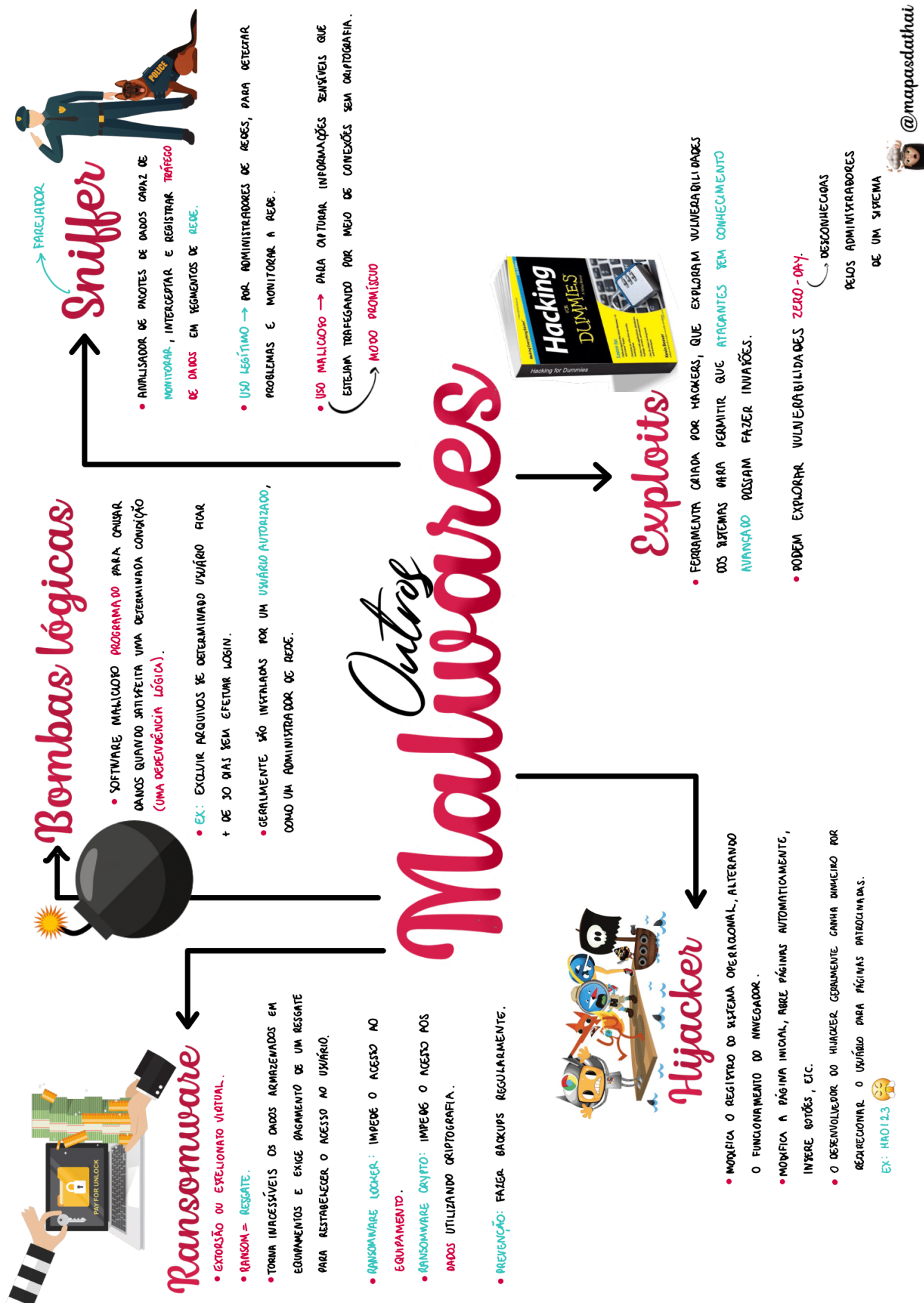
- PROGRAMA QUE PERMITE O RETORNO DE UM INVASOR A UM COMPUTADOR COMPROMETIDO.
- PODE SER INCLUÍDO POR OUTROS CÓDIGOS MALICIOSOS QUE TENHAM PREVIAMENTE INFECTADO O COMPUTADOR OU POR INVASORES QUE EXPLOARAM VULNERABILIDADES NOS PROGRAMAS INSTALADOS NA MÁQUINA.
- GARANTE ACESSO REMOTO FUTURO. (ABRE AS PORTAS TOP)

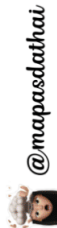
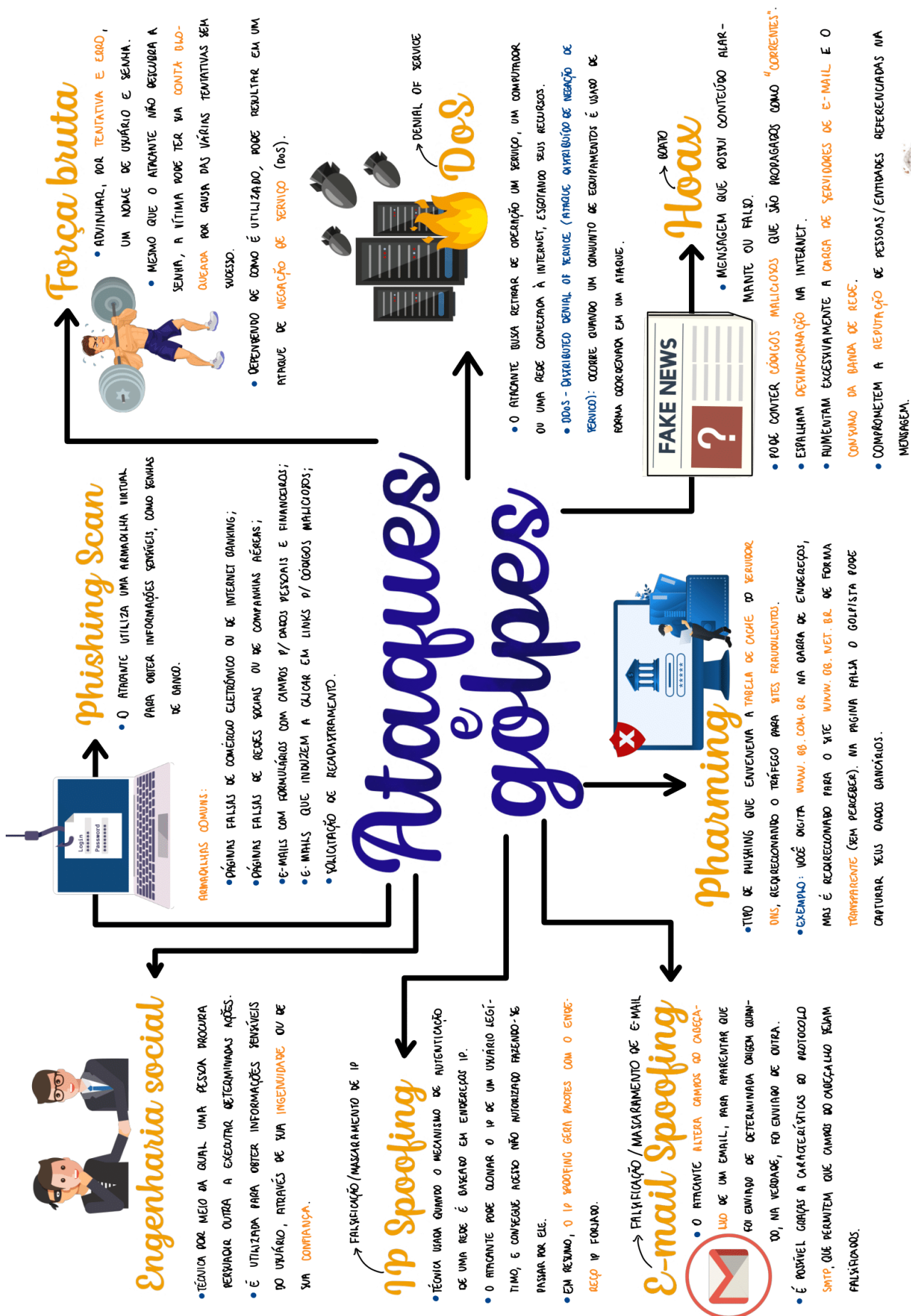


Rootkit

KIT DO ADMINISTRADOR

- CONJUNTO DE PROGRAMAS E TÉCNICAS QUE PERMITE ESCONDER E ASSEGURAR A PRESENÇA DE UM INVASOR OU DE OUTRO CÓDIGO MALICIOSO EM UM COMPUTADOR.
- É UM DOS MALWARES MAIS SORFISTICADOS QUE EXISTEM.
- NÃO É USADO P/ OBTER O ACESSO, MAS SIM P/ MANTÊ-LO.
- COMPROMETE O SISTEMA OPERACIONAL, ALTERANDO TUDO QUE ELE INFORMA, DE ACORDO COM O QUE QUEL O INVASOR.





@mapasdashai

RESUMO

DEFINIÇÃO DE MALWARE

Códigos maliciosos (Malwares, do inglês *Malicious Softwares*) são programas especificamente desenvolvidos para executar ações danosas e atividades maliciosas em um computador.

FORMAS COMUNS DE INFECÇÃO DE MALWARES

Pela exploração de vulnerabilidades existentes nos programas instalados ou pela auto-execução de mídias removíveis infectadas, como pen-drives;

Pelo acesso a páginas maliciosas, utilizando navegadores vulneráveis ou pela ação direta de atacantes que, após invadirem o computador, incluem arquivos contendo códigos maliciosos;

Pela execução de arquivos previamente infectados, obtidos em anexos de mensagens eletrônicas, via mídias removíveis, em páginas web ou de outros computadores.



DEFINIÇÃO DE VÍRUS

Programa ou parte de um programa, normalmente malicioso, que se propaga infectando, inserindo cópias de si mesmo, anexando-se ou hospedando-se em arquivos ou programas existentes na máquina.

TIPOS DE VÍRUS	DESCRIÇÃO
VÍRUS DE SCRIPT	Escrito em linguagem de script, como VBScript e JavaScript, e recebido ao acessar uma página web ou por e-mail, como um arquivo anexo ou como parte do próprio e-mail escrito em formato HTML.
VÍRUS DE MACRO	Tipo específico de vírus de script normalmente recebido ao acessar páginas web ou por e-mail e que tenta infectar arquivos manipulados por aplicativos que utilizam essas linguagens mencionadas anteriormente como os arquivos que compõe o Microsoft Office.
VÍRUS DE BOOT	Também conhecido como Vírus de Setor de Carga ou Vírus de Setor de Inicialização, ele é ativado quando o computador é ligado e é carregado na memória antes do sistema operacional.
VÍRUS DE ARQUIVO	Também conhecido como Vírus de Programa ou Parasitário, trata-se do vírus mais tradicional e comum. Ele infecta e causa danos ao se conectarem a arquivos executáveis (.exe, .com, .dll, etc), sobrescrevendo o código original e causando danos quase sempre irreparáveis.
VÍRUS POLIMÓRFICO	Também conhecido como Vírus Mutante, é capaz de assumir múltiplas formas a cada infecção com o intuito de burlar o software de antivírus.
VÍRUS METAMÓRFICO	Trata-se de um vírus que se transforma a cada infecção, mas que - diferentemente do polimórfico - se reescreve completamente a cada infecção, podendo mudar seu tamanho e comportamento, aumentando a dificuldade de detecção.
VÍRUS STEALTH	Projetados explicitamente para não serem detectados pelo antivírus e têm a capacidade de se remover da memória temporariamente para evitar que o antivírus o detecte.



VÍRUS TIMEBOMB	Conhecido como Vírus Bomba Relógio, trata-se de um vírus que – após infectar a máquina – permanece latente (oculto), apenas se replicando, e seu código malicioso é programado para ser ativado em um determinado momento específico, executando sua carga útil.

TIPOS DE MALWARES	DESCRIÇÃO
WORM	Trata-se de um programa capaz de se replicar automaticamente, enviando cópias de si mesmo. Diferente dos vírus, ele não se propaga por meio da inclusão de cópias de si mesmo em outros programas ou arquivos através da rede, mas – sim – pela exploração automática de vulnerabilidades existentes em programas instalados em computadores ou pela execução direta de suas cópias.
BOT	Trata-se de um programa que dispõe de mecanismos de comunicação com o invasor que permitem que ele seja controlado remotamente. Possui processo de infecção e propagação similar ao do Worm, ou seja, é capaz de se propagar automaticamente, explorando vulnerabilidades existentes em programas instalados em computadores.
BOTNET	Trata-se de uma rede de computadores infectados por malware e controlados remotamente por um cibercriminoso, sem o conhecimento dos usuários. Esses dispositivos, chamados de bots ou zumbis, podem ser usados de forma coordenada para executar atividades maliciosas, como ataques DDoS, envio massivo de spam, roubo de dados, mineração de criptomoedas e propagação de vírus, entre outros.
CAVALO DE TROIA	Trata-se de um programa que age utilizando o princípio do Cavalo de Troia, em um arquivo é enviado se fazendo passar por um aplicativo útil, como um “presente de grego”, mas que na verdade possui funcionalidades maliciosas escondidas. Muitas vezes, o trojan abre portas de comunicação para que através da Internet a máquina possa ser invadida ou monitorada.
RANSOMWARE	Trata-se de um tipo de código malicioso que torna inacessíveis os dados armazenados em um equipamento, geralmente utilizando criptografia, e que exige pagamento de um resgate (<i>Ransom</i> , em inglês) para restabelecer o acesso ao usuário – trata-se de uma espécie de extorsão virtual.
SPYWARE	Software espião, capaz de violar a privacidade das informações de usuários, coletando dados da máquina ou da rede e disponibilizando-as a terceiros. Pode ser usado tanto de forma legítima quanto maliciosa, dependendo de como é instalado, das ações realizadas, do tipo de informação monitorada e do uso que é feito por quem recebe as informações coletadas.
KEYLOGGER	Trata-se de um tipo de malware ou ferramenta de espionagem que registra tudo o que o usuário digita no teclado, armazenando essas informações ou enviando-as remotamente para um invasor. Seu objetivo é capturar dados sensíveis, como senhas, números de cartão de crédito, mensagens pessoais e credenciais de acesso, sem que a vítima perceba.
SCREENLOGGER	Trata-se de um spyware – similar ao keylogger – projetado para capturar imagens da tela (screenshots) do dispositivo infectado em intervalos regulares ou quando determinadas ações são realizadas, como o acesso a sites de bancos ou o preenchimento de formulários. Ao contrário do keylogger, o screenlogger permite que o invasor visualize exatamente o que o usuário está vendo, incluindo dados que não foram digitados.
ADWARE	Trata-se de um spyware projetado especificamente para apresentar propagandas. Pode ser usado para fins legítimos, quando incorporado a programas e serviços, como forma de patrocínio ou retorno financeiro para quem desenvolve programas livres ou presta serviços gratuitos. Também pode ser usado para fins maliciosos quando as propagandas são direcionadas.



SNIFFER	Trata-se de um programa que age monitorando o tráfego na rede, através da captura de pacotes de dados, em busca de informações sensíveis como o endereço dos sites acessados, senhas de acesso, e-mails, entre outros.
BACKDOOR	Trata-se de um tipo de vulnerabilidade ou mecanismo oculto inserido em um sistema, software ou dispositivo com o objetivo de permitir acesso remoto não autorizado, contornando os métodos tradicionais de autenticação e segurança. Esse "acesso dos fundos" pode ser explorado por cibercriminosos para controlar o sistema, roubar dados, instalar outros malwares ou executar comandos silenciosamente.
ROOTKIT	Conjunto de programas e técnicas que projetados para se esconder profundamente no sistema operacional, com o objetivo de manter o acesso privilegiado e ocultar sua presença e a de outros malwares. Ele permite que um invasor controle o sistema de forma remota, sem ser detectado por antivírus tradicionais ou pelo próprio usuário.
BOMBAS LÓGICAS	Trata-se de um software malicioso normalmente instalado por um usuário autorizado, como um administrador da rede, que o mantém no sistema deixando-o programado para causar danos (como excluir arquivos importantes) em um determinado evento, como por exemplo o caso de ficar mais de 30 dias sem efetuar login.
EXPLOITS	Trata-se de um software criado por hackers para permitir explorar vulnerabilidades conhecidas de sistemas e assim permitir que iniciantes (<i>Script Kiddies</i>) possam praticar ações de invasões sem conhecimentos avançados.
HIJACKER	O Hijacker (sequestro, em inglês) é um software malicioso que modifica o registro do sistema operacional, alterando o funcionamento do navegador, modificando sua página inicial, abrindo páginas automaticamente, inserindo botões inadvertidamente.

TIPOS DE ATAQUES	DESCRIÇÃO
ENGENHARIA SOCIAL	Trata-se de uma técnica muito utilizada por golpistas para tentar explorar a ganância, a vaidade e a boa-fé ou abusar da ingenuidade e da confiança de outras pessoas, a fim de aplicar golpes, ludibriar ou obter informações sigilosas e importantes. O termo é utilizado para os métodos de obtenção de informações importantes do usuário, através de sua ingenuidade ou da confiança.
FORÇA BRUTA	Consiste em adivinhar, por tentativa e erro, um nome de usuário e senha e, assim, executar processos e acessar sites, computadores e serviços em nome e com os mesmos privilégios deste usuário. Qualquer computador, equipamento de rede ou serviço que seja acessível via Internet, com um nome de usuário e uma senha, pode ser alvo de um ataque de força bruta.
NEGAÇÃO DE SERVIÇO	Negação de serviço (Denial of Service - DoS) é uma técnica pela qual um atacante busca retirar de operação um serviço, um computador ou uma rede conectada à Internet. Quando usada de forma coordenada e distribuída, ou seja, quando um conjunto de equipamentos é utilizado no ataque, recebe o nome de Ataque Distribuído de Negação de Serviço (Distributed Denial of Service - DDoS).
IP SPOOFING	O IP Spoofing (Falsificação/Mascaramento de IP) é uma técnica de invasão comumente empregada quando o mecanismo de autenticação de uma rede é baseado em endereços IP, isto é, quando a identificação de um usuário é realizada baseado em seu número de endereço IP.



E-MAIL SPOOFING	Técnica que consiste em alterar campos do cabeçalho de um e-mail, de forma a aparentar que ele foi enviado de uma determinada origem quando, na verdade, foi enviado de outra. Essa técnica é possível devido a características do protocolo SMTP (Simple Mail Transfer Protocol) que permitem que campos do cabeçalho sejam falsificados.
PHISHING SCAM	Fraude em que o golpista tenta enganar um usuário para obtenção de dados pessoais e financeiros que permitam a aplicação de um golpe, combinando técnicas computacionais e de engenharia social. Um exemplo de phishing é um e-mail que possa induzir o usuário a clicar em um link falso levando-o para uma página clonada ou um arquivo malicioso.
SMISHING	Tipo de ataque de engenharia social que utiliza mensagens de texto (SMS) como meio para enganar usuários e obter dados pessoais, financeiros ou credenciais de acesso. O termo vem da junção de "SMS" com "phishing", e as mensagens geralmente se passam por instituições confiáveis, como bancos, operadoras ou órgãos públicos, contendo links maliciosos ou solicitações para que a vítima responda com informações sensíveis.
PHARMING	Ataque que possui como estratégia corromper o DNS e direcionar o endereço de um sítio para um servidor diferente do original. É um tipo específico de phishing que envolve o redirecionamento da navegação do usuário para sites falsos, por meio de alterações no serviço de DNS. Nesse caso, quando o usuário tenta acessar um site legítimo, o navegador web é redirecionado, de forma transparente, para uma página falsa.
VISHING	Tipo de golpe baseado em engenharia social por meio de chamadas telefônicas, em que o criminoso tenta enganar a vítima para obter informações confidenciais, como senhas, dados bancários ou números de cartão de crédito. O termo combina "voice" (voz) com "phishing", indicando que o ataque é feito via voz, geralmente com o invasor se passando por um representante de banco, suporte técnico ou órgão oficial.
BAITING	Tipo de ataque de engenharia social que utiliza uma "isca" atrativa para induzir a vítima a executar uma ação maliciosa, como conectar um dispositivo infectado ou acessar um link perigoso. Essa isca pode ser física – como um pen drive deixado propositalmente em locais públicos com rótulos chamativos ("fotos pessoais", "folha de pagamento") – ou digital, como um anúncio oferecendo algo gratuito.
WHALING	Tipo de ataque de engenharia social altamente direcionado que visa executivos de alto escalão ou pessoas com grande poder de decisão dentro de uma organização, como CEOs, diretores financeiros e gerentes de TI. O termo "whaling" (caça à baleia) é uma referência ao "tamanho" da vítima, que, se comprometida, pode fornecer acesso privilegiado a informações sensíveis, finanças corporativas ou infraestrutura crítica.
SPEAR PHISHING	Tipo de ataque de engenharia social altamente direcionado, em que o cibercriminoso envia mensagens falsas, geralmente por e-mail, com o objetivo de enganar uma pessoa ou um pequeno grupo específico. Diferente do phishing comum, que é disparado em massa, o spear phishing é personalizado, baseado em informações reais sobre a vítima – como seu nome, cargo, rotina ou contatos profissionais – para tornar o conteúdo mais convincente.
HOAX	Trata-se de uma mensagem que possui conteúdo alarmante ou falso e que, geralmente, tem como remetente, ou aponta como autora, alguma instituição, empresa importante ou órgão governamental.
MAN IN THE MIDDLE	Trata-se de um ataque em que os dados trocados entre duas partes são de alguma forma interceptados, registrados e possivelmente alterados pelo atacante sem que as vítimas percebam. Durante o ataque, a comunicação é interceptada pelo atacante e retransmitida. O atacante pode decidir retransmitir entre os legítimos participantes os dados inalterados, com alterações ou bloquear partes da informação.
DEFACEMENT	Trata-se de uma técnica que consiste em alterar o conteúdo da página web. Para ganhar mais visibilidade, chamar mais atenção e atingir maior número de visitantes, geralmente os atacantes alteram a página principal do site, porém páginas internas também podem ser alteradas.



SQL INJECTION	Tipo de ataque cibernético que explora vulnerabilidades em sistemas que interagem com bancos de dados SQL, permitindo que o invasor injete comandos maliciosos nas consultas feitas pelo aplicativo. Isso geralmente ocorre quando dados inseridos por usuários não são devidamente validados ou filtrados, permitindo que o atacante modifique a estrutura da consulta e acesse, altere ou até exclua informações confidenciais do banco.
FURTO DE IDENTIDADE	Crime no qual um indivíduo se apropria de dados pessoais de outra pessoa, como nome, CPF, número de cartão de crédito, login e senha, com o objetivo de se passar por ela e realizar ações fraudulentas. Essas ações podem incluir compras online, abertura de contas bancárias, solicitação de empréstimos ou até a prática de crimes em nome da vítima.
FRAUDE DE ANTECIPAÇÃO DE RECURSOS	Tipo de golpe em que o criminoso convence a vítima a pagar antecipadamente uma quantia em dinheiro com a promessa de receber um valor maior posteriormente – como empréstimos, prêmios, heranças ou investimentos falsos. O golpista geralmente utiliza comunicação persuasiva, documentos falsificados e perfis aparentemente legítimos para passar credibilidade e ganhar a confiança da vítima.



PARA MAIS DICAS: [WWW.INSTAGRAM.COM/PROFESSORDIEGOCARVALHO](https://www.instagram.com/professordiegocarvalho)

RESUMO DE CÓDIGOS MALICIOSOS

	VÍRUS	WORM	BOT	TROJAN	SPYWARE	BACKDOOR	ROOTKIT
FORMA DE OBTENÇÃO							
Recebido automaticamente pela rede		X	X				
Recebido por e-mail	X	X	X	X	X		
Baixado de sites na Internet	X	X	X	X	X		
Compartilhamento de arquivos	X	X	X	X	X		
Uso de mídias removíveis infectadas	X	X	X	X	X		
Redes sociais	X	X	X	X	X		
Mensagens instantâneas	X	X	X	X	X		
Inserido por um invasor		X	X	X	X	X	X
Ação de outro código malicioso		X	X	X	X	X	X



FORMA DE INSTALAÇÃO

Execução de um arquivo infectado	X						
Execução explícita do código malicioso		X	X	X	X		
Via execução de outro código malicioso						X	X
Exploração de vulnerabilidades		X	X			X	X

FORMA DE PROPAGAÇÃO

Insere cópia de si próprio em arquivos	X						
Envia cópia de si próprio automaticamente pela rede		X	X				
Envia cópia de si próprio automaticamente por email		X	X				
Não se propaga				X	X	X	X

AÇÕES MALICIOSAS MAIS COMUNS

Altera e/ou remove arquivos	X			X			X
Consome grande quantidade de recursos		X	X				
Furta informações sensíveis			X	X	X		
Instala outros códigos maliciosos		X	X	X			X
Possibilita o retorno do invasor						X	X
Envia <i>spam</i> e <i>phishing</i>			X				
Desfere ataques na Internet		X	X				
Procura se manter escondido	X				X	X	X



QUESTÕES COMENTADAS - AOCP

1. (AOCP / IF-MS - 2025) A segurança na internet é essencial para proteger dispositivos e informações contra ameaças digitais. Em relação aos diferentes tipos de malware, informe se é verdadeiro (V) ou falso (F) o que se afirma a seguir e assinale a alternativa com a sequência correta.

() Phishing é um tipo de malware que se instala em um dispositivo sem o consentimento do usuário, com o objetivo principal de exibir publicidade invasiva.

() Vírus são programas maliciosos projetados para interferir no funcionamento normal de um dispositivo, frequentemente se espalhando para outros dispositivos ao infectar arquivos.

() Ransomware é um tipo de malware que criptografa os dados da vítima, exigindo um pagamento (resgate) para restaurar o acesso a esses dados.

a) F - V - V.

b) V - V - V.

c) V - F - V.

d) V - F - F.

e) F - F - V.

Comentários:

(I) Errado. Phishing não é um malware, mas uma técnica de engenharia social que visa enganar usuários para que revelem informações pessoais.

(II) Correto. Vírus são realmente programas maliciosos que interferem no funcionamento de dispositivos e podem se espalhar por meio de arquivos infectados.

(III) Correto. Ransomware criptografa dados e exige pagamento para que o acesso seja restaurado, caracterizando uma ameaça significativa.

Gabarito: Letra A

2. (AOCP / IF-MS - 2025) O malware refere-se a um código ou aplicativo malicioso projetado para danificar, comprometer ou interromper o funcionamento normal de dispositivos. Quando um sistema é infectado com malware, pode haver roubo de dados, comprometimento de senhas, instalação de outros malwares e perda de informações. Os cavalos de Troia (Trojans) são um tipo de malware que se disfarça de software legítimo para enganar os usuários e induzi-los a baixá-lo e executá-lo. Com base no exposto, assinale a alternativa que NÃO descreve corretamente um cavalo de Troia (Trojan).

a) Um Trojan depende da ação do usuário para ser baixado, geralmente se apresentando como um aplicativo ou arquivo legítimo.



- b) Após ser instalado, um Trojan pode baixar e instalar outros tipos de malware, como vírus e worms.
- c) Um Trojan criptografa os arquivos do dispositivo da vítima e exige um pagamento de resgate para restaurar o acesso aos dados.
- d) Trojans podem ser usados para registrar as teclas digitadas e os sites visitados pelo usuário.
- e) Uma vez instalado, um Trojan pode enviar informações confidenciais, como senhas e histórico de navegação, para um invasor mal-intencionado.

Comentários:

- (a) Correto. Um Trojan realmente depende da ação do usuário para ser baixado, disfarçando-se como um software legítimo;
- (b) Correto. Trojans podem baixar e instalar outros malwares, como vírus e worms, após a instalação;
- (c) Errado. Um Trojan não é especificamente um ransomware; ele pode ter diversas funções, mas não necessariamente criptografa arquivos para exigir resgate;
- (d) Correto. Trojans podem ser utilizados para registrar teclas digitadas e monitorar a atividade do usuário;
- (e) Correto. Trojans podem enviar informações confidenciais, como senhas e histórico de navegação, para invasores.

Gabarito: Letra C

3. (AOCP / UFS - 2024) Malwares são programas maliciosos que podem assumir várias formas e realizar ações prejudiciais nos sistemas. Entre os diferentes tipos de malwares, o "vírus" é um dos mais conhecidos. Assinale a alternativa que apresenta a definição correta do malware "vírus".

- a) É um tipo de malware que se anexa a arquivos ou programas legítimos e se replica quando esses arquivos ou programas são executados.
- b) É um tipo de malware que se disfarça como software legítimo, mas realiza ações maliciosas sem o conhecimento do usuário.
- c) É um programa autônomo que se replica e se espalha para outros computadores em uma rede ou pela internet.
- d) É um malware que registra todas as teclas digitadas em um teclado, capturando informações confidenciais, como senhas e informações de cartão de crédito.



e) Envolve a distribuição de malware por meio de anúncios maliciosos exibidos em sites legítimos.

Comentários:

(a) Correto. Um vírus é um tipo de malware que se anexa a arquivos ou programas legítimos e se replica quando esses arquivos são executados pelo usuário. Ele pode causar danos ao sistema, como corrupção de arquivos e consumo de recursos;

(b) Errado. A descrição corresponde a um Cavalo de Troia (Trojan), que se disfarça como software legítimo para enganar o usuário e realizar ações maliciosas;

(c) Errado. A definição se aplica a um worm, que é um malware autônomo que se replica automaticamente sem a necessidade de um arquivo hospedeiro ou ação do usuário;

(d) Errado. Esse comportamento é típico de um keylogger, um tipo de malware usado para capturar dados digitados, como senhas e informações bancárias;

(e) Errado. Essa técnica é conhecida como malvertising, que utiliza anúncios maliciosos para distribuir malware, mas não é uma característica de vírus especificamente.

Gabarito: Letra A

4. (AOCP / IF-MA - 2023) Utilizando-se dos conceitos de malwares, qual é o nome do programa malicioso capaz de se propagar automaticamente e explorar vulnerabilidades existentes ou falhas em softwares, dispondo de um mecanismo de comunicação com o invasor, permitindo que seu controle seja realizado remotamente?

- a) Worm
- b) Storm
- c) Firewall
- d) Proxy
- e) Bot

Comentários:

(a) Errado. Worms se propagam automaticamente explorando vulnerabilidades, mas não possuem, necessariamente, um mecanismo de comunicação com o invasor para controle remoto;

(b) Errado. Storm não é um tipo de malware, mas pode se referir à Storm Botnet, uma rede de computadores infectados usada para ataques cibernéticos;

(c) Errado. Firewall não é um malware, mas sim um mecanismo de segurança que controla o tráfego de rede para proteger sistemas contra acessos não autorizados;



(d) Errado. Proxy é um servidor intermediário que pode ser usado para segurança, controle de tráfego ou anonimato na navegação, sem relação com malwares;

(e) Correto. Um bot é um programa malicioso que pode se propagar automaticamente e explorar vulnerabilidades. Além disso, ele permite controle remoto por um invasor, geralmente sendo parte de uma botnet, usada para ataques coordenados.

Gabarito: Letra E

5. (AOCP / IF-MA - 2023) Em relação aos softwares maliciosos, assinale a alternativa que apresenta uma característica de um malware classificado como WORM.

a) Configura-se em uma rede composta por inúmeros equipamentos zumbis utilizados para potencializar as ações danosas provenientes de um ataque.

b) Permite que um invasor retorne ao equipamento comprometido, por meio da criação ou modificação de serviços no sistema.

c) Monitora a operação de um computador, coleta e envia as informações coletadas ao invasor.

d) Armazena teclas digitadas por um ou mais usuários no teclado físico de um computador.

e) Propaga-se de forma automatizada pelas redes ao explorar vulnerabilidades nos aplicativos instalados nos computadores, enviando cópias de si mesmo de computador para computador.

Comentários:

(a) Errado. A descrição refere-se a uma botnet, que é uma rede de computadores infectados (zumbis) controlados remotamente para realizar ataques coordenados, como DDoS;

(b) Errado. Essa característica é típica de um backdoor, que permite ao invasor acesso remoto ao sistema comprometido, sem que o usuário perceba;

(c) Errado. O malware que monitora operações do computador e coleta informações sem consentimento é um spyware, usado para espionagem;

(d) Errado. Um keylogger é um software malicioso que armazena as teclas digitadas pelo usuário, sendo usado para roubo de credenciais e senhas;

(e) Correto. Worms são malwares que se propagam automaticamente por redes, explorando vulnerabilidades em sistemas e aplicativos. Eles podem replicar-se sem intervenção do usuário, consumindo recursos e causando lentidão na rede.

Gabarito: Letra E



6. (AOCP / BANESE - 2022) A rede corporativa começou a apresentar lentidão. Os analistas da rede constataram que um tipo bem específico de software malicioso atingiu o ambiente através da rede corporativa, explorando vulnerabilidades encontradas em sistemas operacionais das estações de trabalho e consumindo recursos da rede. Além do que foi relatado, nenhum outro problema foi causado. Pela descrição desse software malicioso, a classificação mais adequada para ele seria

- a) vírus.
- b) cavalo de Troia.
- c) worm.
- d) spyware.
- e) ransomware.

Comentários:

(a) Errado. Vírus normalmente precisa de um arquivo hospedeiro para se espalhar e não se propaga automaticamente pela rede, diferentemente do cenário descrito;

(b) Errado. Cavalos de Troia (Trojans) são malwares que se disfarçam de softwares legítimos para enganar usuários e permitir acesso não autorizado ao sistema, mas não se propagam automaticamente pela rede;

(c) Correto. Worms são malwares autônomos, que se propagam automaticamente pela rede explorando vulnerabilidades em sistemas operacionais. Eles consomem recursos de rede, causando lentidão, sem necessariamente danificar arquivos ou exigir resgates;

(d) Errado. Spyware é um malware usado para espionagem, coletando informações do usuário sem permissão, mas não causa consumo excessivo de recursos de rede como descrito no problema;

(e) Errado. Ransomware criptografa arquivos e exige um pagamento para restaurá-los, mas o problema descrito na questão não menciona bloqueio de dados, apenas lentidão na rede.

Gabarito: Letra C

7. (AOCP / SANESUL - 2021) Assinale a alternativa que apresenta uma característica de malware do tipo ransomware.

- a) Exibição de propagandas para o usuário.
- b) Captura de dados digitados no teclado.
- c) Gravação dos dados exibidos na tela do usuário.
- d) Programa que captura dados bancários e envia ao invasor.
- e) Exige quantia em dinheiro para descriptografar dados do usuário.

Comentários:

(a) Errado. A exibição de propagandas indesejadas é característica de adware, e não de ransomware;



- (b) Errado. A captura de dados digitados no teclado é característica de keyloggers, utilizados para espionagem e roubo de credenciais;
- (c) Errado. A gravação da tela do usuário pode ser feita por spyware, um tipo de malware que coleta informações sem consentimento;
- (d) Errado. Malwares especializados em roubo de dados bancários são conhecidos como trojans bancários, que monitoram atividades financeiras e enviam informações aos atacantes;
- (e) Correto. O ransomware criptografa os arquivos da vítima e exige um pagamento (resgate) para fornecer a chave de descriptografia, bloqueando o acesso aos dados até que o resgate seja pago.

Gabarito: Letra E



QUESTÕES COMENTADAS – MULTIBANCAS

- 1. (CEBRASPE / CNPQ - 2024) Um vírus de computador tem a capacidade de se disseminar automaticamente, sem a necessidade de uma ação humana.**

Comentários:

Os vírus de computador precisam ser executados por um usuário ou programa para se disseminarem. Diferentemente dos worms, que se propagam automaticamente explorando vulnerabilidades de rede, os vírus dependem da interação do usuário para infectar novos sistemas.

Gabarito: Errado

- 2. (CEBRASPE / ITAIPU BINACIONAL - 2024) Quando instalado em uma estação de trabalho sem o conhecimento e consentimento do usuário, um software de keylogger terá a função de**

- a) um antivírus.
- b) registrar as teclas digitadas.
- c) monitorar a disponibilidade do computador.
- d) criptografar conexões HTTP.
- e) propagar-se por meio de dispositivos USB.

Comentários:

(a) Errado. Um antivírus protege contra ameaças, enquanto o keylogger é um software malicioso que registra as teclas digitadas sem o consentimento do usuário;

(b) Correto. O keylogger é um tipo de spyware projetado para capturar e armazenar tudo o que é digitado, incluindo senhas e dados bancários, sem o conhecimento do usuário;

(c) Errado. O keylogger não monitora a disponibilidade do computador, mas sim as entradas de teclado;

(d) Errado. Criptografar conexões HTTP é uma função de protocolos como HTTPS e VPNs, não de um keylogger;

(e) Errado. Embora alguns malwares possam se propagar via USB, a principal função de um keylogger é registrar as teclas digitadas, não a propagação.

Gabarito: Letra B

- 3. (CEBRASPE / ITAIPU BINACIONAL - 2024) Existe uma série de golpes e fraudes que utilizam a Internet como meio de execução; uma delas tem a ação maliciosa de um golpista tentando obter dados pessoais e financeiros, combinando meios técnicos e engenharia social. Esse tipo de fraude é denominado**

- a) scan.
- b) DDoS.
- c) phishing.
- d) brute force.
- e) defacement.



Comentários:

- (a) Errado. Scan refere-se a varreduras de rede para identificar vulnerabilidades, mas não se trata de um golpe de engenharia social para roubo de dados;
- (b) Errado. DDoS (Distributed Denial of Service) é um ataque que sobrecarrega servidores, impedindo o acesso a um serviço, mas não visa capturar dados pessoais;
- (c) Correto. Phishing é uma fraude que usa engenharia social para enganar usuários e obter dados confidenciais, como senhas e informações bancárias, por e-mails, sites falsos ou mensagens enganosas;
- (d) Errado. Brute force é um ataque que tenta adivinhar senhas por tentativa e erro, não envolvendo manipulação direta da vítima como no phishing;
- (e) Errado. Defacement é um ataque que modifica visualmente páginas da web, geralmente para propaganda ou vandalismo digital, sem o objetivo de roubo de dados pessoais.

Gabarito: Letra C

4. (CEBRASPE / MPE-TO - 2024) Hijacker é um tipo de malware que invade o computador e criptografa os dados de forma que o usuário perde o acesso aos próprios dados.

Comentários:

O hijacker é um malware que sequestra configurações do navegador, alterando a página inicial, mecanismos de busca e exibindo anúncios indesejados. Já o malware que criptografa dados e exige resgate é o ransomware.

Gabarito: Errado

5. (CEBRASPE / MPE-TO - 2024) Um tipo muito comum de malware são os chamados worms, programas com capacidade de se replicar, enviando cópias do próprio worm de um computador para outro computador e explorando pontos de vulnerabilidade dos sistemas.

Comentários:

Os worms são malwares que se replicam automaticamente, propagando-se pela rede sem necessidade de ação do usuário. Eles exploram vulnerabilidades em sistemas e podem consumir recursos, degradando o desempenho da rede e dos dispositivos infectados.

Gabarito: Correto

6. (CEBRASPE / APEX - 2024) Determinado software malicioso é conhecido por se propagar automaticamente pela rede de computadores, explorando vulnerabilidades dos sistemas e aplicativos instalados, sendo, inclusive, responsável por consumir muitos recursos, chegando até a afetar o desempenho da rede. Esse é um software do tipo:

- a) ransomware.
- b) vírus.
- c) botnet.
- d) worm



Comentários:

- (a) Errado. O ransomware sequestra dados ao criptografá-los e exige um resgate, mas não se propaga automaticamente pela rede explorando vulnerabilidades;
- (b) Errado. O vírus precisa ser executado por um usuário ou programa para se espalhar, diferentemente do malware descrito, que se propaga automaticamente;
- (c) Errado. Botnet refere-se a uma rede de dispositivos infectados controlados remotamente, mas não descreve um malware que se espalha automaticamente explorando falhas;
- (d) Correto. O worm se propaga automaticamente pela rede, explorando vulnerabilidades em sistemas e aplicativos, podendo consumir muitos recursos e afetar o desempenho da rede.

Gabarito: Letra D

- 7. (CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) O alerta a seguir, apresentado ao se navegar em um sítio eletrônico, se refere a um vírus, uma vez que todo software malicioso é um vírus que executa ações danosas e atividades maliciosas no computador.**



Comentários:

Nem todo software malicioso é um vírus. O termo correto é malware, que engloba várias categorias, como worms, trojans, spyware e ransomware. O alerta indica um site que pode instalar programas maliciosos, mas isso não significa que seja um vírus especificamente.

Gabarito: Errado

- 8. (CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) Em grupos de discussão e redes sociais, não há preocupação com segurança, pois eles são sítios não organizacionais.**

Comentários:

A segurança da informação deve ser uma preocupação em qualquer ambiente digital, incluindo grupos de discussão e redes sociais. Ataques como phishing, engenharia social e vazamento de dados podem ocorrer nesses espaços, independentemente de serem organizacionais ou não.

Gabarito: Errado



9. (CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) Keylogger é um tipo de spyware projetado para monitorar as atividades de um sistema por meio da captura e do armazenamento das teclas digitadas.

Comentários:

O keylogger é um tipo de spyware que registra as teclas digitadas pelo usuário, capturando informações sensíveis, como senhas e dados bancários. Ele pode ser usado para espionagem e roubo de credenciais sem o conhecimento da vítima.

Gabarito: Correto

10.(CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) O trojan é projetado para espionar o dono do dispositivo, que não autorizou a sua instalação e não sabe que tal código espião está instalado em seu equipamento, permitindo que o agente malicioso receba informações confidenciais coletadas

Comentários:

Embora um trojan possa incluir funções de espionagem, seu objetivo principal é agir como um programa aparentemente legítimo enquanto executa ações maliciosas. O malware especializado em espionagem sem consentimento é o spyware.

Gabarito: Errado

11.(FCC / AL-AP - 2020) Considere que, por hipótese, determinada empresa do ramo de soluções para redes de computadores está negociando com uma empresa-cliente a instalação de um software que proteja contra o sequestro de dados, situação que ocorre quando um computador é invadido por um malware que criptografa arquivos do disco da máquina e exige um resgate em dinheiro virtual ou físico para descriptografar e liberar os dados para uso novamente. Tendo em vista tais dados, esse software em negociação tem, a princípio, a função de

- a) antispam.
- b) antispware.
- c) detecção de intrusão.
- d) defesa de ransomware.
- e) filtro de rede local com lista de acesso.

Comentários:

Malware que criptografa arquivos do disco da máquina e exige um resgate em dinheiro virtual ou físico para descriptografar e liberar os dados para uso novamente - trata-se de um ransomware. Logo, o software que deve proteger contra esse malware tem a função de defesa de ransomware.

Gabarito: Letra D

12.(FCC / TJ-MA - 2019) Não há garantia de que uma vítima possa interromper um ataque de ransomware e recuperar seus dados. No entanto, alguns métodos podem funcionar, como, por exemplo,



- a) reiniciar o computador no modo de segurança e remover o arquivo ransomware.dat do computador.
- b) reiniciar o computador no modo de segurança, instalar e executar um antivírus e restaurar o computador a um estado anterior não infectado.
- c) reiniciar o computador a partir de um pen drive de boot do sistema operacional.
- d) executar um antivírus imediatamente após a mensagem de resgate dos dados ser exibida.
- e) usar o comando mbr, no prompt de comando do Windows, para reconstruir o registro de pastas e arquivos do disco.

Comentários:

(a) Errado, a remoção de um arquivo não teria qualquer efeito; (b) Correto, uma das poucas maneiras de tentar se proteger contra ataques de ransomwares é por meio da restauração do computador a um estado anterior não infectado por meio de um ponto de restauração ou por meio de um backup; (c) Errado, reiniciar por meio de um pendrive não teria qualquer efeito; (d) Errado, antivírus após a infecção não teria qualquer efeito; (e) Errado, esse comando sequer existe no prompt de comando do Windows.

Gabarito: Letra B

13.(FCC / TJ-MA - 2019) A tabela abaixo indica a forma de propagação de 5 malwares.

Como o <i>malware</i> se propaga	I	II	III	IV	V
Insere cópia de si próprio em arquivos	✓				
Envia cópia de si próprio automaticamente pela rede		✓			
Envia cópia de si próprio automaticamente por e-mail		✓			
Não se propaga			✓	✓	✓

De acordo com a tabela, os tipos de malwares numerados de I a V são, correta e respectivamente,

- a) I - Vírus
 - II - Bot
 - III - Spyware
 - IV - Backdoor
 - V - Rootkit
- b) I - Backdoor
 - II - Rootkit
 - III - Botnet
 - IV - Phishing
 - V - Worm
- c) I - Adware
 - II - Bot
 - III - Worm
 - IV - Phishing
 - V - Spyware
- d) I - Botnet



- II - Pharming
- III - Rootkit
- IV - Worm
- V - Backdoor

- e) I - Rootkit
- II - Backdoor
 - III - Pharming
 - IV - Vírus
 - V - Worm

Comentários:

- Insere cópias de si mesmo em arquivos: apenas Vírus;
- Envia cópia de si próprio automaticamente pela rede: apenas Bot e o Worm;
- Envia cópia de si próprio automaticamente por e-mail: Bot e o Worm;
- Não se propagam: Trojan, Spyware, Backdoor e Rootkit.

Logo, temos que: (I) Vírus; (II) Bot; (III) Spyware; (IV) Backdoor; (V) Rootkit.

Gabarito: Letra A

14.(FCC / SANASA Campinas - 2019) Um intruso, com o objetivo de desativar o destino dos dados ao invés de roubá-los, entrou em centenas de computadores em diversos lugares do mundo e depois comandou todos esses computadores para realizarem um ataque ao mesmo alvo ao mesmo tempo. Essa estratégia tem um grande poder de fogo e reduz a chance de detecção, pois os pacotes vêm de inúmeras máquinas pertencentes a usuários insuspeitos. Um ataque desse tipo é chamado de:

- a) DDoS.
- b) IP spoofing.
- c) Phishing Scam.
- d) BDoS.
- e) Blood.

Comentários:

Intruso cujo objetivo de desativar o destino dos dados (Ex: Servidor); entrou em centenas de computadores distribuídos; comandou um ataque massivo e simultâneo - todas são características de um DDoS (Distributed Denial of Service). Nenhuma das outras opções faz qualquer sentido!

Gabarito: Letra A

15.(FCC / TRF - 4ª REGIÃO - 2019) Um Técnico Judiciário está analisando as características de diversas pragas virtuais (malwares), para proceder à instalação de antivírus adequado. Dentre as características específicas por ele analisadas, estão:

- I. Programa que, além de executar as funções para as quais foi aparentemente projetado, também executa outras funções, normalmente maliciosas, e sem o conhecimento do usuário. Um exemplo é um programa que se recebe ou se obtém de sites na internet e que parece ser inofensivo. Tal programa geralmente consiste em um único arquivo e necessita ser explicitamente executado para que seja instalado no computador.



II. Programa que permite o retorno de um invasor a um computador comprometido, por meio da inclusão de serviços criados ou modificados para este fim. Pode ser incluído pela ação de outros códigos maliciosos, que tenham previamente infectado o computador, ou por atacantes que exploram vulnerabilidades existentes nos programas instalados no computador. Após incluído, ele é usado para assegurar o acesso futuro ao computador comprometido, permitindo que ele seja acessado remotamente, sem que haja necessidade de recorrer novamente aos métodos utilizados na realização da invasão ou infecção e, na maioria dos casos, sem que seja notado.

III. Programa que torna inacessíveis os dados armazenados em um equipamento, geralmente usando criptografia. O atacante exige pagamento de resgate para restabelecer o acesso ao usuário.

As descrições acima são, correta e respectivamente, correspondentes a:

- a) bot, rootkit e cavalo de troia (trojan).
- b) cavalo de troia (trojan), backdoor e ransomware.
- c) worm, backdoor e vírus.
- d) vírus, spyware e rootkit.
- e) spyware, cavalo de troia (trojan) e ransomware.

Comentários:

(I) Além de executar as funções para as quais foi aparentemente projetado, também executa outras funções, normalmente maliciosas? Trata-se do Cavalo de Troia (Trojan);

(II) Programa que permite o retorno de um invasor a um computador comprometido, por meio da inclusão de serviços criados ou modificados para este fim? Trata-se do Backdoor;

(III) Programa que torna inacessíveis os dados armazenados em um equipamento, geralmente usando criptografia, exigindo pagamento de resgate? Trata-se do Ransomware.

Gabarito: Letra B

16.(FCC / SEMEF Manaus - AM - 2019) Um Assistente de TI identificou o malware que atacou o seu computador como sendo do tipo ransomware, pois apresentava como principal característica:

- a) o pedido de resgate para liberar o acesso aos arquivos.
- b) mostrar propagandas continuamente abrindo janelas do navegador web.
- c) o controle do computador de forma remota.
- d) a modificação dos arquivos do sistema operacional para anular o seu uso.
- e) o uso de muitos recursos deixando o computador lento.

Comentários:

(a) Correto, essa é uma característica do ransomware, isto é, pedir um resgate para liberar o acesso aos dados; (b) Errado, essa é a característica de um adware; (c) Errado, essa é a característica de um bot; (d) Errado, essa é a característica de alguns tipos de vírus; (e) Errado, essa é a característica de um worm.

Gabarito: Letra A

17.(FCC / SEFAZ-BA - 2019) Um Auditor recebeu uma mensagem de e-mail, aparentemente de seu banco, com um link para verificar a existência de uma dívida de cartão de crédito não paga.



Preocupado com a situação, clicou no link e forneceu os dados de seu cartão de crédito para pagar a suposta conta. Dias depois percebeu na fatura do seu cartão que foram feitas diversas compras online em sites de comércio eletrônico na Internet. A situação descrita permite concluir que esse Auditor foi vítima de:

- a) rot.
- b) backdoor.
- c) worm.
- d) phishing.
- e) ransomware.

Comentários:

Esse é um exemplo clássico de um Golpe de Phishing! Uma das formas desse golpe ocorre por meio do envio de mensagens eletrônicas que tentam se passar pela comunicação oficial de uma instituição conhecida, como um banco, uma empresa ou um site popular.

Gabarito: Letra D

18.(FCC / RIOPRETOPREV - 2019) O computador de um usuário foi infectado por um ransomware, um tipo de malware que:

- a) torna inacessíveis os dados armazenados no computador, geralmente usando criptografia, e exige pagamento de resgate (via bitcoins) para restabelecer o acesso ao usuário.
- b) após identificar potenciais computadores alvos, efetua cópias de si mesmo e tenta enviá-las para estes computadores, por e-mail, chat etc.
- c) monitora e captura informações referentes à navegação ou digitação do usuário, e envia estas informações ao atacante.
- d) assegura o acesso futuro do atacante ao computador comprometido, permitindo que ele seja acessado remotamente por meio do protocolo Telnet.
- e) torna o computador um zumbi, sendo controlado remotamente e desferindo automaticamente ataques de negação de serviço a redes e servidores determinados pelo atacante.

Comentários:

(a) Correto, essa definição é realmente de um ransomware; (b) Errado, essa definição é de um worm; (c) Errado, essa definição é de um spyware; (d) Errado, essa definição é de um backdoor; (e) Errado, essa definição é de um bot.

Gabarito: Letra A

19.(FCC / SABESP - 2019) A Sabesp disponibiliza o e-mail canaldedenuncia@sabesp.com.br para que ocorrências de fraudes e transgressões diversas à política de segurança das informações possam ser denunciadas. Considere, hipoteticamente, que uma denúncia enviada descreveu que um certo funcionário estava fazendo ligações internas se passando por alguém da equipe de suporte técnico de TI solicitando determinadas informações para resolver um suposto problema da Sabesp. Conclui-se, corretamente, que a denúncia se configura em um ataque do tipo:



- a) Engenharia Social.
- b) Pharming.
- c) Advance fee fraud.
- d) Spyware.
- e) Negação de Serviço.

Comentários:

Uma pessoa fazendo ligações internas se passando por alguém da equipe de suporte técnico de tecnologia da informação solicitando determinadas informações é um cenário típico de engenharia social. Essa técnica busca obter informações explorando as vulnerabilidades humanas e sociais dos funcionários da organização e, dessa forma, enganar pessoas assumindo-se uma falsa identidade a fim de que elas revelem informações restritas.

Gabarito: Letra A

20.(FCC / SANASA Campinas - 2019) Considere as características de pragas virtuais, abaixo.

I. Não se propaga por meio da inclusão de cópias de si mesmo em outros programas ou arquivos, mas sim pela execução direta de suas cópias ou pela exploração automática de vulnerabilidades existentes em programas instalados em computadores.

II. É um programa ou parte de um programa de computador, normalmente malicioso, que se propaga inserindo cópias de si mesmo e se tornando parte de outros programas e arquivos. Para que possa se tornar ativo e dar continuidade ao processo de infecção, ela depende da execução do programa ou arquivo hospedeiro, ou seja, para que o seu computador seja infectado é preciso que um programa já infectado seja executado.

III. É um programa projetado para monitorar as atividades de um sistema e enviar as informações coletadas para terceiros. Pode ser usado tanto de forma legítima quanto maliciosa, dependendo de como é instalado, das ações realizadas, do tipo de informação monitorada e do uso que é feito por quem recebe as informações coletadas.

Os itens I, II e III descrevem corretamente um:

- a) worm – vírus e spyware.
- b) botnet – trojan e rootkit
- c) backdoor – worm e adware.
- d) vírus – spyware e botnet.
- e) trojan – vírus e rootkit.

Comentários:

(I) Essa é a característica fundamental de um worm; (II) Essa é a característica fundamental de um vírus; (III) Essa é a característica fundamental de um spyware.

Gabarito: Letra A

21.(FGV / AGENERSA - RJ - 2023) Sobre vírus e worms no contexto de pragas virtuais, analise as afirmativas a seguir.



- I. Worms não precisam se alojar em outros programas para se espalhar.
II. Vírus e worms agem basicamente enganando os usuários, por meio de e-mails e sites falsos, de forma a obter informações, senhas, dados pessoais e números de contas e cartões de crédito. III. Vírus e worms são capazes de replicarem a si mesmos.

Está correto o que se afirma em

- a) I, apenas.
- b) I e II, apenas.
- c) I e III, apenas.
- d) II e III, apenas.
- e) I, II e III.

Comentários:

(I) Correto, eles exploram vulnerabilidades de rede e se replicam de forma independente; (II) Errado, isso seria phishing; (III) Correto, ambos são capazes de se replicar e criar cópias de si mesmos para se espalhar e infectar outros sistemas.

Gabarito: Letra C

22.(FGV / TCE-TO - 2022) João acessou a sua conta bancária digitando a senha no seguinte teclado virtual:

6 ou 3	0 ou 9	5 ou 1
4 ou 2	8 ou 7	<

Alguns dias depois, João percebeu que sua conta foi acessada por terceiros.

O ataque spyware que João sofreu foi:

- a) Adware;
- b) Rootkit;
- c) Backdoor;
- d) Keylogger;
- e) Screenlogger.

Comentários:

Se a senha foi digitada em um teclado virtual e mesmo assim a conta foi acessada por terceiros, então João sofreu um ataque de screenlogger.

Gabarito: Letra E

23.(FGV / Senado Federal - Policial Legislativo - 2022) Sobre a natureza dos ataques Dos e DDoS em redes de computadores, assinale a afirmativa correta.

- a) Enviam numerosos e-mails com links falsos, direcionados para programas e downloads maliciosos.
- b) Interceptam a comunicação em locais públicos em busca de informações sobre logins/senhas, dentre outras.



- c) Tentam assumir remotamente o controle de outros computadores por meio de vulnerabilidades no Firewall.
- d) Tentam sobrecarregar um ou mais servidores de modo a impedir o funcionamento normal os serviços.
- e) Usam a “força bruta” para descobrir, por tentativas e erro, logins/senhas para invadir contas e acessar dados sensíveis.

Comentários:

DoS/DDoS são ataques de negação de serviço, isto é, ataques que sobrecarregam recursos com o intuito de interromper atividades legítimas. Em outras palavras, tentam sobrecarregar um ou mais servidores de modo a impedir o funcionamento normal os serviços.

Gabarito: Letra D

24.(FGV / MPE-GO - 2021) João acessou seu computador e recebeu a seguinte mensagem:

Todos os seus arquivos foram criptografados.
Realize o pagamento no link indicado e receba a
senha para descriptografar.

A medida de proteção que João deve tomar é instalar um programa que o proteja de ataques do tipo:

- a) Adware.
- b) Keylogger.
- c) Ransomware.
- d) Vírus.
- e) Backdoor.

Comentários:

Arquivos sendo criptografados e o criminoso exigindo um resgate por meio de um pagamento financeiro para enviar a senha que descriptografa os arquivos atacados são características de um malware chamado **ransomware** (ransom = resgate).

Gabarito: Letra C

25.(FGV / TJDF - 2022) João administra uma rede de computadores com muitos sistemas de informação cujas operações são de acesso restrito, pois contém informações confidenciais. Nos últimos meses, João recebeu diversos relatos de ataques de keylogger e screenlog.

Diante desse cenário, João deve proteger a sua rede de ataques do tipo:

- a) worm;
- b) spyware;
- c) botnet;
- d) zumbi;
- e) remote access trojan.



Comentários:

Keyloggers e Screenloggers são tipos de Spywares! Logo, diante desse cenário, João deve proteger a sua rede de ataques do tipo spyware (a redação é um pouco esquisita, dado que spyware é um malware e, não, um golpe).

Gabarito: Letra B

26.(FGV / SEFAZ-BA - 2022) Com relação às políticas de segurança da informação, analise as afirmativas a seguir.

I. Política de senhas: define o conjunto de regras do uso de senhas em uma rede, bem como recursos computacionais que fazem parte na mesma. Entre as informações contidas na política estão a periodicidade da troca de senha, o tamanho mínimo e máximo e a composição.

II. Política de backup: define regras específicas da realização das cópias de segurança, como os tipos de mídia a serem utilizados no backup, a frequência de execução (diária, semanal, mensal) e o período de retenção das cópias.

III. Política de privacidade online: são regras sociais que não contemplam como as informações pessoais serão tratadas, sejam elas de usuários, clientes, funcionários e fornecedores.

Está correto o que se afirma em:

- a) I, somente.
- b) I e II, somente.
- c) I e III, somente.
- d) II e III, somente.
- e) I, II e III.

Comentários:

A política de segurança define os direitos e as responsabilidades de cada um em relação à segurança dos recursos computacionais que utiliza e as penalidades às quais está sujeito, caso não a cumpra. É considerada como um importante mecanismo de segurança, tanto para as instituições como para os usuários, pois com ela é possível deixar claro o comportamento esperado de cada um. Desta forma, casos de mau comportamento, que estejam previstos na política, podem ser tratados de forma adequada pelas partes envolvidas. A política de segurança pode conter outras políticas específicas, como:

(I) Política de senhas: define as regras sobre o uso de senhas nos recursos computacionais, como tamanho mínimo e máximo, regra de formação e periodicidade de troca.

(II) Política de backup: define as regras sobre a realização de cópias de segurança, como tipo de mídia utilizada, período de retenção e frequência de execução.

(III) Política de privacidade: define como são tratadas as informações pessoais, sejam elas de clientes, usuários ou funcionários.

Logo, apenas o terceiro item está errado, dado que ela contempla – sim – como as informações pessoais serão tratadas, sejam elas de usuários, clientes, funcionários e fornecedores.

Gabarito: Letra B



27.(FGV / TJDF - 2022) Marina recebeu uma ligação de um suposto funcionário que dizia estar fazendo uma pesquisa sanitária sobre uma pandemia. Marina passou suas informações pessoais e profissionais, que permitiram ao falso funcionário acessar um sistema com suas credenciais.

A técnica empregada pelo falso funcionário para conseguir as informações de Marina é:

- a) *poisoning*
- b) *flooding*;
- c) engenharia social;
- d) suborno;
- e)

sniffer.

Comentários:

A questão trata de Engenharia Social, que é uma técnica empregada por criminosos virtuais para induzir usuários desavisados a enviar dados confidenciais, infectar seus computadores com malware ou abrir links para sites infectados. Além disso, os hackers podem tentar explorar a falta de conhecimento do usuário.

Gabarito: Letra C

28.(FGV / TJDF - 2022) Carlos recebeu um e-mail que parecia pertencer ao seu banco e, sem perceber, baixou e instalou um software malicioso no seu computador. A partir desse software, um criminoso cibernético passou a ter o controle do computador de Carlos.

O software malicioso instalado no computador de Carlos é:

- a) *phishing*;
- b) DoS
- c)
- d) *rootkit*;
- e) *sandbox*.

ransomware;

Comentários:

(a) Errado, isso é um golpe e, não, um malware; (b) Errado, isso é um ataque e, não, um malware; (c) Errado, esse malware é responsável por criptografar dados e cobrar um valor pelo seu resgate; (d) Correto, esse malware realmente permite que o criminoso cibernético obtenha acesso privilegiado sobre o computador do usuário; (e) Errado, isso é uma prática de isolar um ambiente em uma rede.

Gabarito: Letra D

29.(FGV / TJDF - 2022) Marcelo está elaborando a política de segurança em seu órgão e incluiu orientações sobre criação de senhas fortes para acesso aos sistemas, principalmente aqueles acessados pela internet. A orientação do Marcelo visa proteger seus usuários contra ataques de hackers que utilizam software automático para descobrir senhas fracas.

A técnica para obtenção de senhas da qual Marcelo está tentando proteger seus usuários é:

- a) *man-in-the-middle*;
- b) *brute force*;
- c) *backdoors*;



- d) *session hijacking*;
- e) XXS.

Comentários:

A técnica para obtenção de senhas bastante útil para descobrir senhas fracas (Ex: senhas pequenas, somente com números, sem caracteres especiais, etc) comumente por meio de uma estratégia de tentativa e erro é chamada de Técnica de Força Bruta (Brute Force).

Gabarito: Letra B

30.(FGV / SEFAZ-BA - 2022) O ataque digital que tem como objetivo capturar informações sensíveis por meio de fraudes eletrônicas e que se utiliza de pretextos falsos, com o intuito de receber informações sensíveis dos usuários, e que ocorre com mais frequência por meio do envio de e-mails e páginas web falsas, denomina-se:

- a) *IP spoofing*.
- b) *pharming*.
- c) *fakenews*.
- d) *phishing*.
- e) *toolkit*.

Comentários:

Esse é o típico caso de *phishing*: o atacante envia geralmente um e-mail com pretextos falsos com um link que redireciona para uma página falsa em que ele captura informações sensíveis do usuário. Lembrando que o IP Spoofing é basicamente um mascaramento do endereço IP verdadeiro; Pharming é um tipo de phishing que altera o endereço de uma página no servidor DNS; fakenews é um tipo de hoax; e toolkit não tem nenhum significado dentro desse contexto.

Gabarito: Letra D

31.(CESGRANRIO / AgeRIO - 2023) Os vírus de computador existem há muitas décadas, mas foi com o advento das redes de computadores, em especial da Internet, que seu poder de disseminação aumentou exponencialmente. Esses vírus podem, por exemplo, apagar todos os arquivos de um computador. Um vírus de computador é normalmente executado quando uma pessoa, ao utilizar sua estação de trabalho,

- a) abre com o programa bloco de notas um arquivo do tipo texto infectado com um vírus.
- b) envia uma mensagem de correio eletrônico com vírus.
- c) escuta uma música no formato MP4 infectada com um vírus.
- d) executa um programa infectado por um vírus.
- e) visualiza uma foto em formato JPG infectada com um vírus.

Comentários:

(a) Errado. Abrir um arquivo de texto simples (.txt) com o Bloco de Notas geralmente não executa vírus. O Bloco de Notas é um editor de texto que não interpreta ou executa códigos, tornando-o seguro para visualizar o conteúdo de arquivos de texto, mesmo que estejam infectados. O vírus não seria ativado apenas pela visualização do texto.



(b) Errado. Enviar uma mensagem de correio eletrônico com um vírus não executa o vírus na máquina do remetente. A ameaça se concretiza quando o destinatário da mensagem executa o arquivo infectado anexado ao email.

(c) Errado. Escutar uma música no formato MP4 infectada com um vírus, por si só, geralmente não resulta na execução do vírus. Embora arquivos multimídia possam ser um vetor para a disseminação de malware, a simples reprodução de um arquivo de música ou vídeo não é normalmente suficiente para ativar um vírus.

(d) Correto. Executar um programa infectado por um vírus é uma das formas mais comuns de ativação de vírus em computadores. Ao executar o programa, o código malicioso contido nele é ativado, podendo causar os danos para os quais foi programado.

(e) Errado. Visualizar uma foto em formato JPG infectada com um vírus, assim como no caso do arquivo MP4, normalmente não ativa o vírus. Embora existam técnicas sofisticadas que podem embutir código malicioso em arquivos de imagem, a simples visualização desses arquivos raramente é suficiente para ativar um vírus.

Gabarito: Letra D

32.(CESGRANRIO / BASA - 2022) Códigos maliciosos (malware) são programas desenvolvidos para executar ações danosas e atividades maliciosas em uma grande diversidade de equipamentos. Dentre os vários tipos de malware, há um programa capaz de se propagar automaticamente pelas redes, explorando vulnerabilidades nos programas instalados e enviando cópias de si mesmo de equipamento para equipamento. Esse programa é o:

- a) backdoor
- b) spyware
- c) rootkit
- d) keylogger
- e) worm

Comentários:

(a) Errado. Um backdoor é um método de burlar os procedimentos normais de autenticação de um sistema de computadores. Embora seja um tipo de malware, ele não se propaga automaticamente através de redes.

(b) Errado. Spyware é um software que recolhe informações de um computador sem o consentimento do usuário, frequentemente para fins publicitários ou de espionagem. Ele também não se propaga automaticamente.

(c) Errado. Rootkit é um conjunto de programas e técnicas que esconde a presença de malware no sistema e concede acesso privilegiado ao invasor. Ele não é caracterizado pela propagação automática.

(d) Errado. Keylogger é um tipo de software malicioso que grava as teclas digitadas pelo usuário, capturando diversas informações sensíveis, como senhas. Ele não se propaga automaticamente por redes.

(e) Correto. Worm, ou verme em português, é um tipo de malware que se caracteriza por sua capacidade de se propagar automaticamente através de redes, enviando cópias de si mesmo de um equipamento para outro, geralmente explorando vulnerabilidades em softwares.



Gabarito: Letra E

33.(CESGRANRIO / AgeRIO - 2023) Os vírus de computador existem há muitas décadas, mas foi com o advento das redes de computadores, em especial da Internet, que seu poder de disseminação aumentou exponencialmente. Esses vírus podem, por exemplo, apagar todos os arquivos de um computador. Um vírus de computador é normalmente executado quando uma pessoa, ao utilizar sua estação de trabalho,

- a) abre com o programa bloco de notas um arquivo do tipo texto infectado com um vírus.
- b) envia uma mensagem de correio eletrônico com vírus.
- c) escuta uma música no formato MP4 infectada com um vírus.
- d) executa um programa infectado por um vírus.
- e) visualiza uma foto em formato JPG infectada com um vírus.

Comentários:

(a) Errado. Abrir um arquivo de texto simples (.txt) com o Bloco de Notas geralmente não executa vírus. O Bloco de Notas é um editor de texto que não interpreta ou executa códigos, tornando-o seguro para visualizar o conteúdo de arquivos de texto, mesmo que estejam infectados. O vírus não seria ativado apenas pela visualização do texto.

(b) Errado. Enviar uma mensagem de correio eletrônico com um vírus não executa o vírus na máquina do remetente. A ameaça se concretiza quando o destinatário da mensagem executa o arquivo infectado anexado ao email.

(c) Errado. Escutar uma música no formato MP4 infectada com um vírus, por si só, geralmente não resulta na execução do vírus. Embora arquivos multimídia possam ser um vetor para a disseminação de malware, a simples reprodução de um arquivo de música ou vídeo não é normalmente suficiente para ativar um vírus.

(d) Correto. Executar um programa infectado por um vírus é uma das formas mais comuns de ativação de vírus em computadores. Ao executar o programa, o código malicioso contido nele é ativado, podendo causar os danos para os quais foi programado.

(e) Errado. Visualizar uma foto em formato JPG infectada com um vírus, assim como no caso do arquivo MP4, normalmente não ativa o vírus. Embora existam técnicas sofisticadas que podem embutir código malicioso em arquivos de imagem, a simples visualização desses arquivos raramente é suficiente para ativar um vírus.

Gabarito: Letra D

34.(CESGRANRIO / BB - 2021) Muitos códigos maliciosos aproveitam-se de um recurso do Windows 10 que possibilita a execução de um programa presente em um dispositivo de armazenamento USB imediatamente após a sua conexão ao computador. Esse recurso, que pode ser desativado, é conhecido como:

- a) inicialização automática.
- b) execução automática.
- c) reprodução automática.
- d) atualização automática.
- e) configuração automática.



Comentários:

O recurso que permite a execução imediata de um programa presente em um dispositivo USB após a sua conexão ao computador (plug & play) é chamado de Reprodução Automática. Ele realmente pode ser desativado para impedir a ação de malwares – aliás, esse é o padrão atualmente.

Gabarito: Letra C

35.(CESGRANRIO / BB - 2021) Os bancos investem em recursos de segurança para minimizar os riscos de fraude nas operações bancárias através de Internet Banking. Os usuários, porém, precisam estar atentos aos golpistas que procuram persuadir vítimas em potencial a acessar sites falsos e a fornecer informações sensíveis. Esse ataque é conhecido como:

- a) botnet.
- b) injection.
- c) spyware.
- d) phishing.
- e) ransomware.

Comentários:

(a) Errado. Botnet refere-se a uma rede de computadores infectados que são controlados por um atacante, geralmente usados para lançar ataques em larga escala, como ataques de negação de serviço, e não estão diretamente relacionados ao descrito no enunciado.

(b) Errado. Injection, como SQL Injection, é uma técnica de ataque que envolve a inserção de código malicioso em programas ou sistemas para explorar vulnerabilidades, o que não se aplica ao cenário descrito.

(c) Errado. Spyware refere-se basicamente a um tipo de malware projetado para coletar informações do usuário de maneira furtiva, sem necessariamente envolver a indução do usuário a acessar sites falsos.

(d) Correto. Phishing é o termo que descreve exatamente o cenário descrito: ataques em que os golpistas persuadem as vítimas a acessar sites falsos e fornecer informações confidenciais, como detalhes de login bancário.

(e) Errado. Ransomware é um tipo de malware que restringe o acesso ao sistema infectado e exige um resgate para que o acesso possa ser restabelecido – não tem nenhuma relação com golpistas procurando vítimas em potencial para acessar sites falsos.

Gabarito: Letra D

36.(CESGRANRIO / PETROBRAS - 2009) Os itens a seguir relacionam-se corretamente à Internet, EXCETO:

- a) Phishing é uma técnica usada para induzir usuários de computador a revelar informações pessoais ou financeiras, como uma senha de conta bancária.
- b) Com o Microsoft Word, é possível inserir controles de formulário HTML em uma página da Web para criar formulários de coleta ou fornecimento de dados.



- c) Os vírus de e-mail são anexados às mensagens enviadas e o firewall, ao determinar o conteúdo da mensagem, pode, portanto, proteger o computador contra esses tipos de vírus.
- d) World Wide Web é uma rede de computadores na Internet que fornece informação em forma de hipertexto, podendo usar um software chamado browser para descarregar essas informações de servidores de sites e mostrá-las na tela do usuário.
- e) Um upload consiste em se fazer uma cópia de um arquivo de um computador para algum servidor na Internet

Comentários:

Firewall é um hardware e/ou software que controla o tráfego em uma rede – ele não determina o conteúdo de mensagens nem protege computadores contra vírus de e-mail. Todos os outros itens da questão estão perfeitos!

Gabarito: Letra C

37.(CESGRANRIO / UNIRIO - 2016) Os responsáveis por procedimentos de Segurança da Informação devem-se preocupar com usuários mal intencionados, muitas vezes responsáveis por geração de prejuízos empresariais disseminando malwares, roubando senhas ou realizando outra ação qualquer de invasão dos sistemas da empresa. Um exemplo típico é o programador competente, mas mau caráter, que produz programa malicioso capaz de propagar-se automaticamente pela rede de computadores da empresa em que trabalha, por meio de cópias de computador para computador, provocando, por exemplo, lentidão na rede, desaparecimento de arquivos, etc. Os males que esse tipo de programa produz ainda seriam mais graves se dispusesse, como outros malwares, de mecanismos de comunicação que proporcionassem seu controle remoto pelo agente invasor. Esse tipo de programa malicioso é conhecido como:

- a) Adware
- b) Spyware
- c) Keylogger
- d) Vírus
- e) Worm

Comentários:

(a) Errado, adware não causa lentidão na rede nem se propaga automaticamente; (b) Errado, spyware não causa lentidão na rede nem se propaga automaticamente; (c) Errado, keylogger não causa lentidão na rede nem se propaga automaticamente; (d) Errado, vírus não causa lentidão na rede nem se propaga automaticamente – suas ações maliciosas mais comuns são alterar e/ou remover arquivos em geral de forma escondida; (e) Correto, worm pode causar lentidão na rede devido ao consumo excessivo de recursos além de se propagar automaticamente.

Gabarito: Letra E

38.(CESGRANRIO / ANP - 2016) Uma hacker ameaçou divulgar na Web informações sigilosas de uma empresa após ter conseguido acesso a seus sistemas de informação. Para conseguir o acesso, ela telefonou para uma das secretárias da diretoria, passando-se por esposa de um dos diretores. Em seguida, ela disse à secretária que seu marido tinha sofrido um acidente e estava hospitalizado. Porém, antes de ficar inconsciente, o diretor lhe havia pedido que entrasse em



contato com a empresa a fim de que uma de suas secretárias solicitasse a mudança do seu login e da sua senha, pois ele havia perdido sua agenda no acidente e temia que alguém pudesse invadir os sistemas da empresa, uma vez que esses dados, por descuido seu, estavam anotados na agenda perdida. Em seguida, a suposta esposa forneceu os novos login e senha à secretária. Esse tipo de ataque para obtenção de informações é chamado de:

- a) informações livres
- b) engenharia social
- c) varredura de vulnerabilidades
- d) dumpster diving
- e) ataque físico

Comentários:

(a) Errado. Informações Livres é uma técnica de análise de informações que podem ser obtidas livremente na internet sem a necessidade de ações intrusivas; (b) Correto. Engenharia Social é uma técnica de obtenção de informações explorando vulnerabilidades humanas e sociais dos funcionários de uma organização; (c) Errado. Varredura de Vulnerabilidades é uma técnica de envio de tipos de pacotes com o objetivo de obter informações relevantes para um ataque sobre um computador ou uma rede; (d) Errado. Dumpster Diving é uma técnica de vasculhar o lixo (sim, lixo mesmo) de empresas e pessoas com o objetivo de encontrar algo de valor; (e) Errado. Ataque Físico é basicamente o roubo de equipamentos ou dispositivos de armazenamento realizado diretamente em uma organização.

Gabarito: Letra B

39.(CESGRANRIO / BB - 2015) Os escriturários de uma agência foram chamados para uma reunião com um profissional da área de segurança da informação de um banco. O objetivo dessa reunião era informá-los de que houve uma falha nos procedimentos de segurança da rede de computadores da agência, o que permitiu a propagação de um programa malicioso bastante perigoso. Durante a reunião, o profissional de segurança disse que o programa em questão permite monitorar a movimentação do mouse por sobre a tela de uma aplicação bancária, com o objetivo de descobrir a senha digitada por um usuário que esteja usando um teclado virtual.

Ele completou sua explanação dizendo que esse tipo de código malicioso é chamado de:

- a) vírus
- b) trojan clicker
- c) spyware
- d) botnet
- e) trojan backdoor

Comentários:

Permite monitorar a movimentação do mouse sobre a tela de uma aplicação bancária? Busca descobrir a senha digitada por um usuário que esteja usando um teclado virtual? Galera, a questão trata do *screenlogger*, que é um tipo de *spyware*: capaz de armazenar a posição do cursor e a tela apresentada no monitor, nos momentos em que o mouse é clicado, ou a região que circunda a posição onde o mouse é clicado. É bastante utilizado por atacantes para capturar as teclas digitadas pelos usuários em teclados virtuais, disponíveis principalmente em sites de Internet Banking. Ressalva: a questão poderia ter utilizado o termo "instalação" em vez de "propagação" para ficar mais adequado, visto que spywares não se propagam.



Gabarito: Letra C

40.(CESGRANRIO / BB - 2013) Há características importantes que distinguem os códigos maliciosos denominados worm daqueles denominados trojan. Uma dessas características é a:

- a) autorreplicação automática pela rede
- b) instalação por execução de arquivo infectado
- c) contaminação através de redes sociais
- d) contaminação por compartilhamento de arquivos
- e) instalação por execução explícita do código malicioso

Comentários:

Uma diferença básica é que worms são capazes de propagar automaticamente e trojans, não; ademais, trojans não são recebidos automaticamente pela rede e worms são.

Gabarito: Letra A

41.(VUNESP / Câmara de Piracicaba - SP - 2019) Um usuário mal-intencionado enviou um e-mail para o diretor de uma empresa, muito semelhante aos enviados pelo banco, com o intuito de coletar informações pessoais. Esse tipo comum de ataque é conhecido como:

- a) negação de serviço (DoS).
- b) flooding.
- c) força bruta.
- d) phishing.
- e) spoofing.

Comentários:

Usuário mal-intencionado que envia um e-mail muito semelhante aos enviados por um banco com o intuito de coletar informações pessoais é uma característica típica de ataques de phishing.

Gabarito: Letra D

42.(VUNESP / IPSM - 2018) Dentre os tipos de spyware existentes, há um que visa capturar as teclas digitadas por um usuário, no teclado de seu computador. Esse tipo de spyware é conhecido como:

- a) adware.
- b) keylogger.
- c) backdoor.
- d) rootkit.
- e) screenlogger.

Comentários:

O spyware capaz de capturar teclas (keys) digitadas por um usuário é o Keylogger.

Gabarito: Letra B



43.(VUNESP / Câmara de Indaiatuba -SP - 2018) Dentre os vários tipos de códigos maliciosos, foi constatada a infecção com as seguintes características: o código malicioso começou a atuar após acesso a um site e ativação de um link para uma fotografia; alterou e removeu arquivos; instalou um código malicioso; furtou senhas do computador. O tipo de código malicioso descrito é:

- a) bot.
- b) vírus.
- c) worm.
- d) rootkit.
- e) trojan.

Comentários:

(a) Errado, um bot é um programa que dispõe de mecanismos de comunicação com o invasor que permitem que ele seja controlado remotamente; (b) Errado, um vírus busca se propagar infectando, inserindo cópias de si mesmo, anexando-se ou hospedando-se em arquivos ou programas existentes na máquina; (c) Errado, um worm é um programa capaz de se replicar automaticamente, enviando cópias de si mesmo de computador para computador – geralmente congestionando a rede; (d) Errado, um rootkit é um conjunto de programas e técnicas que permite esconder e assegurar a presença de um invasor ou de outro código malicioso em um computador comprometido; (e) Correto. Perceba que o usuário acessou um site com um link para uma fotografia (achando que era algo legítimo), mas depois ocorreram várias atividades maliciosas – característica típica de um cavalo de troia (trojan).

Gabarito: Letra E

44.(VUNESP / PC-BA - 2018) Uma das formas de atuação do ransomware, um dos códigos maliciosos mais difundidos atualmente, é:

- a) capturar as senhas digitadas no computador e enviar para o hacker.
- b) criptografar os dados do disco rígido e solicitar o pagamento de resgate.
- c) enviar várias cópias de uma mensagem de e-mail utilizando os seus contatos.
- d) instalar diversos arquivos de imagens para lotar o disco rígido.
- e) mostrar uma mensagem com propaganda no navegador Internet.

Comentários:

(a) Errado, isso está mais próximo a um keylogger; (b) Correto, essa é uma atuação típica de ransomware; (c) Errado, essa não é uma forma típica de atuação de um ransomware; (d) Errado, essa não é uma forma típica de atuação de um ransomware; (e) Errado, isso está mais próximo a um adware.

Gabarito: Letra B

45.(VUNESP / PC-SP - 2014) O Comitê Gestor da Internet no Brasil define _____ como um programa, ou parte de um programa de computador, normalmente malicioso, que se propaga inserindo cópias de si mesmo e se tornando parte de outros programas e arquivos, para executar ações danosas ou atividades maliciosas em um computador. Assinale a alternativa que preenche corretamente a lacuna do enunciado:

- a) o spam
- b) o vírus
- c) o antivírus
- d) a criptografia



e) o firewall

Comentários:

O Comitê Gestor da Internet no Brasil define o vírus como um programa, ou parte de um programa de computador, normalmente malicioso, que se propaga inserindo cópias de si mesmo e se tornando parte de outros programas e arquivos, para executar ações danosas ou atividades maliciosas em um computador.

Gabarito: Letra B

46.(VUNESP / PC-SP - 2013) Um estudante desatento teve seus dados bancários, financeiros e informações sobre seus hábitos na internet transmitidos de seu notebook para uma empresa localizada na Ásia - sem o seu conhecimento ou consentimento - por um programa que se alojou no seu computador. Esse programa é classificado como:

- a) Uploader
- b) Spyware.
- c) Hacker.
- d) Browser.
- e) Cracker.

Comentários:

Dados bancários, financeiros e informações sobre hábitos? Transmido para uma empresa? Sem consentimento? Trata-se de uma forma típica de ação de um Spyware.

Gabarito: Letra B



LISTA DE QUESTÕES - AOC

1. (AOC / IF-MS - 2025) A segurança na internet é essencial para proteger dispositivos e informações contra ameaças digitais. Em relação aos diferentes tipos de malware, informe se é verdadeiro (V) ou falso (F) o que se afirma a seguir e assinale a alternativa com a sequência correta.

() Phishing é um tipo de malware que se instala em um dispositivo sem o consentimento do usuário, com o objetivo principal de exibir publicidade invasiva.

() Vírus são programas maliciosos projetados para interferir no funcionamento normal de um dispositivo, frequentemente se espalhando para outros dispositivos ao infectar arquivos.

() Ransomware é um tipo de malware que criptografa os dados da vítima, exigindo um pagamento (resgate) para restaurar o acesso a esses dados.

a) F - V - V.

b) V - V - V.

c) V - F - V.

d) V - F - F.

e) F - F - V.

2. (AOC / IF-MS - 2025) O malware refere-se a um código ou aplicativo malicioso projetado para danificar, comprometer ou interromper o funcionamento normal de dispositivos. Quando um sistema é infectado com malware, pode haver roubo de dados, comprometimento de senhas, instalação de outros malwares e perda de informações. Os cavalos de Troia (Trojans) são um tipo de malware que se disfarça de software legítimo para enganar os usuários e induzi-los a baixá-lo e executá-lo. Com base no exposto, assinale a alternativa que NÃO descreve corretamente um cavalo de Troia (Trojan).

a) Um Trojan depende da ação do usuário para ser baixado, geralmente se apresentando como um aplicativo ou arquivo legítimo.

b) Após ser instalado, um Trojan pode baixar e instalar outros tipos de malware, como vírus e worms.

c) Um Trojan criptografa os arquivos do dispositivo da vítima e exige um pagamento de resgate para restaurar o acesso aos dados.

d) Trojans podem ser usados para registrar as teclas digitadas e os sites visitados pelo usuário.

e) Uma vez instalado, um Trojan pode enviar informações confidenciais, como senhas e histórico de navegação, para um invasor mal-intencionado.

3. (AOC / UFS - 2024) Malwares são programas maliciosos que podem assumir várias formas e realizar ações prejudiciais nos sistemas. Entre os diferentes tipos de malwares, o "vírus" é um



dos mais conhecidos. Assinale a alternativa que apresenta a definição correta do malware "vírus".

- a) É um tipo de malware que se anexa a arquivos ou programas legítimos e se replica quando esses arquivos ou programas são executados.
- b) É um tipo de malware que se disfarça como software legítimo, mas realiza ações maliciosas sem o conhecimento do usuário.
- c) É um programa autônomo que se replica e se espalha para outros computadores em uma rede ou pela internet.
- d) É um malware que registra todas as teclas digitadas em um teclado, capturando informações confidenciais, como senhas e informações de cartão de crédito.
- e) Envolve a distribuição de malware por meio de anúncios maliciosos exibidos em sites legítimos.

4. (AOCP / IF-MA - 2023) Utilizando-se dos conceitos de malwares, qual é o nome do programa malicioso capaz de se propagar automaticamente e explorar vulnerabilidades existentes ou falhas em softwares, dispondo de um mecanismo de comunicação com o invasor, permitindo que seu controle seja realizado remotamente?

- a) Worm
- b) Storm
- c) Firewall
- d) Proxy
- e) Bot

5. (AOCP / IF-MA - 2023) Em relação aos softwares maliciosos, assinale a alternativa que apresenta uma característica de um malware classificado como WORM.

- a) Configura-se em uma rede composta por inúmeros equipamentos zumbis utilizados para potencializar as ações danosas provenientes de um ataque.
- b) Permite que um invasor retorne ao equipamento comprometido, por meio da criação ou modificação de serviços no sistema.
- c) Monitora a operação de um computador, coleta e envia as informações coletadas ao invasor.
- d) Armazena teclas digitadas por um ou mais usuários no teclado físico de um computador.
- e) Propaga-se de forma automatizada pelas redes ao explorar vulnerabilidades nos aplicativos instalados nos computadores, enviando cópias de si mesmo de computador para computador.



6. (AOCP / BANESE - 2022) A rede corporativa começou a apresentar lentidão. Os analistas da rede constataram que um tipo bem específico de software malicioso atingiu o ambiente através da rede corporativa, explorando vulnerabilidades encontradas em sistemas operacionais das estações de trabalho e consumindo recursos da rede. Além do que foi relatado, nenhum outro problema foi causado. Pela descrição desse software malicioso, a classificação mais adequada para ele seria

- a) vírus.
- b) cavalo de Troia.
- c) worm.
- d) spyware.
- e) ransomware.

7. (AOCP / SANESUL - 2021) Assinale a alternativa que apresenta uma característica de malware do tipo ransomware.

- a) Exibição de propagandas para o usuário.
- b) Captura de dados digitados no teclado.
- c) Gravação dos dados exibidos na tela do usuário.
- d) Programa que captura dados bancários e envia ao invasor.
- e) Exige quantia em dinheiro para descriptografar dados do usuário.



GABARITO - AOCP

1. LETRA A
2. LETRA C
3. LETRA A
4. LETRA E
5. LETRA E
6. LETRA C
7. LETRA E



LISTA DE QUESTÕES – MULTIBANCAS

1. (CEBRASPE / CNPQ - 2024) Um vírus de computador tem a capacidade de se disseminar automaticamente, sem a necessidade de uma ação humana.
2. (CEBRASPE / ITAIPU BINACIONAL - 2024) Quando instalado em uma estação de trabalho sem o conhecimento e consentimento do usuário, um software de keylogger terá a função de
 - a) um antivírus.
 - b) registrar as teclas digitadas.
 - c) monitorar a disponibilidade do computador.
 - d) criptografar conexões HTTP.
 - e) propagar-se por meio de dispositivos USB.
3. (CEBRASPE / ITAIPU BINACIONAL - 2024) Existe uma série de golpes e fraudes que utilizam a Internet como meio de execução; uma delas tem a ação maliciosa de um golpista tentando obter dados pessoais e financeiros, combinando meios técnicos e engenharia social. Esse tipo de fraude é denominado
 - a) scan.
 - b) DDoS.
 - c) phishing.
 - d) brute force.
 - e) defacement.
4. (CEBRASPE / MPE-TO - 2024) Hijacker é um tipo de malware que invade o computador e criptografa os dados de forma que o usuário perde o acesso aos próprios dados.
5. (CEBRASPE / MPE-TO - 2024) Um tipo muito comum de malware são os chamados worms, programas com capacidade de se replicar, enviando cópias do próprio worm de um computador para outro computador e explorando pontos de vulnerabilidade dos sistemas.
6. (CEBRASPE / APEX - 2024) Determinado software malicioso é conhecido por se propagar automaticamente pela rede de computadores, explorando vulnerabilidades dos sistemas e aplicativos instalados, sendo, inclusive, responsável por consumir muitos recursos, chegando até a afetar o desempenho da rede. Esse é um software do tipo:
 - a) ransomware.
 - b) vírus.
 - c) botnet.
 - d) worm
7. (CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) O alerta a seguir, apresentado ao se navegar em um sítio eletrônico, se refere a um vírus, uma vez que todo software malicioso é um vírus que executa ações danosas e atividades maliciosas no computador.





8. (CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) Em grupos de discussão e redes sociais, não há preocupação com segurança, pois eles são sítios não organizacionais.
9. (CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) Keylogger é um tipo de spyware projetado para monitorar as atividades de um sistema por meio da captura e do armazenamento das teclas digitadas.
- 10.(CEBRASPE / Prefeitura de Cachoeiro de Itapemirim-ES - 2024) O trojan é projetado para espionar o dono do dispositivo, que não autorizou a sua instalação e não sabe que tal código espião está instalado em seu equipamento, permitindo que o agente malicioso receba informações confidenciais coletadas
- 11.(FCC / AL-AP - 2020) Considere que, por hipótese, determinada empresa do ramo de soluções para redes de computadores está negociando com uma empresa-cliente a instalação de um software que proteja contra o sequestro de dados, situação que ocorre quando um computador é invadido por um malware que criptografa arquivos do disco da máquina e exige um resgate em dinheiro virtual ou físico para descriptografar e liberar os dados para uso novamente. Tendo em vista tais dados, esse software em negociação tem, a princípio, a função de
- a) antispam.
 - b) antispware.
 - c) detecção de intrusão.
 - d) defesa de ransomware.
 - e) filtro de rede local com lista de acesso.
- 12.(FCC / TJ-MA - 2019) Não há garantia de que uma vítima possa interromper um ataque de ransomware e recuperar seus dados. No entanto, alguns métodos podem funcionar, como, por exemplo,
- a) reiniciar o computador no modo de segurança e remover o arquivo ransomware.dat do computador.
 - b) reiniciar o computador no modo de segurança, instalar e executar um antivírus e restaurar o computador a um estado anterior não infectado.
 - c) reiniciar o computador a partir de um pen drive de boot do sistema operacional.
 - d) executar um antivírus imediatamente após a mensagem de resgate dos dados ser exibida.
 - e) usar o comando mbr, no prompt de comando do Windows, para reconstruir o registro de pastas e arquivos do disco.
- 13.(FCC / TJ-MA - 2019) A tabela abaixo indica a forma de propagação de 5 malwares.



Como o <i>malware</i> se propaga	I	II	III	IV	V
Insere cópia de si próprio em arquivos	✓				
Envia cópia de si próprio automaticamente pela rede		✓			
Envia cópia de si próprio automaticamente por e-mail		✓			
Não se propaga			✓	✓	✓

De acordo com a tabela, os tipos de malwares numerados de I a V são, correta e respectivamente,

a) I - Vírus

- II - Bot
- III - Spyware
- IV - Backdoor
- V - Rootkit

b) I - Backdoor

- II - Rootkit
- III - Botnet
- IV - Phishing
- V - Worm

c) I - Adware

- II - Bot
- III - Worm
- IV - Phishing
- V - Spyware

d) I - Botnet

- II - Pharming
- III - Rootkit
- IV - Worm
- V - Backdoor

e) I - Rootkit

- II - Backdoor
- III - Pharming
- IV - Vírus
- V - Worm

14.(FCC / SANASA Campinas - 2019) Um intruso, com o objetivo de desativar o destino dos dados ao invés de roubá-los, entrou em centenas de computadores em diversos lugares do mundo e depois comandou todos esses computadores para realizarem um ataque ao mesmo alvo ao mesmo tempo. Essa estratégia tem um grande poder de fogo e reduz a chance de detecção, pois os pacotes vêm de inúmeras máquinas pertencentes a usuários insuspeitos. Um ataque desse tipo é chamado de:

- a) DDoS.
- b) IP spoofing.
- c) Phishing Scam.



- d) BDoS.
- e) Blood.

15.(FCC / TRF - 4ª REGIÃO - 2019) Um Técnico Judiciário está analisando as características de diversas pragas virtuais (malwares), para proceder à instalação de antivírus adequado. Dentre as características específicas por ele analisadas, estão:

I. Programa que, além de executar as funções para as quais foi aparentemente projetado, também executa outras funções, normalmente maliciosas, e sem o conhecimento do usuário. Um exemplo é um programa que se recebe ou se obtém de sites na internet e que parece ser inofensivo. Tal programa geralmente consiste em um único arquivo e necessita ser explicitamente executado para que seja instalado no computador.

II. Programa que permite o retorno de um invasor a um computador comprometido, por meio da inclusão de serviços criados ou modificados para este fim. Pode ser incluído pela ação de outros códigos maliciosos, que tenham previamente infectado o computador, ou por atacantes que explorem vulnerabilidades existentes nos programas instalados no computador. Após incluído, ele é usado para assegurar o acesso futuro ao computador comprometido, permitindo que ele seja acessado remotamente, sem que haja necessidade de recorrer novamente aos métodos utilizados na realização da invasão ou infecção e, na maioria dos casos, sem que seja notado.

III. Programa que torna inacessíveis os dados armazenados em um equipamento, geralmente usando criptografia. O atacante exige pagamento de resgate para restabelecer o acesso ao usuário.

As descrições acima são, correta e respectivamente, correspondentes a:

- a) bot, rootkit e cavalo de troia (trojan).
- b) cavalo de troia (trojan), backdoor e ransomware.
- c) worm, backdoor e vírus.
- d) vírus, spyware e rootkit.
- e) spyware, cavalo de troia (trojan) e ransomware.

16.(FCC / SEMEF Manaus - AM - 2019) Um Assistente de TI identificou o malware que atacou o seu computador como sendo do tipo ransomware, pois apresentava como principal característica:

- a) o pedido de resgate para liberar o acesso aos arquivos.
- b) mostrar propagandas continuamente abrindo janelas do navegador web.
- c) o controle do computador de forma remota.
- d) a modificação dos arquivos do sistema operacional para anular o seu uso.
- e) o uso de muitos recursos deixando o computador lento.

17.(FCC / SEFAZ-BA - 2019) Um Auditor recebeu uma mensagem de e-mail, aparentemente de seu banco, com um link para verificar a existência de uma dívida de cartão de crédito não paga. Preocupado com a situação, clicou no link e forneceu os dados de seu cartão de crédito para pagar a suposta conta. Dias depois percebeu na fatura do seu cartão que foram feitas diversas compras online em sites de comércio eletrônico na Internet. A situação descrita permite concluir que esse Auditor foi vítima de:

- a) rot.
- b) backdoor.
- c) worm.
- d) phishing.



e) ransomware.

18.(FCC / RIOPRETOPREV - 2019) O computador de um usuário foi infectado por um ransomware, um tipo de malware que:

a) torna inacessíveis os dados armazenados no computador, geralmente usando criptografia, e exige pagamento de resgate (via bitcoins) para restabelecer o acesso ao usuário.

b) após identificar potenciais computadores alvos, efetua cópias de si mesmo e tenta enviá-las para estes computadores, por e-mail, chat etc.

c) monitora e captura informações referentes à navegação ou digitação do usuário, e envia estas informações ao atacante.

d) assegura o acesso futuro do atacante ao computador comprometido, permitindo que ele seja acessado remotamente por meio do protocolo Telnet.

e) torna o computador um zumbi, sendo controlado remotamente e desferindo automaticamente ataques de negação de serviço a redes e servidores determinados pelo atacante.

19.(FCC / SABESP - 2019) A Sabesp disponibiliza o e-mail canaldedenuncia@sabesp.com.br para que ocorrências de fraudes e transgressões diversas à política de segurança das informações possam ser denunciadas. Considere, hipoteticamente, que uma denúncia enviada descreveu que um certo funcionário estava fazendo ligações internas se passando por alguém da equipe de suporte técnico de TI solicitando determinadas informações para resolver um suposto problema da Sabesp. Conclui-se, corretamente, que a denúncia se configura em um ataque do tipo:

a) Engenharia Social.

b) Pharming.

c) Advance fee fraud.

d) Spyware.

e) Negação de Serviço.

20.(FCC / SANASA Campinas - 2019) Considere as características de pragas virtuais, abaixo.

I. Não se propaga por meio da inclusão de cópias de si mesmo em outros programas ou arquivos, mas sim pela execução direta de suas cópias ou pela exploração automática de vulnerabilidades existentes em programas instalados em computadores.

II. É um programa ou parte de um programa de computador, normalmente malicioso, que se propaga inserindo cópias de si mesmo e se tornando parte de outros programas e arquivos. Para que possa se tornar ativo e dar continuidade ao processo de infecção, ela depende da execução do programa ou arquivo hospedeiro, ou seja, para que o seu computador seja infectado é preciso que um programa já infectado seja executado.

III. É um programa projetado para monitorar as atividades de um sistema e enviar as informações coletadas para terceiros. Pode ser usado tanto de forma legítima quanto maliciosa, dependendo de como é instalado, das ações realizadas, do tipo de informação monitorada e do uso que é feito por quem recebe as informações coletadas.

Os itens I, II e III descrevem corretamente um:



- a) worm – vírus e spyware.
- b) botnet – trojan e rootkit
- c) backdoor – worm e adware.
- d) vírus – spyware e botnet.
- e) trojan – vírus e rootkit.

21.(FGV / AGENERSA - RJ - 2023) Sobre vírus e worms no contexto de pragas virtuais, analise as afirmativas a seguir.

- I. Worms não precisam se alojar em outros programas para se espalhar.
- II. Vírus e worms agem basicamente enganando os usuários, por meio de e-mails e sites falsos, de forma a obter informações, senhas, dados pessoais e números de contas e cartões de crédito.
- III. Vírus e worms são capazes de replicarem a si mesmos.

Está correto o que se afirma em

- a) I, apenas.
- b) I e II, apenas.
- c) I e III, apenas.
- d) II e III, apenas.
- e) I, II e III.

22.(FGV / TCE-TO - 2022) João acessou a sua conta bancária digitando a senha no seguinte teclado virtual:

6 ou 3	0 ou 9	5 ou 1
4 ou 2	8 ou 7	<

Alguns dias depois, João percebeu que sua conta foi acessada por terceiros.

O ataque spyware que João sofreu foi:

- a) Adware;
- b) Rootkit;
- c) Backdoor;
- d) Keylogger;
- e) Screenlogger.

23.(FGV / Senado Federal - Policial Legislativo - 2022) Sobre a natureza dos ataques Dos e DDoS em redes de computadores, assinale a afirmativa correta.

- a) Enviam numerosos e-mails com links falsos, direcionados para programas e downloads maliciosos.
- b) Interceptam a comunicação em locais públicos em busca de informações sobre logins/senhas, dentre outras.
- c) Tentam assumir remotamente o controle de outros computadores por meio de vulnerabilidades no Firewall.



- d) Tentam sobrecarregar um ou mais servidores de modo a impedir o funcionamento normal os serviços.
- e) Usam a “força bruta” para descobrir, por tentativas e erro, logins/senhas para invadir contas e acessar dados sensíveis.

24.(FGV / MPE-GO - 2021) João acessou seu computador e recebeu a seguinte mensagem:

Todos os seus arquivos foram criptografados.
Realize o pagamento no link indicado e receba a
senha para descriptografar.

A medida de proteção que João deve tomar é instalar um programa que o proteja de ataques do tipo:

- a) Adware.
- b) Keylogger.
- c) Ransomware.
- d) Vírus.
- e) Backdoor.

25.(FGV / TJDF - 2022) João administra uma rede de computadores com muitos sistemas de informação cujas operações são de acesso restrito, pois contém informações confidenciais. Nos últimos meses, João recebeu diversos relatos de ataques de keylogger e screenlog.

Diante desse cenário, João deve proteger a sua rede de ataques do tipo:

- a) *worm*;
- b) *spyware*;
- c) *botnet*;
- d) *zumbi*;
- e) *remote access trojan*.

26.(FGV / SEFAZ-BA - 2022) Com relação às políticas de segurança da informação, analise as afirmativas a seguir.

I. Política de senhas: define o conjunto de regras do uso de senhas em uma rede, bem como recursos computacionais que fazem parte na mesma. Entre as informações contidas na política estão a periodicidade da troca de senha, o tamanho mínimo e máximo e a composição.

II. Política de backup: define regras específicas da realização das cópias de segurança, como os tipos de mídia a serem utilizados no backup, a frequência de execução (diária, semanal, mensal) e o período de retenção das cópias.

III. Política de privacidade online: são regras sociais que não contemplam como as informações pessoais serão tratadas, sejam elas de usuários, clientes, funcionários e fornecedores.

Está correto o que se afirma em:

- a) I, somente.
- b) I e II, somente.
- c) I e III, somente.
- d) II e III, somente.



e) I, II e III.

27.(FGV / TJDF - 2022) Marina recebeu uma ligação de um suposto funcionário que dizia estar fazendo uma pesquisa sanitária sobre uma pandemia. Marina passou suas informações pessoais e profissionais, que permitiram ao falso funcionário acessar um sistema com suas credenciais.

A técnica empregada pelo falso funcionário para conseguir as informações de Marina é:

- a) *poisoning*
- b) *flooding*;
- c) engenharia social;
- d) suborno;

28.(FGV / TJDF - 2022) Carlos recebeu um e-mail que parecia pertencer ao seu banco e, sem perceber, baixou e instalou um software malicioso no seu computador. A partir desse software, um criminoso cibernético passou a ter o controle do computador de Carlos.

O software malicioso instalado no computador de Carlos é:

- a) *phishing*;
- b) DoS
- c) *ransomware*;
- d) *rootkit*;
- e) *sandbox*.

29.(FGV / TJDF - 2022) Marcelo está elaborando a política de segurança em seu órgão e incluiu orientações sobre criação de senhas fortes para acesso aos sistemas, principalmente aqueles acessados pela internet. A orientação do Marcelo visa proteger seus usuários contra ataques de hackers que utilizam software automático para descobrir senhas fracas.

A técnica para obtenção de senhas da qual Marcelo está tentando proteger seus usuários é:

- a) *man-in-the-middle*;
- b) *brute force*;
- c) *backdoors*;
- d) *session hijacking*;
- e) XSS.

30.(FGV / SEFAZ-BA - 2022) O ataque digital que tem como objetivo capturar informações sensíveis por meio de fraudes eletrônicas e que se utiliza de pretextos falsos, com o intuito de receber informações sensíveis dos usuários, e que ocorre com mais frequência por meio do envio de e-mails e páginas web falsas, denomina-se:

- a) *IP spoofing*.
- b) *pharming*.
- c) *fakenews*.
- d) *phishing*.
- e) *toolkit*.

31.(CESGRANRIO / AgeRIO - 2023) Os vírus de computador existem há muitas décadas, mas foi com o advento das redes de computadores, em especial da Internet, que seu poder de disseminação aumentou exponencialmente. Esses vírus podem, por exemplo, apagar todos os



arquivos de um computador. Um vírus de computador é normalmente executado quando uma pessoa, ao utilizar sua estação de trabalho,

- a) abre com o programa bloco de notas um arquivo do tipo texto infectado com um vírus.
- b) envia uma mensagem de correio eletrônico com vírus.
- c) escuta uma música no formato MP4 infectada com um vírus.
- d) executa um programa infectado por um vírus.
- e) visualiza uma foto em formato JPG infectada com um vírus.

32.(CESGRANRIO / BASA - 2022) Códigos maliciosos (malware) são programas desenvolvidos para executar ações danosas e atividades maliciosas em uma grande diversidade de equipamentos. Dentre os vários tipos de malware, há um programa capaz de se propagar automaticamente pelas redes, explorando vulnerabilidades nos programas instalados e enviando cópias de si mesmo de equipamento para equipamento. Esse programa é o:

- a) backdoor
- b) spyware
- c) rootkit
- d) keylogger
- e) worm

33.(CESGRANRIO / AgeRIO - 2023) Os vírus de computador existem há muitas décadas, mas foi com o advento das redes de computadores, em especial da Internet, que seu poder de disseminação aumentou exponencialmente. Esses vírus podem, por exemplo, apagar todos os arquivos de um computador. Um vírus de computador é normalmente executado quando uma pessoa, ao utilizar sua estação de trabalho,

- a) abre com o programa bloco de notas um arquivo do tipo texto infectado com um vírus.
- b) envia uma mensagem de correio eletrônico com vírus.
- c) escuta uma música no formato MP4 infectada com um vírus.
- d) executa um programa infectado por um vírus.
- e) visualiza uma foto em formato JPG infectada com um vírus.

34.(CESGRANRIO / BB - 2021) Muitos códigos maliciosos aproveitam-se de um recurso do Windows 10 que possibilita a execução de um programa presente em um dispositivo de armazenamento USB imediatamente após a sua conexão ao computador. Esse recurso, que pode ser desativado, é conhecido como:

- a) inicialização automática.
- b) execução automática.
- c) reprodução automática.
- d) atualização automática.
- e) configuração automática.

35.(CESGRANRIO / BB - 2021) Os bancos investem em recursos de segurança para minimizar os riscos de fraude nas operações bancárias através de Internet Banking. Os usuários, porém, precisam estar atentos aos golpistas que procuram persuadir vítimas em potencial a acessar sites falsos e a fornecer informações sensíveis. Esse ataque é conhecido como:

- a) botnet.
- b) injection.
- c) spyware.



- d) phishing.
- e) ransomware.

36.(CESGRANRIO / PETROBRAS - 2009) Os itens a seguir relacionam-se corretamente à Internet, EXCETO:

- a) Phishing é uma técnica usada para induzir usuários de computador a revelar informações pessoais ou financeiras, como uma senha de conta bancária.
- b) Com o Microsoft Word, é possível inserir controles de formulário HTML em uma página da Web para criar formulários de coleta ou fornecimento de dados.
- c) Os vírus de e-mail são anexados às mensagens enviadas e o firewall, ao determinar o conteúdo da mensagem, pode, portanto, proteger o computador contra esses tipos de vírus.
- d) World Wide Web é uma rede de computadores na Internet que fornece informação em forma de hipertexto, podendo usar um software chamado browser para descarregar essas informações de servidores de sites e mostrá-las na tela do usuário.
- e) Um upload consiste em se fazer uma cópia de um arquivo de um computador para algum servidor na Internet

37.(CESGRANRIO / UNIRIO - 2016) Os responsáveis por procedimentos de Segurança da Informação devem-se preocupar com usuários mal intencionados, muitas vezes responsáveis por geração de prejuízos empresariais disseminando malwares, roubando senhas ou realizando outra ação qualquer de invasão dos sistemas da empresa. Um exemplo típico é o programador competente, mas mau caráter, que produz programa malicioso capaz de propagar-se automaticamente pela rede de computadores da empresa em que trabalha, por meio de cópias de computador para computador, provocando, por exemplo, lentidão na rede, desaparecimento de arquivos, etc. Os males que esse tipo de programa produz ainda seriam mais graves se dispusesse, como outros malwares, de mecanismos de comunicação que proporcionassem seu controle remoto pelo agente invasor. Esse tipo de programa malicioso é conhecido como:

- a) Adware
- b) Spyware
- c) Keylogger
- d) Vírus
- e) Worm

38.(CESGRANRIO / ANP - 2016) Uma hacker ameaçou divulgar na Web informações sigilosas de uma empresa após ter conseguido acesso a seus sistemas de informação. Para conseguir o acesso, ela telefonou para uma das secretárias da diretoria, passando-se por esposa de um dos diretores. Em seguida, ela disse à secretária que seu marido tinha sofrido um acidente e estava hospitalizado. Porém, antes de ficar inconsciente, o diretor lhe havia pedido que entrasse em contato com a empresa a fim de que uma de suas secretárias solicitasse a mudança do seu login e da sua senha, pois ele havia perdido sua agenda no acidente e temia que alguém pudesse invadir os sistemas da empresa, uma vez que esses dados, por descuido seu, estavam anotados na agenda perdida. Em seguida, a suposta esposa forneceu os novos login e senha à secretária. Esse tipo de ataque para obtenção de informações é chamado de:

- a) informações livres



- b) engenharia social
- c) varredura de vulnerabilidades
- d) dumpster diving
- e) ataque físico

39.(CESGRANRIO / BB - 2015) Os escriturários de uma agência foram chamados para uma reunião com um profissional da área de segurança da informação de um banco. O objetivo dessa reunião era informá-los de que houve uma falha nos procedimentos de segurança da rede de computadores da agência, o que permitiu a propagação de um programa malicioso bastante perigoso. Durante a reunião, o profissional de segurança disse que o programa em questão permite monitorar a movimentação do mouse por sobre a tela de uma aplicação bancária, com o objetivo de descobrir a senha digitada por um usuário que esteja usando um teclado virtual.

Ele completou sua explanação dizendo que esse tipo de código malicioso é chamado de:

- a) vírus
- b) trojan clicker
- c) spyware
- d) botnet
- e) trojan backdoor

40.(CESGRANRIO / BB - 2013) Há características importantes que distinguem os códigos maliciosos denominados worm daqueles denominados trojan. Uma dessas características é a:

- a) autorreplicação automática pela rede
- b) instalação por execução de arquivo infectado
- c) contaminação através de redes sociais
- d) contaminação por compartilhamento de arquivos
- e) instalação por execução explícita do código malicioso

41.(VUNESP / Câmara de Piracicaba - SP - 2019) Um usuário mal-intencionado enviou um e-mail para o diretor de uma empresa, muito semelhante aos enviados pelo banco, com o intuito de coletar informações pessoais. Esse tipo comum de ataque é conhecido como:

- a) negação de serviço (DoS).
- b) flooding.
- c) força bruta.
- d) phishing.
- e) spoofing.

42.(VUNESP / IPSM - 2018) Dentre os tipos de spyware existentes, há um que visa capturar as teclas digitadas por um usuário, no teclado de seu computador. Esse tipo de spyware é conhecido como:

- a) adware.
- b) keylogger.
- c) backdoor.
- d) rootkit.
- e) screenlogger.

43.(VUNESP / Câmara de Indaiatuba -SP - 2018) Dentre os vários tipos de códigos maliciosos, foi constatada a infecção com as seguintes características: o código malicioso começou a atuar após



acesso a um site e ativação de um link para uma fotografia; alterou e removeu arquivos; instalou um código malicioso; furtou senhas do computador. O tipo de código malicioso descrito é:

- a) bot.
- b) vírus.
- c) worm.
- d) rootkit.
- e) trojan.

44.(VUNESP / PC-BA - 2018) Uma das formas de atuação do ransomware, um dos códigos maliciosos mais difundidos atualmente, é:

- a) capturar as senhas digitadas no computador e enviar para o hacker.
- b) criptografar os dados do disco rígido e solicitar o pagamento de resgate.
- c) enviar várias cópias de uma mensagem de e-mail utilizando os seus contatos.
- d) instalar diversos arquivos de imagens para lotar o disco rígido.
- e) mostrar uma mensagem com propaganda no navegador Internet.

45.(VUNESP / PC-SP - 2014) O Comitê Gestor da Internet no Brasil define _____ como um programa, ou parte de um programa de computador, normalmente malicioso, que se propaga inserindo cópias de si mesmo e se tornando parte de outros programas e arquivos, para executar ações danosas ou atividades maliciosas em um computador. Assinale a alternativa que preenche corretamente a lacuna do enunciado:

- a) o spam
- b) o vírus
- c) o antivírus
- d) a criptografia
- e) o firewall

46.(VUNESP / PC-SP - 2013) Um estudante desatento teve seus dados bancários, financeiros e informações sobre seus hábitos na internet transmitidos de seu notebook para uma empresa localizada na Ásia - sem o seu conhecimento ou consentimento - por um programa que se alojou no seu computador. Esse programa é classificado como:

- a) Uploader
- b) Spyware.
- c) Hacker.
- d) Browser.
- e) Cracker.



GABARITO – MULTIBANCAS

1. ERRADO
2. LETRA B
3. LETRA C
4. ERRADO
5. CORRETO
6. LETRA D
7. ERRADO
8. ERRADO
9. CORRETO
10. ERRADO
11. LETRA D
12. LETRA B
13. LETRA A
14. LETRA A
15. LETRA B
16. LETRA A
17. LETRA D
18. LETRA A
19. LETRA A
20. LETRA A
21. LETRA C
22. LETRA E
23. LETRA D
24. LETRA C
25. LETRA B
26. LETRA B
27. LETRA C
28. LETRA D
29. LETRA B
30. LETRA D
31. LETRA D
32. LETRA E
33. LETRA D
34. LETRA C
35. LETRA D
36. LETRA C
37. LETRA E
38. LETRA B
39. LETRA C
40. LETRA A
41. LETRA D
42. LETRA B
43. LETRA E
44. LETRA B
45. LETRA B
46. LETRA B



ESSA LEI TODO MUNDO CONHECE: PIRATARIA É CRIME.

Mas é sempre bom revisar o porquê e como você pode ser prejudicado com essa prática.



1 Professor investe seu tempo para elaborar os cursos e o site os coloca à venda.



2 Pirata divulga ilicitamente (grupos de rateio), utilizando-se do anonimato, nomes falsos ou laranjas (geralmente o pirata se anuncia como formador de "grupos solidários" de rateio que não visam lucro).



3 Pirata cria alunos fake praticando falsidade ideológica, comprando cursos do site em nome de pessoas aleatórias (usando nome, CPF, endereço e telefone de terceiros sem autorização).



4 Pirata compra, muitas vezes, clonando cartões de crédito (por vezes o sistema anti-fraude não consegue identificar o golpe a tempo).



5 Pirata fere os Termos de Uso, adultera as aulas e retira a identificação dos arquivos PDF (justamente porque a atividade é ilegal e ele não quer que seus fakes sejam identificados).



6 Pirata revende as aulas protegidas por direitos autorais, praticando concorrência desleal e em flagrante desrespeito à Lei de Direitos Autorais (Lei 9.610/98).



7 Concurseiro(a) desinformado participa de rateio, achando que nada disso está acontecendo e esperando se tornar servidor público para exigir o cumprimento das leis.



8 O professor que elaborou o curso não ganha nada, o site não recebe nada, e a pessoa que praticou todos os ilícitos anteriores (pirata) fica com o lucro.



Deixando de lado esse mar de sujeira, aproveitamos para agradecer a todos que adquirem os cursos honestamente e permitem que o site continue existindo.